

# Informationssicherheit & Datenschutz

Teil 1 von 2: Informationssicherheit

**Prof. Dr. Thomas Städter**

# Nutzungsrechte

**© FOM Hochschule für Oekonomie & Management  
gemeinnützige Gesellschaft mbH (FOM), Leimkugelstraße 6, 45141 Essen**

Dieses Werk ist urheberrechtlich geschützt und nur für den persönlichen Gebrauch im Rahmen der Veranstaltungen der FOM bestimmt.

Die durch die Urheberschaft begründeten Rechte (u. a. Vervielfältigung, Verbreitung, Übersetzung, Nachdruck) bleiben dem Urheber vorbehalten.

Das Werk oder Teile daraus dürfen nicht ohne schriftliche Genehmigung des Urhebers / der FOM reproduziert oder unter Verwendung elektronischer Systeme verarbeitet, vervielfältigt oder verbreitet werden. Dies schließt auch den Upload in soziale Medien oder andere digitale Plattformen ein.



Instituts-, Kompetenzcentrums-,  
Firmenlogo/s (optional)



## Kurzvita

Station 1 (1979-1986):

Studium der Rechtsmedizin an der Ruhr-Universität Bochum

Station 2 (1987-1993):

Promotion an der Universität Duisburg-Essen  
Thema der Dissertation:

Station 3 (1993-heute):

Geschäftsführer der FOCUS Marketing GmbH

An der FOM seit 2000 (Studienzentrum Essen)

Forschungsschwerpunkt 1

Lorem ipsum dolor sit amet, consectetur adipiscing elit. Aenean commodo

Forschungsschwerpunkt 2

Lorem ipsum dolor sit amet, consectetur adipiscing elit. Aenean commodo

Forschungsfelder

Elektronische Dokumentation und Archivierung -  
Beiträge zwischen Grundlagenforschung und  
Praxis: Marktanforderungen (Industrien und  
Behörden), Technologien (Standards und IT-  
Compliance) und geltende, gesetzliche  
Regelungen.

# Modul- / Veranstaltungsgliederung

|     |                                                                   |
|-----|-------------------------------------------------------------------|
| 1   | Einführung                                                        |
| 1.1 | Modulziele                                                        |
| 1.2 | Prüfungsmodalitäten                                               |
| 1.3 | Literatur                                                         |
| 2   | Ausgangslage und Herausforderungen                                |
| 2.1 | Gefahren für das informationelle Selbstbestimmungsrecht           |
| 2.2 | Cybercrime                                                        |
| 2.3 | Ethische und politische Aspekte                                   |
| 3   | Technische und organisatorische Grundlagen                        |
| 3.1 | Daten und Information                                             |
| 3.2 | Abgrenzung IT-Sicherheit/ Datenschutz                             |
| 3.3 | Schutzziele der IT-Sicherheit                                     |
| 3.4 | Kryptographie                                                     |
| 3.5 | Datenverarbeitung und technisch-organisatorische Maßnahmen (TOMs) |
| 4   | Cyber Security                                                    |
| 4.1 | Ursachen, Auswirkungen und Maßnahmen                              |

# Modul- / Veranstaltungsgliederung

|     |                                                         |
|-----|---------------------------------------------------------|
| 4.2 | Auswahlthemen                                           |
| 5   | Managementaufgaben                                      |
| 5.1 | Governance, Risk & Compliance                           |
| 5.2 | Schutzbedarfsanalyse und Risikomanagement               |
| 6   | ISMS/ DSMS                                              |
| 6.1 | Management-Systeme                                      |
| 6.2 | BSI-Grundschutz und ISO 2700X                           |
| 6.3 | ISMS und DSMS                                           |
| 6.4 | Praktisches Arbeiten mit verinice                       |
| 7   | Datenschutz                                             |
| 7.1 | Allgemeine Begriffsbestimmungen                         |
| 7.2 | Grundsätze für die Verarbeitung personenbezogener Daten |
| 7.3 | Technische und organisatorische Maßnahmen               |
| 7.4 | Pflichten der verantwortlichen Stelle                   |
| 7.5 | Betroffenenrechte                                       |
| 7.6 | Aufbau- und Ablauforganisation                          |
| 7.7 | Internationaler Datenverkehr                            |
| 7.8 | Fallbeispiele                                           |

# 1

## Einführung

# Modulziel

Die Studierenden können nach erfolgreichem Abschluss des Moduls:

- Begriffe der Informationssicherheit, IT-Sicherheit und des Datenschutzes und deren Bedeutung im Unternehmen benennen
- Konzepte und Methoden im Bereich der Informationssicherheit charakterisieren und hinsichtlich ihrer praktischen Relevanz bewerten,
- Anforderungen an die Informationssicherheit aus der unternehmerischen Tätigkeit ableiten,
- Bedrohungen und Risiken für die Informationssicherheit identifizieren, analysieren und bewerten und adäquate Maßnahmen zum Aufbau eines Schutzpotentials definieren,
- die EU-DSGVO und andere relevante Gesetze (z.B. IT-SiG 2.0, TDDDG) verstehen,
- Kryptographische Verfahren kategorisieren und deren konkrete Anwendungsfälle spezifizieren,
- Unterschiedliche Schadsoftware und Angriffsarten beschreiben und daraus resultierende Gegenmaßnahmen ableiten,
- standardisierte Vorgehensweisen bei der Konzipierung eines IT-Sicherheitsmanagements (BSI, ISO) und des Datenschutzmanagements anwenden,

# Modulziel

- die Vorschriften des Datenschutzes und den gesetzeskonformen Umgang mit personenbezogenen Daten anwenden und in die fachlichen Abläufe der IT integrieren,
- moderne Techniken und Vermarktungsformen sowie modernen Informationsverkehr bewerten und deren Umsetzung datenschutzkonform vorbereiten,
- Technisch-organisatorische Maßnahmen zur Gewährleistung des Datenschutzes umsetzen.

## Lehr-/Lernmethoden:

- Seminaristischer Unterricht
- Themenbezogene Diskussionen
- Übungsaufgaben (ÜA) und Fallstudien (FS)
- Gruppenarbeit (GA)
- Strukturiertes Eigenstudium



# Arbeitsmarktrelevanz

Durch die Digitalisierung sowie durch die steigende Komplexität von IT-Architekturen ergeben sich kontinuierlich neue sicherheitstechnische Herausforderungen, die analysiert, gestaltet und verwaltet werden müssen. Zusätzlich sind die Grundsätze und Vorschriften zum Schutz natürlicher Personen bei der Verarbeitung ihrer personenbezogenen Daten zu gewährleisten.

Sämtliche im Wege der Nutzung von digitalen Diensten erhobenen Informationen sind gemäß des Telekommunikation-Digitale-Dienste-Datenschutz-Gesetz (TDDDG) und der Datenschutz-Grundverordnung (DSGVO) umzusetzen. Dabei steigt auch der Aufwand für Risikomanagement und Compliance stetig an.

Um diese Anforderungen und komplexen Aufgabenstellungen systematisch und qualifiziert zu analysieren, zu verwalten und Lösungsvorschläge zu generieren, sind die in diesem Modul erworbenen Kenntnisse zielführend.

# Prüfungsmodalitäten

## Prüfung und Benotung

Klausur 90 Minuten (100% der Modulnote)

Transferaufgabe in der Klausur (etwa 10% des Klausurumfangs):

- In der Veranstaltung werden Arbeits- und/oder Rechercheaufgaben mit explizitem Transferbezug zum praktischen Umfeld der Studierenden gestellt.
- Im Rahmen der Klausur wird dann durch angelehnte (nicht zwingend identische) Fragestellungen die Übertragung wissenschaftlicher Inhalte und Methoden auf konkrete betriebliche oder gesellschaftliche Probleme reflektiert.

# Aktivierende Lehrmethoden in diesem Modul

## Lehrmaterialien und SW-Tools:

- Fallstudie Sicherheitsmanagement
- Übungsaufgaben (ÜA) und Gruppenarbeiten (GA)
- verinice als ISMS-Tool; Info und Download unter: <http://www.verinice.com>

## Diverse Vorlagen, z.B. für:

- Risikoanalyse
- Systemlandschaft

## Websites / Gesetztestexte

- <https://dsgvo-portal.de>
- <https://dsgvo-gesetz.de>

- BSI – Bundesamt für Sicherheit in der Informationstechnik (2022). IT-Grundschutz Kompendium, Edition 2022 [https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/Grundschutz/Kompendium/IT\\_Grundschutz\\_Kompendium\\_Edition2022.pdf](https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/Grundschutz/Kompendium/IT_Grundschutz_Kompendium_Edition2022.pdf)
- Bedner, Mark; Ackermann, Tobias (2010): Schutzziele der IT-Sicherheit. In: DuD 34 (5), S. 323–328
- Datenschutzrecht: DatSchR (2023), 15. Aufl., Beck im dtv
- Eckert, C. (2018): IT-Sicherheit, Konzepte-Verfahren-Protokolle, De Gruyter
- ENISA (2021): Guideline on Security Measures under the EECc, European Union Agency for Cybersecurity, <https://www.enisa.europa.eu/publications/guideline-on-security-measures-under-the-eecc>
- Pohlmann, N. (2019): Cyber-Sicherheit, Springer Vieweg
- Schrahe, D. & Städter, T. (2019): Integration von Informationssicherheits- und Datenschutzmanagement, in: Datenschutz und Datensicherheit - DuD, 43(5), S. 265-269, <https://rdcu.be/bz9Sb>

## Ergänzende Literatur

- Forgó, N., Helfrich, M. & Schneider, J. (2019): Betrieblicher Datenschutz, 3. Aufl., C.H. Beck
- Kersten, H., Klett, G., Reuter, J. & Schröder, K.-W. (2016): IT-Sicherheitsmanagement nach der neuen ISO 27001, Springer, 2016
- Kersten, H. & Klett, G. (2015): Der IT Security Manager, Springer
- Laudon C.K., Laudon, J.P. & Schoder, D. (2016): Wirtschaftsinformatik, Pearson
- Pohlmann, N., Blumberg, H. (2006): Der IT-Sicherheitsleitfaden: Das Pflichtenheft zur Implementierung von IT-Sicherheitsstandards im Unternehmen, mitp-Verlag

# 2

## Ausgangslage und Herausforderungen

# Grundrechte sind das Fundament der Demokratie



**Wer die Freiheit aufgibt, um Sicherheit zu gewinnen,  
wird am Ende beides verlieren.“**

**Benjamin Franklin**

# Gefahren für das informationelle Selbstbestimmungsrecht

## Daten sind der Rohstoff und wichtigste Geschäftsgrundlage vieler IKT- Anwendungen

[Karaboga et al., 2014]

- Werbung als Geschäftsgrundlage
- Weiterverkauf von Daten und Analysen
- Begrenzung der Datenverarbeitung auf das erforderliche Maß und Zweckbindung erfolgt nicht [Schaar, 2014]

**„If you're not paying for something, you're not the customer, you're the product being sold.“**

- [Andrew Lewis]

## Paradigmenwechsel in der IKT

- „data-driven economy“
- Konzentration und Monopolbildung, immer weniger „Big Player“
- Rechtsordnungen sind grundsätzlich national ausgerichtet, Datenverarbeitung ist aber global

## Datenmacht: Immer mehr Daten in immer weniger Händen!

[Schaar, 2014]



# Risiken für Unternehmen

## Studie des Instituts der deutschen Wirtschaft Köln für die Vereinigung der Bayerischen Wirtschaft (vbw)

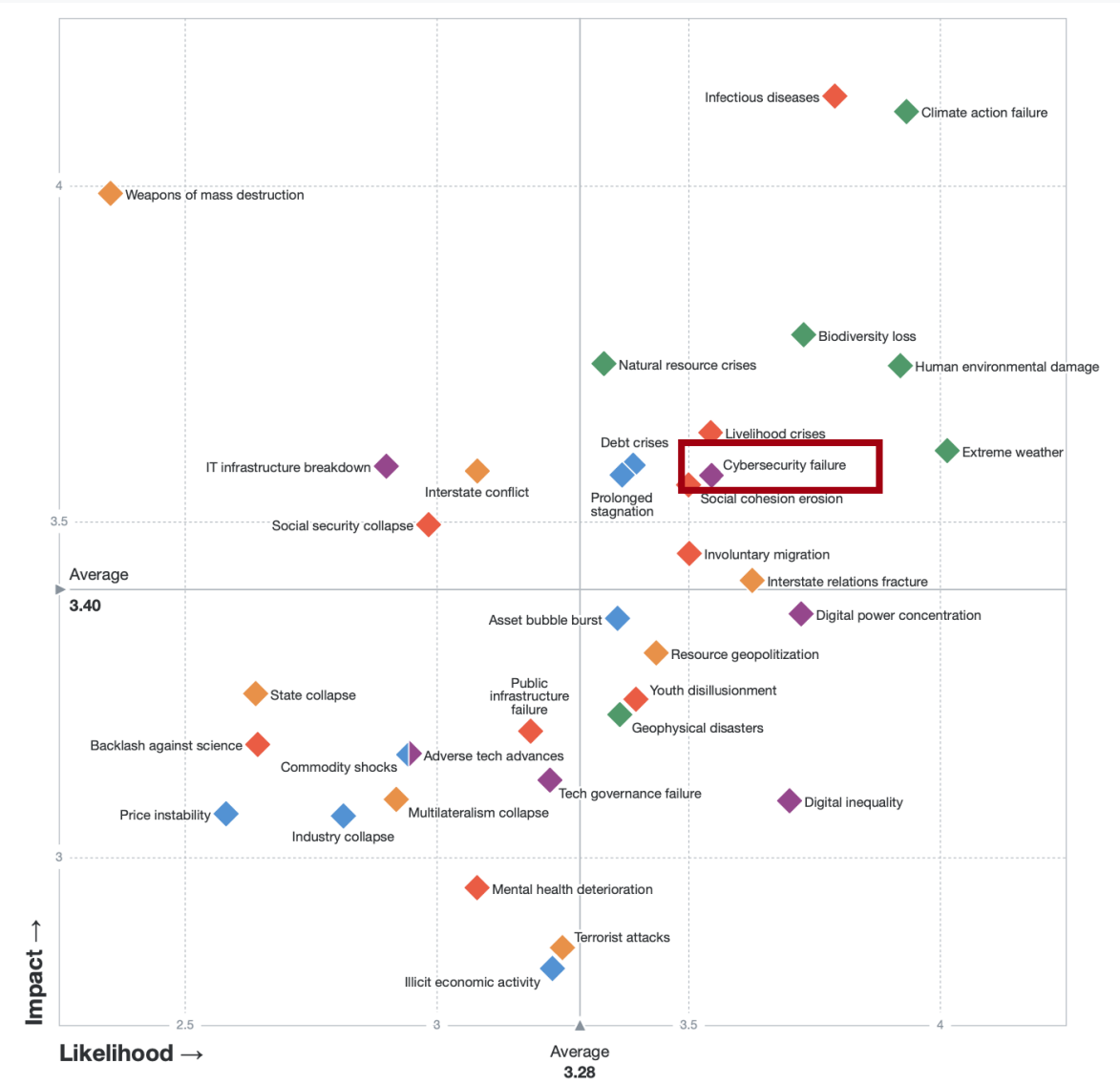
- 42 Prozent der befragten Firmen sehen ein hohes Risiko durch aktuelle und weitere Pandemien
- nur für 8 Prozent gibt es dauerhafte Gegenmaßnahmen.

## Cyberkriminalität

- das am zweithäufigsten genannte Risiko (27 Prozent)
- viel mehr Vorsorge: 62 Prozent der Unternehmen tun dauerhaft etwas dagegen.

**„... steigenden Bedarf an internationaler Risikokompetenz der Unternehmen“**

[B. Brossardt, vbw]



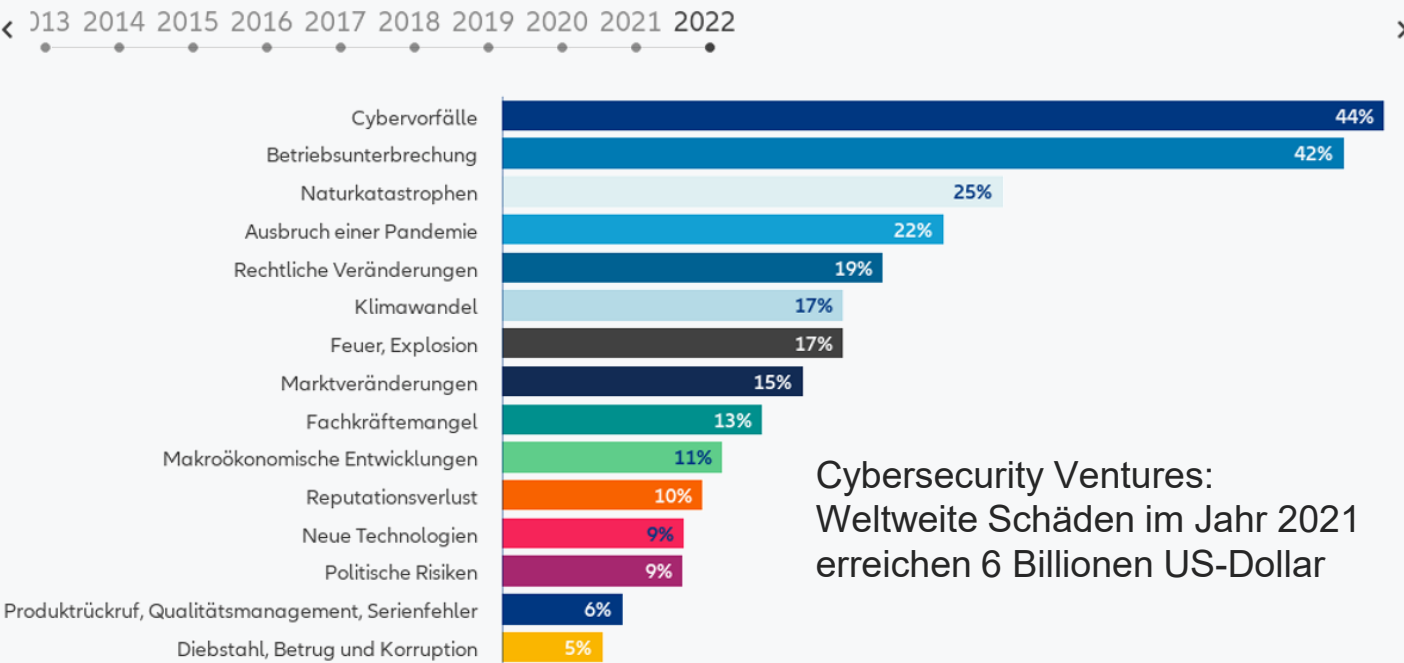
Quelle: World Economic Forum Global Risks Perception Survey 2020



# Top 10 Geschäftsrisiken weltweit in den vergangenen 10 Jahren

Allianz Risk Barometer 2013 - 2022

Diese Grafik zeigt, wie sich die Sichtweise **ausgewählter** Top-Risiken in den letzten 10 Jahren verändert hat (% der Antworten). Nicht alle Risiken, die in der jährlichen Umfrage genannt wurden, erscheinen in dieser Grafik, da sich Risiken und Kategorisierungen im Laufe der Zeit verändert haben. Um die Top-Risiken für jedes Jahr nach Rangfolge zu sehen, klicken Sie auf: [Allianz Risk Barometer](#).



Cybersecurity Ventures:  
Weltweite Schäden im Jahr 2021  
erreichen 6 Billionen US-Dollar

AGCS News & Insights

Quelle: Allianz Global Corporate & Specialty

# Schaden steigt auf 266,6 Milliarden Euro

Welche Schäden sind Ihrem Unternehmen im Zusammenhang mit Diebstahl, Industriespionage oder Sabotage entstanden?

| Schaden durch...                                                                                   | Schadenssummen in<br>Mrd. Euro (2024) | Schadenssummen in<br>Mrd. Euro (2023) | Schadenssummen in<br>Mrd. Euro (2022) |
|----------------------------------------------------------------------------------------------------|---------------------------------------|---------------------------------------|---------------------------------------|
| Ausfall, Diebstahl oder Schädigung von Informations- und Produktionssystemen oder Betriebsabläufen | 54,5                                  | 35,0                                  | 41,5                                  |
| Kosten für Rechtsstreitigkeiten                                                                    | 53,1                                  | 29,8                                  | 16,2                                  |
| Umsatzeinbußen durch nachgemachte Produkte bzw. Plagiate                                           | 39,2                                  | 15,3                                  | 21,1                                  |
| Kosten für Ermittlungen und Ersatzmaßnahmen                                                        | 32,2                                  | 25,2                                  | 10,1                                  |
| Datenschutzrechtliche Maßnahmen, z.B. durch Behörden                                               | 27,2                                  | 12,4                                  | 18,3                                  |
| Imageschaden bei Kunden oder Lieferanten, Negative Medienberichterstattung                         | 20,2                                  | 35,3                                  | 23,6                                  |
| Patentrechtsverletzungen, auch vor Anmeldung                                                       | 14,8                                  | 10,4                                  | 18,8                                  |
| Erpressung mit gestohlenen Daten                                                                   | 13,4                                  | 16,1                                  | 10,7                                  |
| Umsatzeinbußen durch Verlust von Wettbewerbsvorteilen                                              | 11,2                                  | 21,5                                  | 41,5                                  |
| Geldabfluss durch Betrugsversuche                                                                  | 0,8                                   | 3,9                                   | -                                     |
| Sonstige Schäden                                                                                   | 0                                     | 1,1                                   | 0,9                                   |
| Gesamtschaden pro Jahr                                                                             | 266,6                                 | 205,9                                 | 202,7                                 |

Basis: Alle Unternehmen (n=1.003) | Mehrfachnennungen möglich | rundungsbedingt kann die Summe der Einzelschäden vom Gesamtschaden abweichen. | Quelle: Bitkom Research 2024



# Digitalisierung aller Lebens- und Wirtschaftsbereiche

**SmartCity, SmartHome oder auch Industrie 4.0 vergrößern die Angriffsfläche für Kriminelle, es entstehen neue Risiken!**

## **Das BSI warnt in seinem ersten Bericht zum digitalen Verbraucherschutz**

- Verbraucher sind Schwachstellen oft "hilflos ausgeliefert"
- Sorgen bereiten vor allem das Internet der Dinge und Gesundheits-Apps
- Vernetzte Türklingeln, „smartes“ Spielzeug
- Windows-7-Installationen
- Sorglosigkeit der Verbraucher

# Bundeslagebild Cybercrime (1/2)

## Ransomware / Verschlüsselungstrojaner

- Digitale Erpressung

## DDoS (Distributed Denial of Service)

- Fehlerhafte Heimvernetzungen
- Angriffe auf digitale Infrastrukturen
  - IoT (Internet of Things) und Industrie 4.0
- Machen das Leben leichter aber ...
- „Sicherheitsalptraum“

## Cybercrime-as-a-Service

- Bereitstellung von Botnetzen für verschiedenste kriminelle Aktivitäten
- DDoS-Attacken
- Malware-Herstellung und Verteilung
- Datendiebstahl

## Doxing

- Veröffentlichung privater Daten zum Schaden einer Person

[Quellen: [Bitkom, 2024](#); [BSI, 2024](#); [BKA, 2024](#)]

## Bundeslagebild Cybercrime (2/2)

### BKA Bundeslagebild Cybercrime 2024

- [https://www.bka.de/DE/AktuelleInformationen/StatistikenLagebilder/Lagebilder/Cybercrime/2024/CC\\_2024.html](https://www.bka.de/DE/AktuelleInformationen/StatistikenLagebilder/Lagebilder/Cybercrime/2024/CC_2024.html)

### World's Biggest Data Breaches & Hacks

- <http://www.informationisbeautiful.net/visualizations/worlds-biggest-data-breaches-hacks/>

### Datenlecks kosten Unternehmen durchschnittlich rund 4 Millionen Euro

- IBM-Studie: [https://www.ibm.com/reports/data-breach?\\_gl=1\\*1ao7t15\\*\\_ga\\*MTM5NDg0MzYxNi4xNjkwMTc3ODgw\\*\\_ga\\_FYECCCS21D\\*MTY5MDE3Nzg3OS4xLjEuMTY5MDE3ODE2OC4wLjAuMA..](https://www.ibm.com/reports/data-breach?_gl=1*1ao7t15*_ga*MTM5NDg0MzYxNi4xNjkwMTc3ODgw*_ga_FYECCCS21D*MTY5MDE3Nzg3OS4xLjEuMTY5MDE3ODE2OC4wLjAuMA..)
- <https://www.heise.de/news/IBM-Studie-Datenlecks-kosten-Unternehmen-durchschnittlich-rund-4-Millionen-Euro-9224457.html>

### Die Lage der IT-Sicherheit in Deutschland 2024

- BSI: <https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/Publikationen/Lageberichte/Lagebericht2024.html>

# IT-Sicherheit im Home-Office

## BSI-Umfrage

- Seit Beginn der Corona-Pandemie hat sich die Zahl der Heimarbeitsplätze verdoppelt
- 12 Millionen Beschäftigte sind ins Homeoffice gewechselt. Für viele ist das spontan geschehen, IT-Sicherheit hat dabei oft keine Rolle gespielt.
- 66 Prozent der befragten Unternehmen betreiben ein VPN, 8 Prozent planen eines einzurichten. Datenträger im Homeoffice werden von 64 Prozent verschlüsselt, 9 Prozent planen dies.
- 38 Prozent der Unternehmen managen die Sicherheit von Handys, Laptops, Tablets und weiteren mobile Endgeräte mit Verbindung zum Firmennetzwerk.

Für mobiles Arbeiten bedürfe es einer richtigen Balance zwischen dem benutzerfreundlichen Zugriff auf Unternehmensdaten und dem Schutz der IT. Dabei seien ein robustes und risikobasiertes IT-Sicherheitsmanagement gefordert, Mitarbeiterschulungen und gut durchdachte Notfallkonzepte.

- [Achim Berg, Bitkom]



# Schatten-IT im Home-Office

Einsatz privater Geräte und Software-Tools, die nicht von der zentralen IT im Unternehmen verwaltet, kontrolliert und abgesichert werden.

## Gründe

- Erledigung bestimmter, arbeitsbezogener Aufgaben – im Kontext geltender oder nicht geltender Unternehmensrichtlinien
- Schwierigkeit, ohne Schatten-IT diese Aufgaben zu bewältigen

## Risiken

- Speichern oder Übertragen von Arbeitsaufgaben auf USB-Sticks
- Nutzung privater e-Mail- und Cloud-Dienste für Arbeitszwecke
- Sorglosigkeit im Umgang mit physischen Arbeitsunterlagen
- Ausdrucken von Arbeitsunterlagen auf privaten Geräten
- Nutzung der Arbeitsgeräte des Arbeitgebers auch für private Zwecke
- Stressfaktoren im Home-Office

## ... es wird schon irgendwie funktionieren

### Ein Warnschild am Abgrund

Ein Reisender erkundigt sich empört bei einem Einheimischen: "Sagen Sie mal, warum steht denn an diesem gefährlichen Abgrund kein Warnschild?"

Der Einheimische blickt kurz auf: "Das haben wir wieder abgenommen. Da ist sowieso keiner runtergefallen."

### Zwei Männer und ein Regenschirm

Zwei Männer aus Chelm gingen spazieren. Der eine nahm seinen Regenschirm mit, der andere nicht. Nach einer Weile fing es an zu regnen.

"Spann deinen Schirm auf", sagte der Mann, der keinen Schirm dabei hatte. Der andere erwiderte: "Das nützt nichts." – "Was soll das heißen?", sagte der erste. "Ein Regenschirm schützt uns vor dem Regen." – "Der hier aber nicht", sagte der Mann mit dem Schirm, "er ist löcherig wie ein altes Sieb."

"Ja, warum hast du ihn dann überhaupt mitgenommen?" fragte der erste. Der Mann mit dem Schirm antwortete: "Ich habe gedacht, es würde nicht regnen."

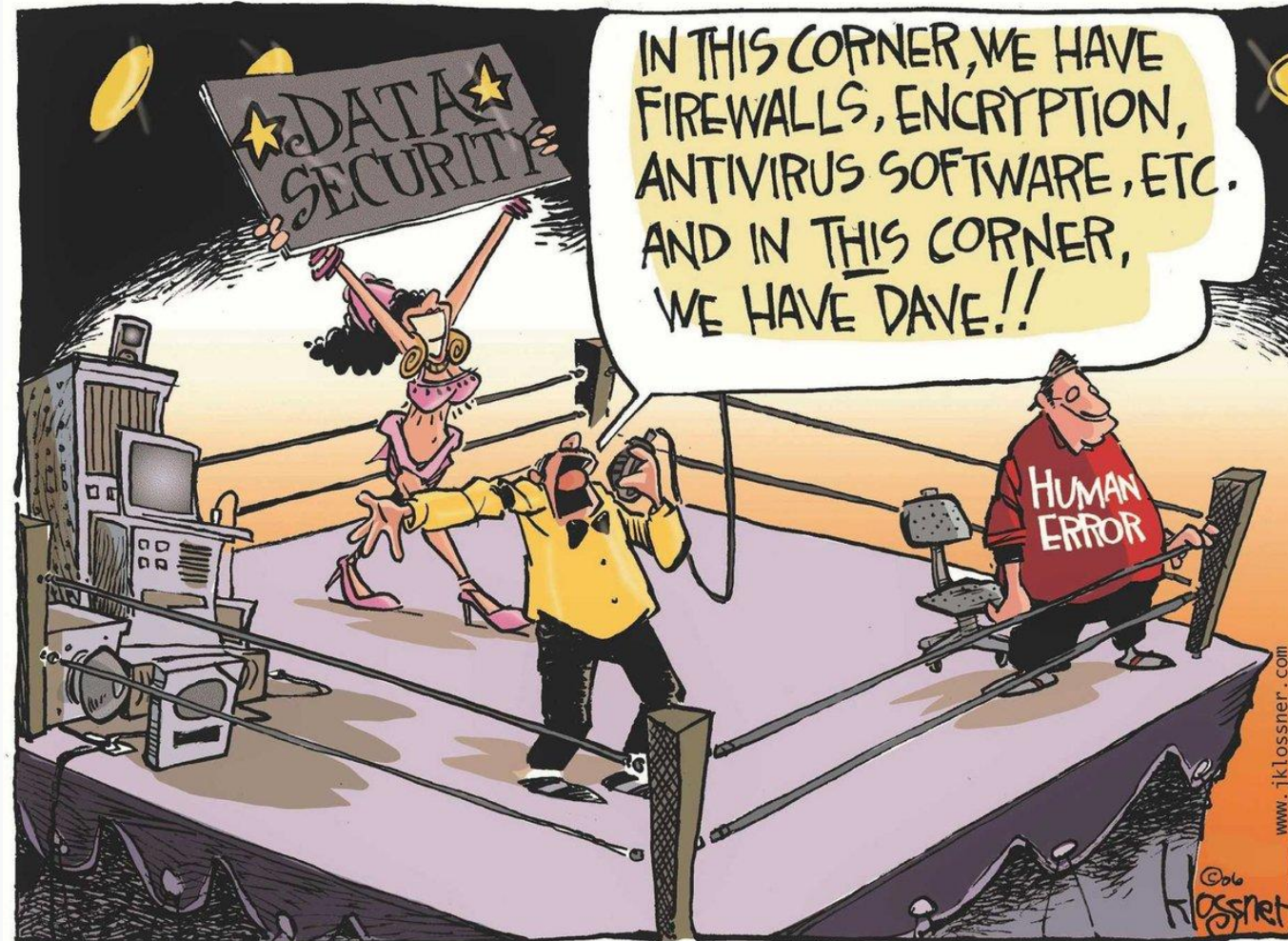
## **ABER: Das „schwächste Glied in der Kette bestimmt die Sicherheit**

**Ein Gesamtsystem bestehend aus IT-Komponenten und Mitarbeitern ist nur so stark, wie das schwächste Glied in der Kette.**





# Generalprobe für die Bedrohungen des 21. Jahrhunderts



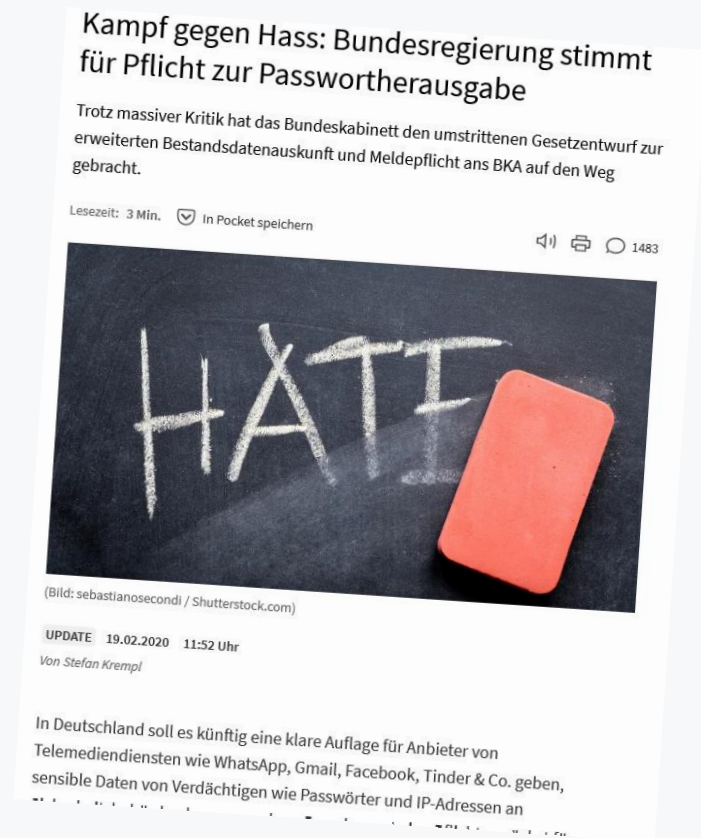
## Ethische und politische Aspekte

„Die Informationstechnik ist ein überraschend wirksames Werkzeug zur Unterdrückung: nicht nur zur Überwachung, sondern auch zu Zensur und Propaganda. Und die Regierungen werden immer besser darin, es einzusetzen. Je mehr wir glauben, wir seien „im Krieg“ und der chauvinistischen Rhetorik vertrauen, desto mehr sind wir bereit, unsere Privatsphäre, unsere Freiheiten und die Kontrolle über das Internet aufzugeben.“

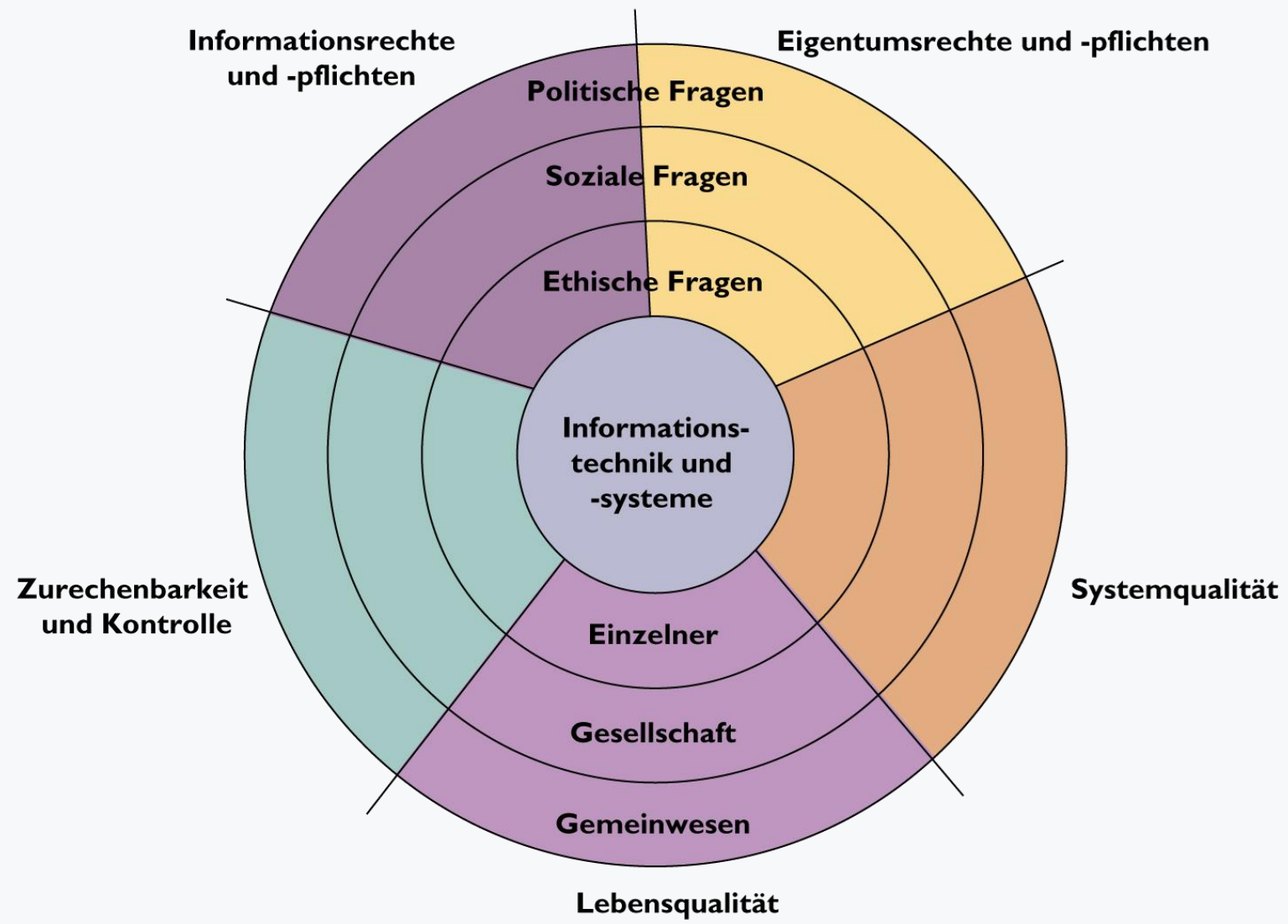
- [Bruce Schneier, Kryptoexperte]

"Wenn Sie argumentieren, dass Sie keine Privatsphäre brauchen, weil Sie nichts zu verbergen haben, ist das so, als würden Sie sagen, dass Sie keine Freiheit der Meinungsäußerung brauchen, weil Sie nichts zu sagen haben.“

- [Edward Snowden, Whistleblower]



# ÜA: Diskussion ethischer, sozialer und politischer Fragen



Quelle: Laudon, 2006, S. 226

# ÜA: Diskussion moralischer Aspekte von Informationssystemen und IT-Sicherheit

## Informationsrechte und Pflichten

Privatsphäre und Freiheit im Internetzeitalter

## Eigentumsrechte

Geistiges Eigentum

## Zurechenbarkeit, Haftung und Kontrolle

Wer ist verantwortlich und haftbar?

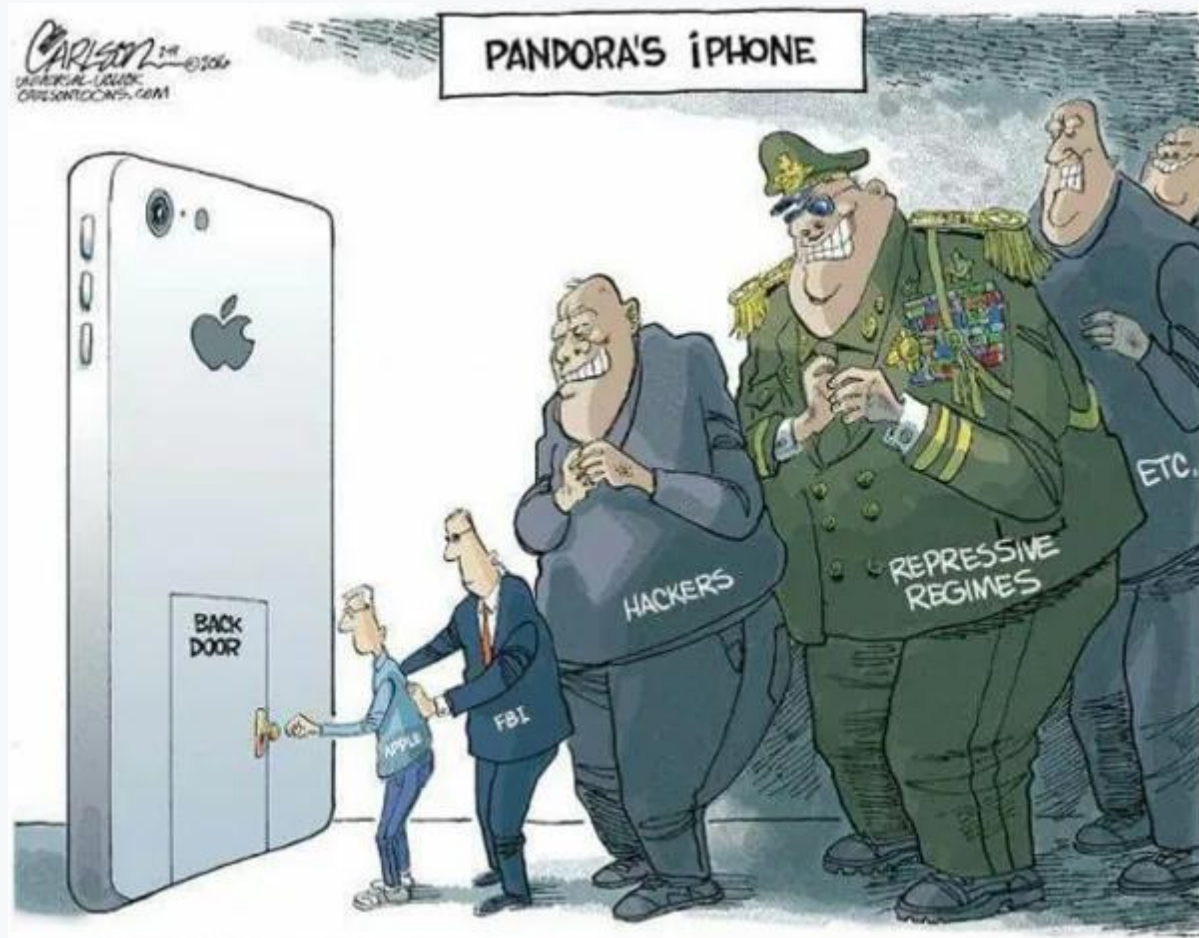
## Systemqualität

Datenqualität und Systemfehler

## Lebensqualität

Wert, Zugang und Grenzen





**Schlange stehen, um an verschlüsselte Daten zu gelangen:**

Jede Verschlüsselungs-Hintertür ist eine Schwachstelle.

Diese zu bauen ist einfach – sie zu sichern ist unmöglich!



# 3

## Technische und organisatorische Grundlagen

# Was sind Daten?

**„Daten sind Werte und Befunde über Dinge, Ereignisse und Zustände, die durch Beobachtung und Messung ermittelt werden und in ihrer Formulierung technisch festgehalten werden.“**

## Datenarten

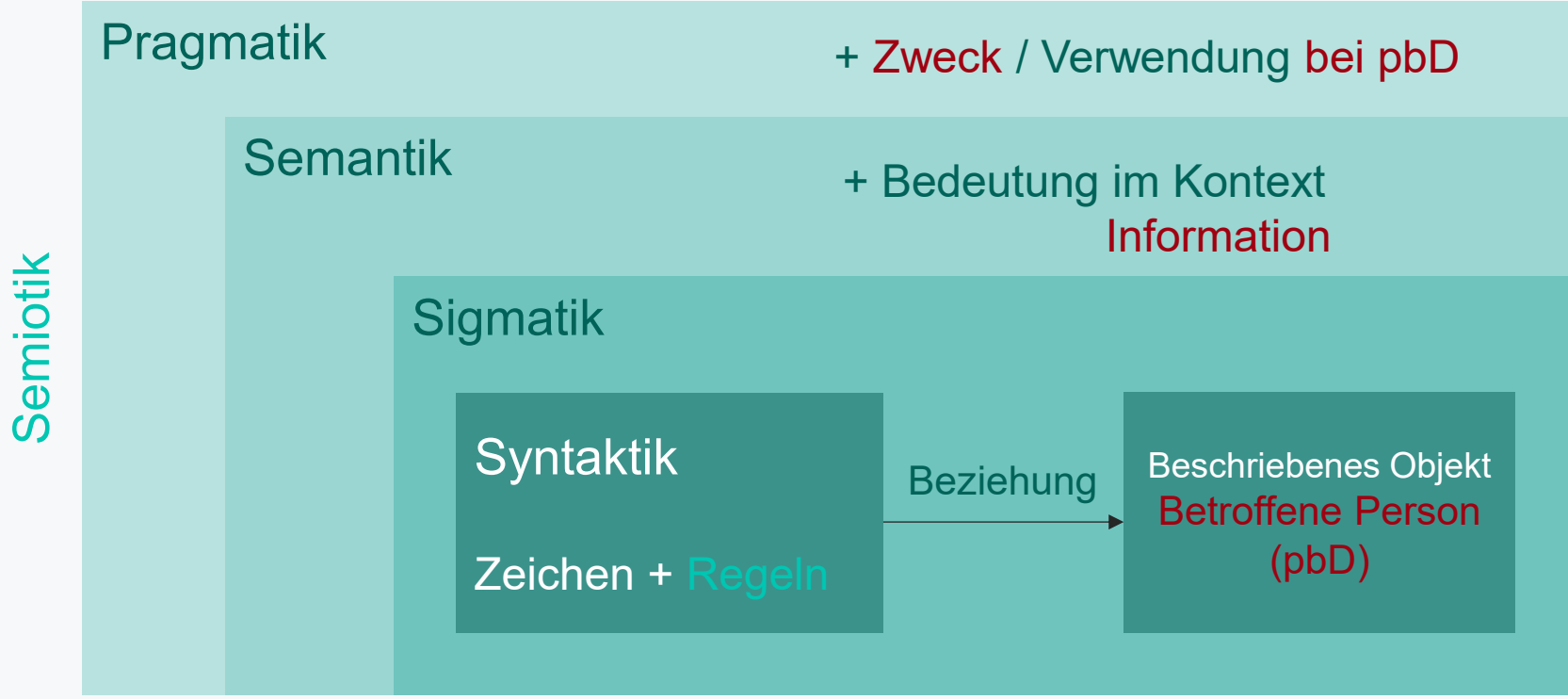
Persönliche Daten: Informationen, die sich auf eine natürliche Person beziehen

Technische Daten: Informationen, die sich auf eine Sache beziehen

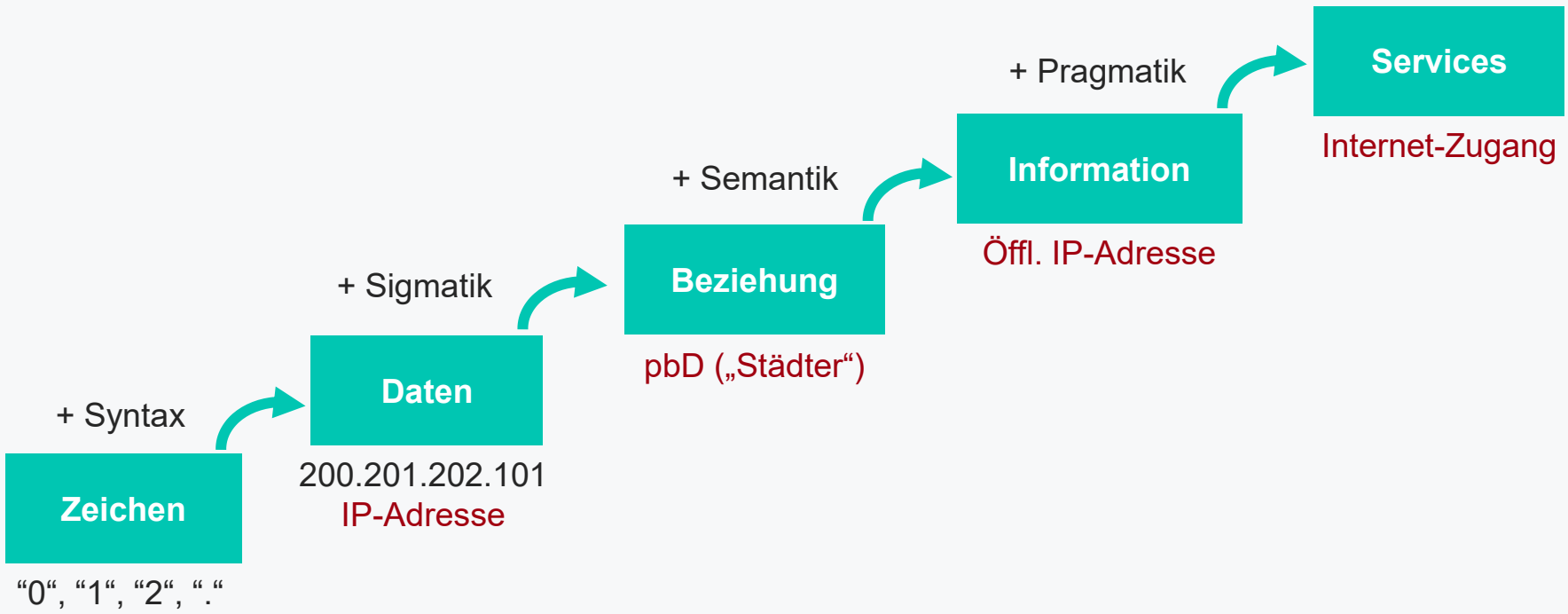
Anonyme bzw. freie Daten

- Persönliche Daten, deren Personenbezug nur mit unverhältnismäßig hohem Aufwand wiederhergestellt werden kann
- Informationen die legal frei zugänglich gemacht wurden

# Was sind Daten bzw. Informationen?



Quelle: Eigene Darstellung

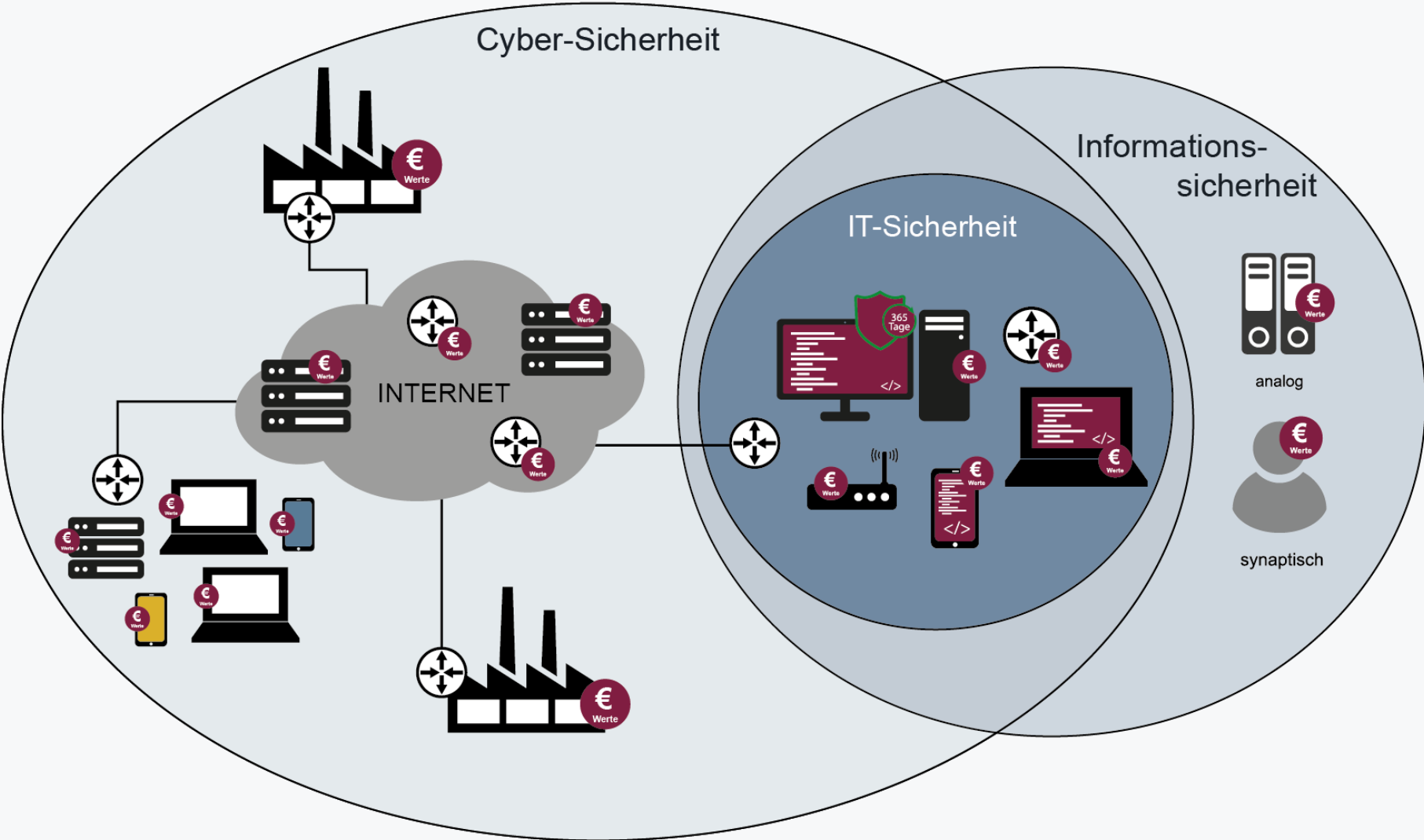


Quelle: Eigene Darstellung

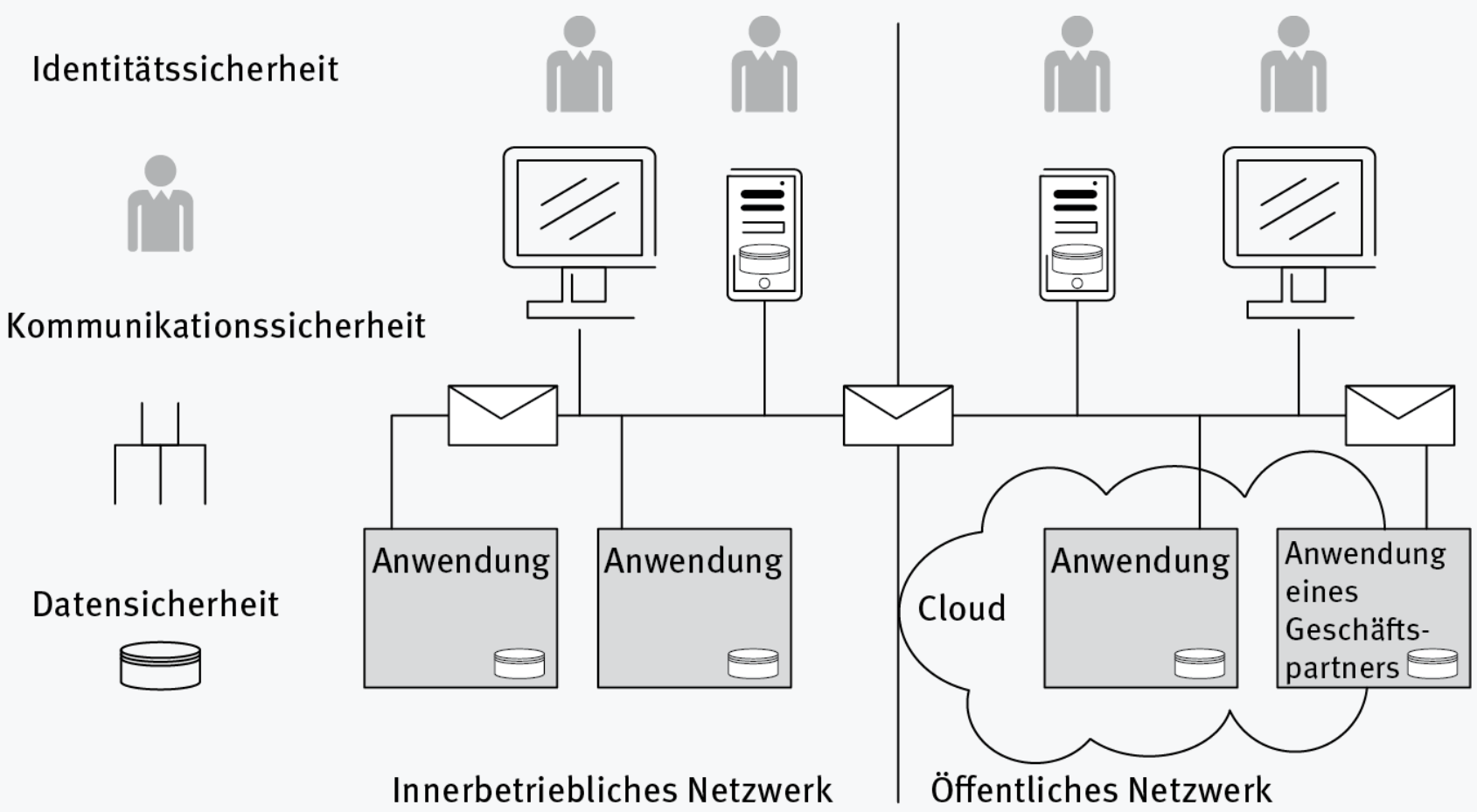
# 3.2

## Abgrenzung IT-Sicherheit/ Datenschutz

# Cyber-Sicherheit, Informationssicherheit und IT-Sicherheit



Quelle: © Prof. Norbert Pohlmann – Glossar Cyber-Sicherheit



Quelle: Hansen et al., 2015

# Datensicherheit

**Vertraulichkeit („Lesen“)** \*

**Integrität („Schreiben“)** \*

**Verfügbarkeit („Ausführen“)**

\*Grundrecht auf Gewährleistung der Vertraulichkeit und Integrität informationstechnischer Systeme (IT-Grundrecht, Computer-Grundrecht), 2008

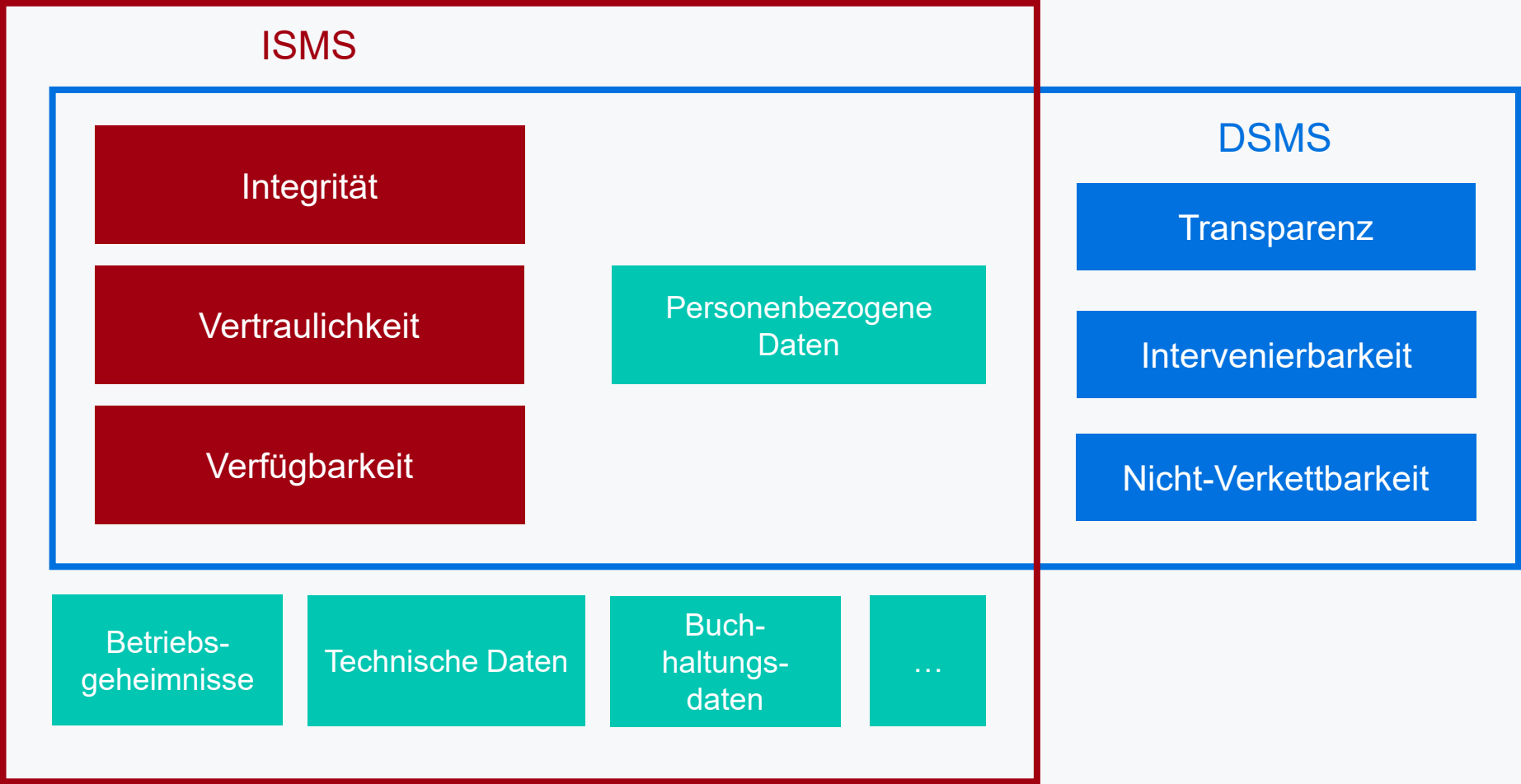


# Abgrenzung IT-Sicherheit / Datenschutz

|                   | IT-Sicherheit                                                                      | Datenschutz                                                                                                                   |
|-------------------|------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------|
| Schutzzweck       | Dient dem Interesse der verarbeitenden Stelle                                      | Dient dem Interesse des Betroffenen                                                                                           |
| Funktion          | Schützt vor dem Verlust der Vertraulichkeit, Integrität und Verfügbarkeit          | Schützt vor Technik, Intransparenz und ungerechtfertigten Verkettungen von Daten, Prozessen und Ereignissen mit Personenbezug |
| Maßnahmen         | Technisch-Organisatorische IT-Sicherheitsmaßnahmen<br>Realisieren auch Datenschutz | Datenschutzmaßnahmen<br>Realisieren auch IT-Sicherheitsmaßnahmen                                                              |
| Anwendungsbereich | Automatisierte Datenverarbeitung                                                   | Alle Verarbeitungsarten                                                                                                       |

IT-Grundschutz und IT-Sicherheitsmanagementsysteme (ISMS nach ISO27001) sind grundrechtskonform zu gestalten!

# Schutzziele von ISM und DSM



Quelle: Schrahe & Städter, 2019

# IT-Sicherheitsbeauftragter / Datenschutzbeauftragter

## IT-Sicherheitsbeauftragter

- stimmt die Informationssicherheitsziele mit den Zielen des Unternehmens ab
- erstellt die Leitlinie zur Informations-sicherheit und stimmt diese mit der Leitungsebene ab
- verantwortet den Aufbau, Betrieb und Weiterentwicklung der Informations-sicherheitsorganisation innerhalb des Unternehmens
- erstellt und erlässt Richtlinien und Regelungen für die Informationssicherheit
- berät die Leitungsebene in allen Fragen der Informationssicherheit
- initiiert und kontrolliert die Umsetzung von Informationssicherheitsmaßnahmen
- plant und konzeptualisiert die Notfallvorsorge und erstellt ein Notfallhandbuch zur Bewältigung von Notfällen
- ...

## Datenschutzbeauftragter

- allgemeine betriebswirtschaftliche und organisatorische Beratung des Auftraggebers zur Realisierung des Datenschutzes und der Datensicherheit

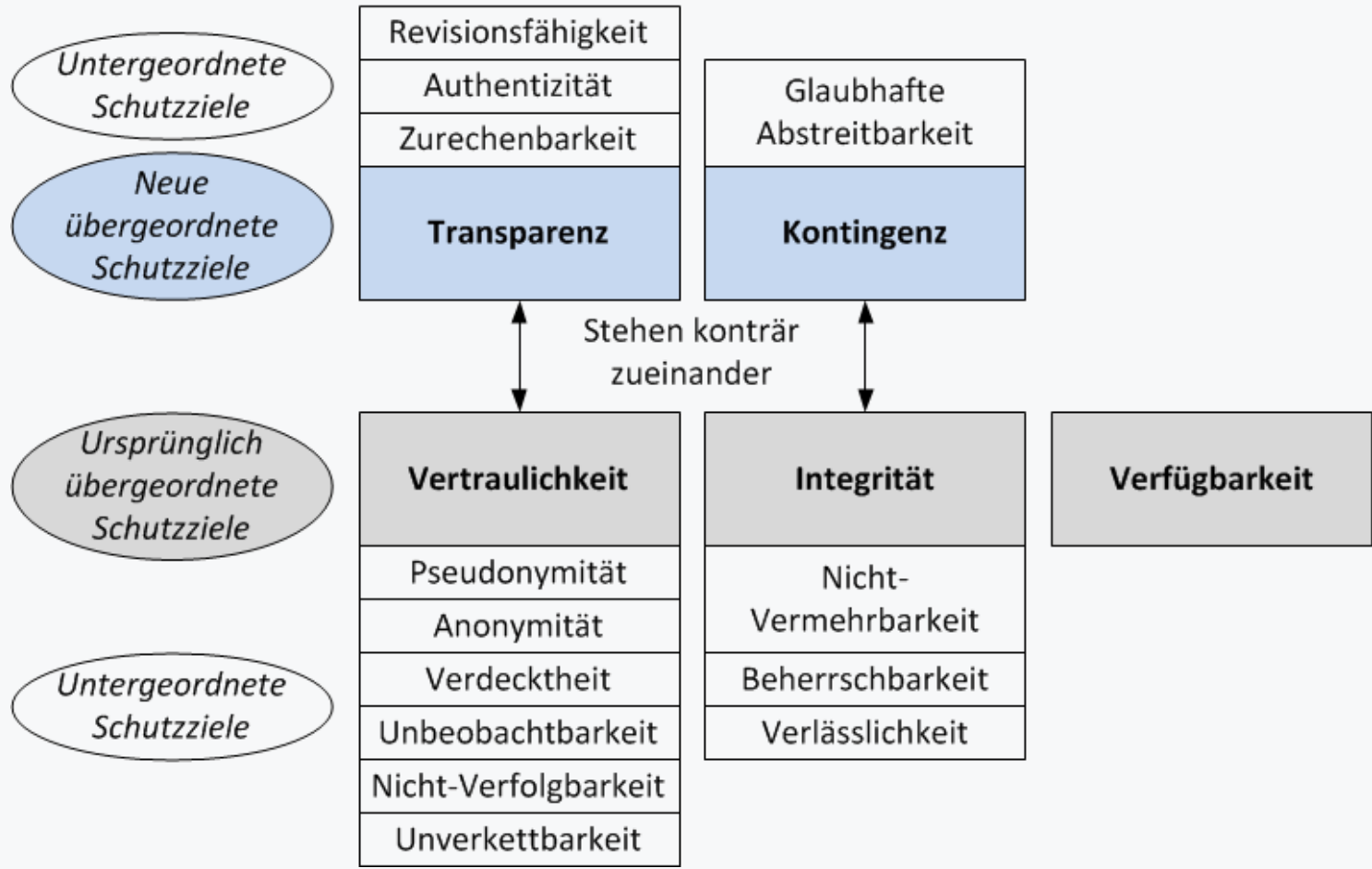
### Aufgaben

- Überwachungspflicht
- ordnungsgemäße Anwendung der DV-Programme
- Vorabinformation des DSB über Vorhaben der automatisierten Verarbeitung
- Einbindung in:
  - Unternehmensprozesse
  - Beschaffungsentscheidungen
  - Auftragsprozesse
- Schulung der Mitarbeiter
  - Grundschulung bei Aufnahme der Tätigkeit
  - Laufende Auffrischungen

# 3.3

## Schutzziele der IT-Sicherheit

# Schutzziele IT-Sicherheit



Quelle: vgl. Bedner und Ackermann (2010), S. 323

# Vertraulichkeit (1/2)

## Ziel

- Verhindern, dass vertrauliche/geheime Information für unberechtigte Dritte zugänglich wird;
- Die Vertraulichkeit eines IT-Systems ist gegeben, wenn keine unerlaubte Informationsgewinnung stattfinden kann.

## Gesetzliche Regelungen

- Brief- sowie das Post- und Fernmeldegeheimnis [Art. 10 GG]
- Fernmeldegeheimnis [§ 88 TKG und § 206 StGB]
- Grundsätze für die Verarbeitung personenbezogener Daten [Art. 5, Abs. 1 lit. f DSGVO]
- Sicherheit der Verarbeitung [Art. 32 Abs. 1 lit. b DSGVO]
- Verpflichtung der Mitarbeiter auf die Vertraulichkeit
- TOMs als Anlage zu Art. 28 DSGVO
- Privat- oder Betriebsgeheimnisse [§ 203 StGB und § 17 UWG]
- EG 39, 49, 75, 83, 85 DSGVO

## Vertraulichkeit (2/2)

### Umsetzung

- Zugriffsschutz
- Symmetrische und asymmetrische Verschlüsselung

### Grundlagen

- Festlegung von Kontrollen und Berechtigungen, die unterbinden, dass Subjekte unautorisiert Kenntnisse von Informationen erlangen
- Festlegung zulässiger Informationsflüsse
- Abwehr unzulässiger Informationsflüsse

# Pseudonymität (1/2)

## Ziel

- Schutz vor namentlicher Identifizierung
- Ähnlich Anonymität mit dem Unterschied, dass der Bezug zu einer Person nicht gänzlich aufgehoben ist und somit der Personenkreis, der die Zuordnungsregel kennt, die Möglichkeit hat die Personen zur Verantwortung zu ziehen.
- Kompromiss aus Vertraulichkeit und Transparenz [Bedner et al., 2010, S. 325]

## Gesetzliche Regelungen

„... dass die personenbezogenen Daten ohne Hinzuziehung zusätzlicher Informationen nicht mehr einer spezifischen betroffenen Person zugeordnet werden können, sofern diese zusätzlichen Informationen gesondert aufbewahrt werden und technischen und organisatorischen Maßnahmen unterliegen, die gewährleisten, dass die personenbezogenen Daten nicht einer identifizierten oder identifizierbaren natürlichen Person zugewiesen werden;“  
[Art. 4 Abs. 5 DSGVO]

Siehe auch EG 28 und Art. 4 Abs. 5 EU DSGVO sowie EG 26, 28, 29, 156



## Pseudonymität (2/2)

### Umsetzung

- PbD werden mit Hilfe einer Zuordnungsvorschrift derart verändert, sodass eine Zuordnung der Daten ohne Kenntnis der Zuordnungsvorschrift zu einem Individuum nicht erfolgen kann.
- Der Besitzer der Übersetzungstabelle bleibt jederzeit in der Lage, den Bezug zwischen einem Datensatz und der betroffenen Person wiederherzustellen.

### Achtung!

Datenbestände mit Pseudonymen unterliegen generell dem Datenschutz [vgl. auch Hammer et al., 2015]

## Anonymität (1/2)

PbD werden derart verändert, sodass eine Zuordnung der Daten zu einem Individuum gar nicht oder nur mit unverhältnismäßig großem Aufwand an Kosten und Zeit erfolgen kann.

### Ziel

- Schutz von Identifizierung [Biskup, 2009, S. 44]
- ... ist eine Folge der Unverkettbarkeit, das bedeutet die Daten der Informationen können der Person nicht zugeordnet werden.
- Siehe auch Art. 6 Abs. 4 lit. e DSGVO, EG 26 DSGVO

# Anonymität (2/2)

## Umsetzung

- Kappung der Zuordnung von Daten zu bestimmten Personen
- Identifizierung erheblich erschweren oder gänzlich unmöglich machen
- Verschlüsselung ...

## Anonymisierungskonzept [Art29G, 2014]

- Können die Datensätze im Ergebnisbestand auf eine konkrete Gruppe von Betroffenen bezogen werden?
- Können identifizierende Merkmale im Ergebnisbestand ausgeschlossen werden? Werden auch aussagekräftige Äquivalenzklassen vermieden?
- Ist die Gruppe der Neugierigen begrenzt? Kann angenommen werden, dass sie geringere Mittel einsetzen können, als wenn die Daten veröffentlicht würden?
- Welches Kontextwissen und welche Referenzwerte können für einen Neugierigen verfügbar sein?
- Kann der Neugierige Zuordnungsregeln zwischen scheinbar unabhängigen Datenbeständen erschließen und daraus Informationen gewinnen?

# Verdecktheit und Unbeobachtbarkeit

## Ziel

- Es lässt sich nicht erkennen, wer Daten sendet oder empfängt.  
[Biskup, 2009, S. 43]
- Niemand außer den Kommunikationspartnern weiß, dass Kommunikation stattfindet.

## Umsetzung

- Schutz von Kommunikationssystemen, auch der Räumlichkeiten vor optischen, akustischen, oder auch elektromagnetischer Aufklärung
- „Mix“-Server, siehe Unverkettbarkeit
- Steganographie  
Verstecken von Informationen in Bild- oder Musikdateien
- „Hidden Volumes“  
z.B. VeraCrypt, TrueCrypt  
Siehe auch „Glaubhafte Abstreitbarkeit“

## Unverkettbarkeit und Nicht-Verfolgbarkeit (1/2)

Unverkettbarkeit von Subjekten, Objekten oder Aktionen bedeutet, dass durch Beobachtungen des Szenarios die Wahrscheinlichkeit einer Relation zwischen enthaltenen Elementen unverändert bleibt. [vgl. Bedner et al., 2010]

### Ziel

- ... soll gewährleisten, dass mehrere kommunikative Ereignisse, etwa aufeinander folgende Abrufe von Informationen auf verschiedenen Webservern im Internet, nicht miteinander in Verbindung gebracht werden können.
- Nicht-Verfolgbarkeit erweitert die Unverkettbarkeit, indem es zusätzlich die Informationsinhalte keiner eindeutig identifizierbaren Person zulässt. [Bedner et al., 2010]

### Gesetzliche Regelungen

- Zweckbindung nach Art. 5 Abs. 1 DSGVO
- Pflicht zur Führung eines Verzeichnisses von Verarbeitungstätigkeiten [Art. 30 DSGVO]

# Unverkettbarkeit und Nicht-Verfolgbarkeit (2/2)

## Umsetzung

Verschiedene Pseudonyme bei verschiedenen Diensten [Biskup, 2009]

- Kopplung eines Bezahldienstes mit Dienstleistungen, ohne dass der Anbieter erfährt, wer sein Käufer ist.

### „Mix“-Server

- Zuordnung eines Datenpakets zu einem Nutzer verschleiern, indem Nachrichten nicht direkt vom Sender zum Empfänger, sondern über mehrere Zwischenstationen übertragen und untereinander verwürfelt werden.
- Dadurch auch Umsetzung der „Unbeobachtbarkeit“
- Siehe auch [Chaum, 1981]

# Transparenz

... strebt im Kontext der Datenschutzziele Klarheit, Erkennbarkeit und Nachvollziehbarkeit an [vgl. Rost/Pfitzmann, 2009]

## Ziel / Umsetzung

- Dokumentation der Verarbeitungstätigkeiten [Art. 30 DSGVO] (Schutzziel)
- Auskunftsrechte der betroffenen Person [Art. 15 DSGVO] (Gewährleistungsziel)

## Gesetzliche Regelungen

- Grundsätze für die Verarbeitung personenbezogener Daten [Art. 5 Abs. 1 lit. a]
- Informationspflicht und Recht auf Auskunft zu personenbezogenen Daten [Art. 13 – 15 DSGVO]
- Datenverarbeitung im Beschäftigungskontext [Art. 88 Abs. 2 DSGVO]
- EG 39, 58, 78 DSGVO



# Authentizität

... ist die anhand von eindeutigen Charakteristika nachweisbare Echtheit und Glaubwürdigkeit von Objekten und Subjekten.

Nachweisliche Garantie von Integrität und Herkunft von Information

## Umsetzung

Charakteristika:

- Something you know (Passwort)
- Something you have (Token)
- Something you are (biometrisches Merkmal)
- Authentifizierung mit Nutzernamen und Passwort vs. Privacy-freundliche Authentifizierung

Maßnahmen zur Authentifizierung (Identifizierung und Authentisierung)

- Individuelle Benutzerpasswörter
- Biometrische Merkmale
- 2-Faktor-Authentifizierung
- Digitale Signaturen

# Exkurs: Sichere Authentifikation

Grundsätzlich sind drei Arten der Authentifikation möglich:

## Something you know

- Passwort
- Passphrase
- Sicherheitsfrage

## Something you have

- Token
- Softtoken
- Smartcard

## Something you are

- Irisscan
- Handvenenscan
- Fingerabdruck

**Höhere Sicherheitsanforderungen können durch die Kombination aus mehreren Merkmalen erfüllt werden (2FA/ MFA)**

## Exkurs: Sichere Authentifikation

**Authentifikation ist wie fast jede Sicherheitsmaßnahme erklärungsbedürftig, damit das dadurch verfolgte Ziel erreicht werden kann.**



Was könnte mit dieser Smartcard passiert sein und warum ist das „mehr als ungünstig“ für die sichere Authentifikation?

## Exkurs: Sichere Authentifikation

... der CIO desselben Unternehmens hatte das „Problem“ der Mitarbeiterin übrigens ebenfalls erkannt und kreativ „gelöst“:



# Transparenz: Untergeordnete Schutzziele ...

## Zurechenbarkeit

Zuordnung von Aktionen oder Dokumenten zu Urhebern

Protokollierung, welche Benutzer welche Systemressourcen in Anspruch genommen haben

Umsetzung:

- Zugriffskontrolle und Nicht-Abstreitbarkeit
- Protokollierung, Nutzung digitaler Signaturen und Zeitstempel

## Revisionsfähigkeit

Nachvollziehbarkeit und Nachprüfbarkeit, wer, wann, welche Daten in welcher Weise verarbeitet hat [Pohl, 2004]

Umsetzung

- Protokollierung und Dokumentation von Prozessschritten

# Integrität (1/2)

## Ziel

- Es soll gewährleistet werden, dass Subjekten keine unautorisierten und unbemerkten Manipulationen an Datenobjekten ermöglicht wird
- Korrektheit der Daten, als auch die adäquate Funktionsweise des Systems (Systemintegrität)
- Garantie, dass Daten in unveränderter Form (im „Originalzustand“) vorliegen

## Gesetzliche Regelungen

- Grundsätze für die Verarbeitung personenbezogener Daten [Art. 5, Abs. 1 lit. f DSGVO]
- Sicherheit der Verarbeitung [Art. 32 Abs. 1 lit. b DSGVO]
- Unveränderbarkeit [§ 146 Absatz 4 AO, § 239 Absatz 3 HGB]

# Integrität (2/2)

## Umsetzung

- Hash-Funktionen (bei jeder Veränderung der Daten verändert sich auch der Hash-Wert („Elektronischer Fingerabdruck“))
- Message Authentication Codes (MAC)
- Digitale Signaturen

## Grundlagen

- Festlegung von Rechten zur Nutzung von Daten
- Verfahren und Techniken zur Manipulationserkennung

# Integrität: Untergeordnete Schutzziele ...

## Verlässlichkeit

- Eigenschaft eines stabilen Systems, welches keine unzulässigen oder undefinierten Zustände annimmt
- Gewährleistung zuverlässiger Funktionen

## Beherrschbarkeit

- Sorgt für die Sicherheit des Betroffenen
- der Einzelne sowie die Gesellschaft wird von unerwünschten Auswirkungen durch die Systemnutzung verschont

## Nicht-Vermehrbarkeit

Informationen dürfen von Unberechtigten nicht kopiert oder in anderer Form vermehrt werden



# Kontingenz und glaubhafte Abstreitbarkeit

## Ziel

- Kontingenz erlaubt die Feststellung, dass „etwas anders sein könnte, als es scheint“.
- Interventionsmöglichkeiten beim Einsatz technischer Mittel

## Umsetzung

- zielt auf den bewussten Verzicht technischer Integritäts- und Sicherheitsmaßnahmen ab [Rost/Pfitzmann, 2009]
- Steganographie
- VeraCrypt

## Weitere Schutzziele

### Nicht-Abstreitbarkeit

Gewährleistung, dass weder Absender noch Empfänger das Versenden (den Empfang) einer Meldung abstreiten kann

### Verbindlichkeit

- Es ist keinem Subjekt möglich, eine Aktion zu einem späteren Zeitpunkt abzustreiten
- Die Verbindlichkeit oder Nicht-Abstreitbarkeit ist die Grundlage für rechtsverbindliche Transaktionen

### Umsetzung

- Kombinierte Verfahren auf Basis von Authentifikation, Integrität und Bestätigungen
- erfolgt i.d.R. durch elektronische Signaturen
- Herausforderung: Anonyme Transaktionen, die rechtsverbindlich ablaufen (analog zur Bezahlung einer Ware durch Bargeld)

# Prinzipien für die Gewährleistung der Integrität und Vertraulichkeit

## Need-to-Know-Prinzip

Jeder Anwender soll nur so viele Berechtigungen haben, wie er für die Erfüllung seiner Aufgaben unbedingt benötigt.

## Separation-of-Duties-Prinzip

Jeder Geschäftsprozess soll von mehr als einem Anwender bearbeitet werden, so dass Manipulationen bemerkt werden können.

## Rotation-of-Duties-Prinzip

Aufgabenbereiche zwischen den Anwendern regelmäßig tauschen, so dass ein ausgefallener Anwender durch Kollegen vertreten werden kann und dass Manipulationen durch diese Kollegen bemerkt werden können.

# Verfügbarkeit

## Ziel

Gewährleistung, dass Dienste den berechtigten Benutzern stets zur Verfügung stehen

## Attacken:

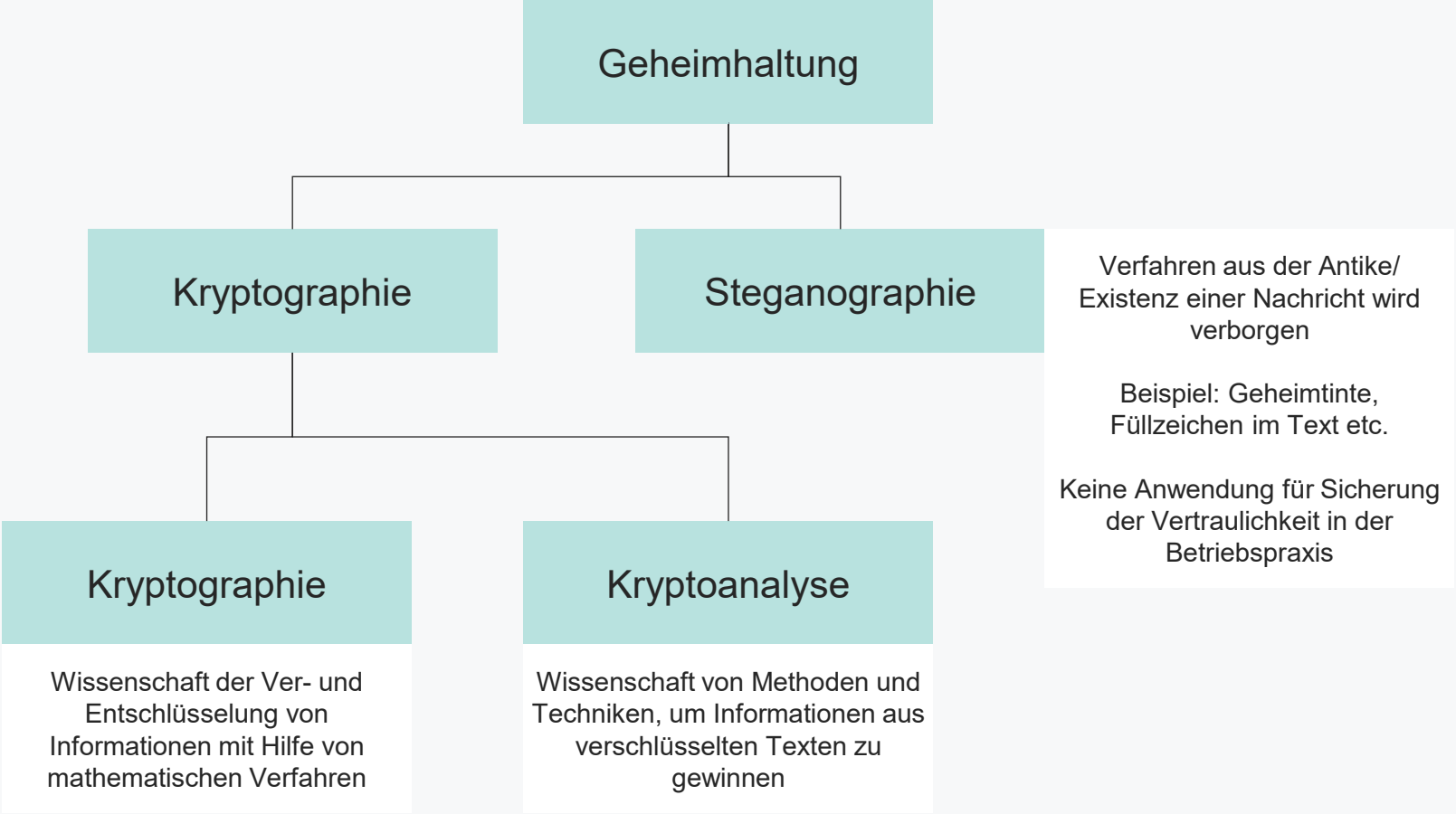
- Denial-of-Service-Attacke (DoS)/Distributed-Denial-of-Service-Attacke (DDoS): Ein Server wird mit „sinnlosen“ Anfragen überflutet, sodass er seiner ursprünglichen Aufgabe nicht (oder nicht im vollen Umfang) nachkommen kann.
- Ransomware/Verschlüsselungstrojaner

## Maßnahmen:

- Erkennen von atypischen Nutzungsmustern
- Beschränkung der Ressourcenzuweisungen an einzelne Benutzer
- Backup

# 3.4

## Kryptographie



# Kryptographie

## Ziele

Verschlüsselung um Vertraulichkeit zu ermöglichen

Integritätsmaßnahmen um Veränderungen zu erkennen

## Kryptographie im weiteren Sinne

Vertraulichkeit (Zugriffsschutz)

Integrität (Änderungsschutz)

Authentizität (Fälschungsschutz)

Zurechenbarkeit (Nichtabstreitbarkeit)

## Kryptographie im engeren Sinne

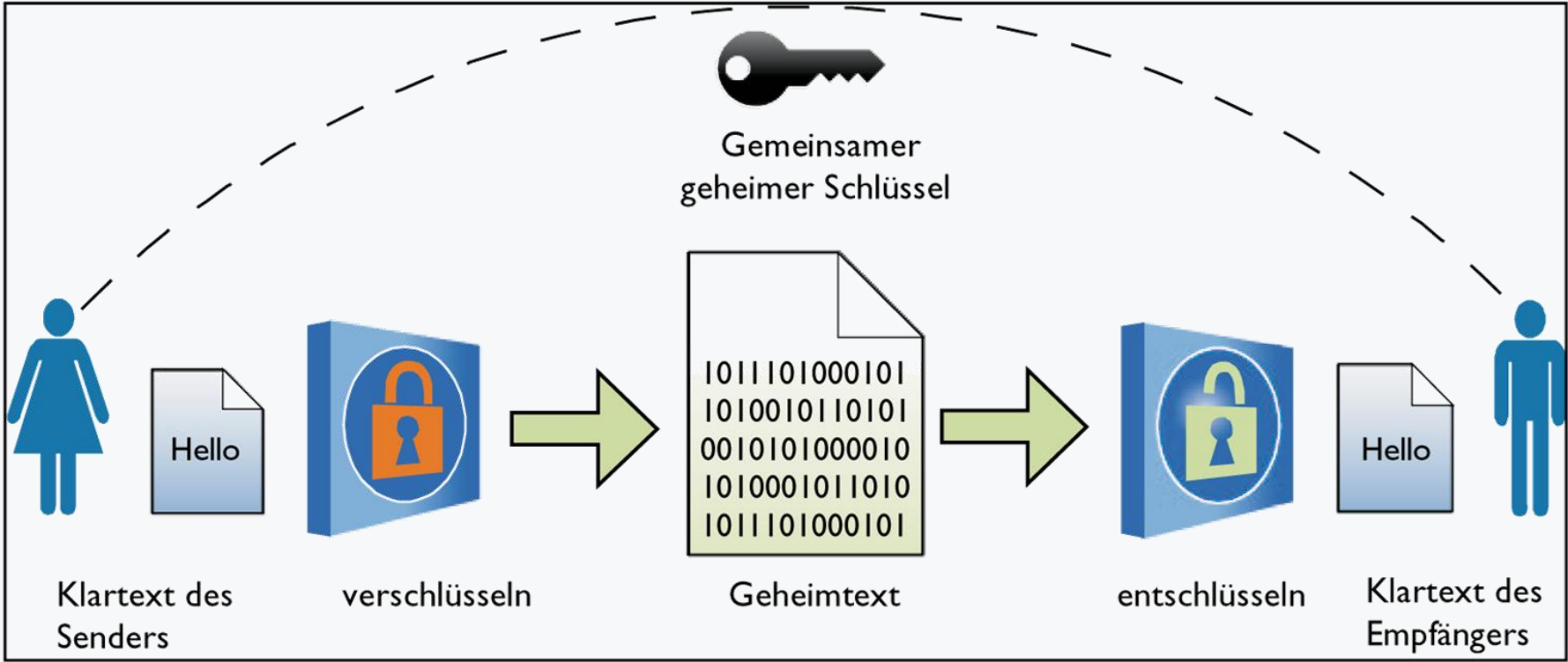
Geheimhaltung

Nicht (!): Organisatorische Sicherheit

Nicht (!): Physische Sicherheit

Sondern: Kommunikation unter Verwendung geheimer Zusatzinformationen

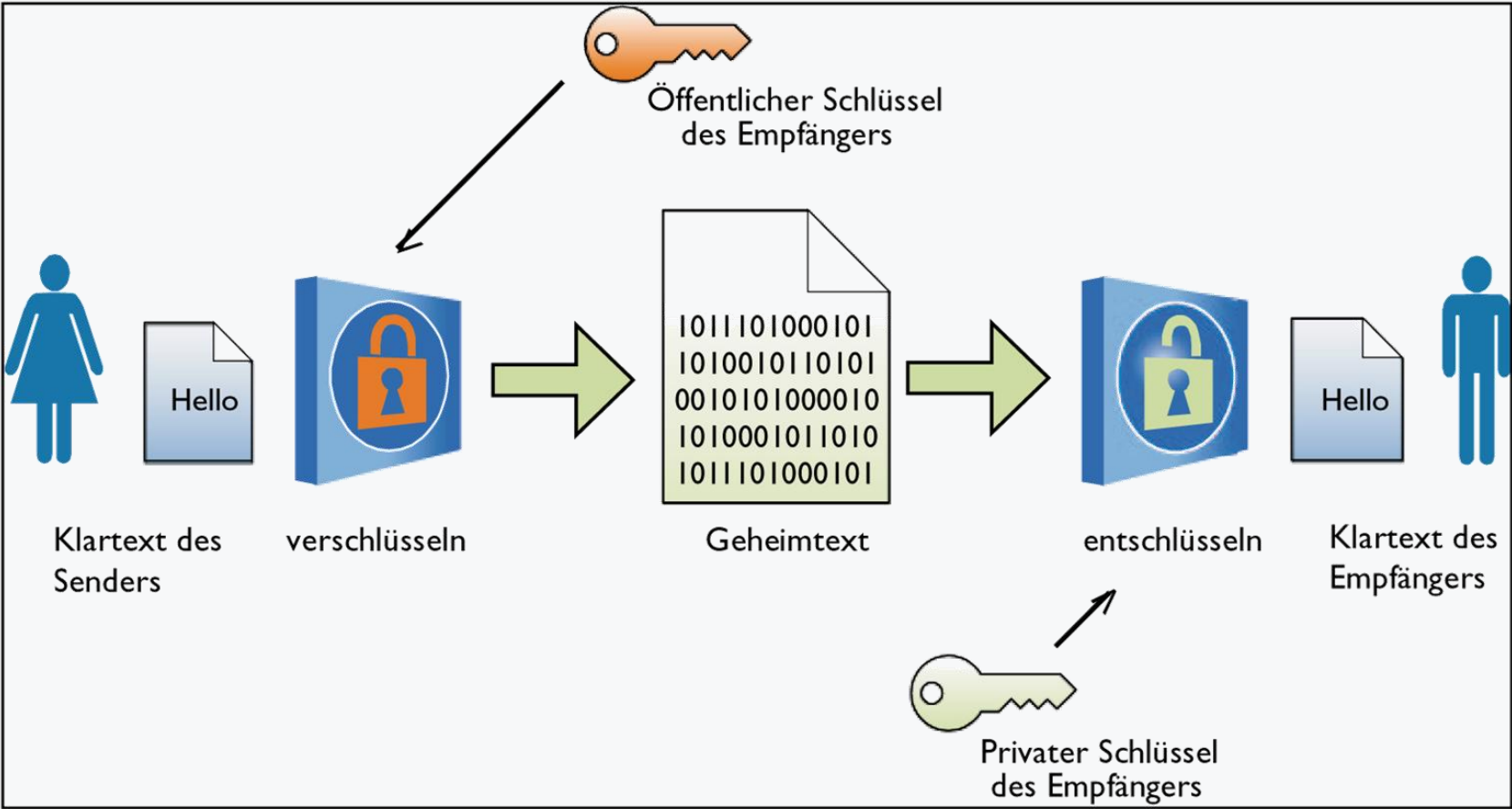
# Kryptographie: Secret Key Verschlüsselung



Quelle: Laudon, 2006, S. 670



# Kryptographie: Public Key Verschlüsselung



Quelle: Laudon, 2006, S. 671

# Kryptographie: Hash / Einwegfunktionen

## Hashing

Ermittlung einer repräsentativen, irreversiblen Prüfsumme (Digest)

$$y = f(x)$$

- $f$  - gegebene Funktion,  $x$  - gegebener Parameter (z.B. Text)
- bei bekanntem  $f(x)$  praktisch unmöglich,  $x$  zu bestimmen

## Verfahren

SHA: Secure Hash Algorithm (256 Bit, 512 Bit)

PBKDF2, RIPEMD160, ...

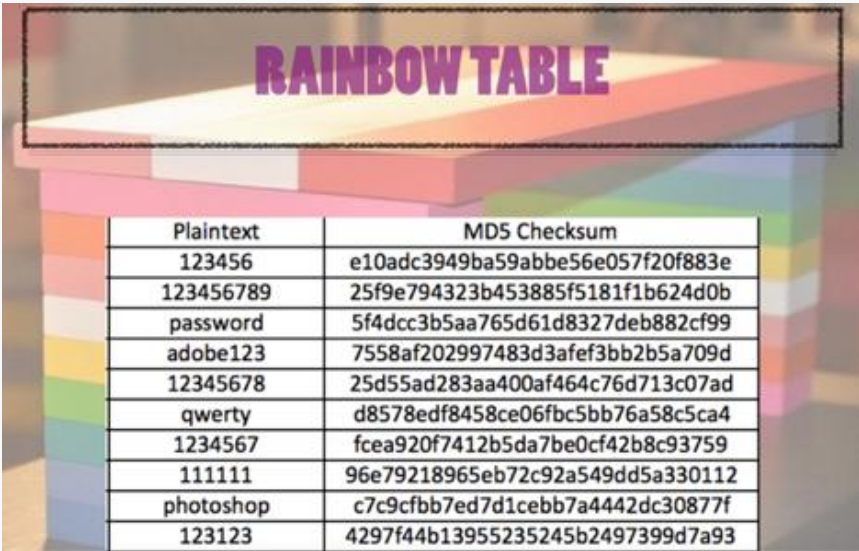
## Verwendung bei:

- Digitalen Signaturen
- Speicherung von Kennwörtern
- Prüfsummen bei/für Downloads
- Integritätsprüfungen (z.B. bei Betriebssystemen)

# Exkurs: Passwortspeicherung mittels Hashing

## Hashing von Passwörtern mit Salt

- Verschlüsselte Speicherung bei Passwörtern nicht ideal
- Speicherung als Hash (nicht zurückrechenbar)
- Für einfache Passwörter bestehen Rainbow-Tables
- Salt (Zufallswert) wird angehängt und mit Passwort gespeichert
- Rainbow-Tables funktionieren nicht mehr
- Achtung: Unsichere Passwörter wie 123456 bleiben auch mit Salt unsicher!

A graphic of a multi-colored, 3D block structure resembling a staircase or a rainbow, with the text "RAINBOW TABLE" in bold purple letters at the top. Below the graphic is a table showing a mapping of plaintext passwords to their MD5 checksums.

| Plaintext | MD5 Checksum                     |
|-----------|----------------------------------|
| 123456    | e10adc3949ba59abbe56e057f20f883e |
| 123456789 | 25f9e794323b453885f5181f1b624d0b |
| password  | 5f4dcc3b5aa765d61d8327deb882cf99 |
| adobe123  | 7558af202997483d3afef3bb2b5a709d |
| 12345678  | 25d55ad283aa400af464c76d713c07ad |
| qwerty    | d8578edf8458ce06fbc5bb76a58c5ca4 |
| 1234567   | fcea920f7412b5da7be0cf42b8c93759 |
| 111111    | 96e79218965eb72c92a549dd5a330112 |
| photoshop | c7c9cfbb7ed7d1cebb7a4442dc30877f |
| 123123    | 4297f44b13955235245b2497399d7a93 |

- Unsicheres Passwort „123456“ führt zu bekanntem Hash-Wert
- Ergänzt um generierten Salt „1+Yw4[U5“ ergibt sich ein anderer Hashwert
- In der Passwortdatenbank wird gespeichert: [Hashwert]+“1+Yw4[U5“
- Für das Passwort „123456 1+Yw4[U5“ existiert kein Eintrag in einer Rainbow-Table

# Kryptographie: Digitale Signatur

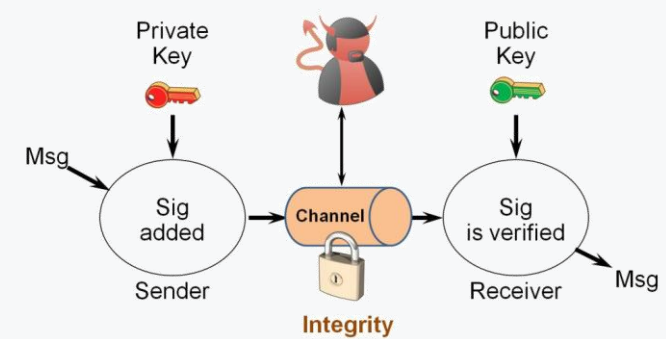
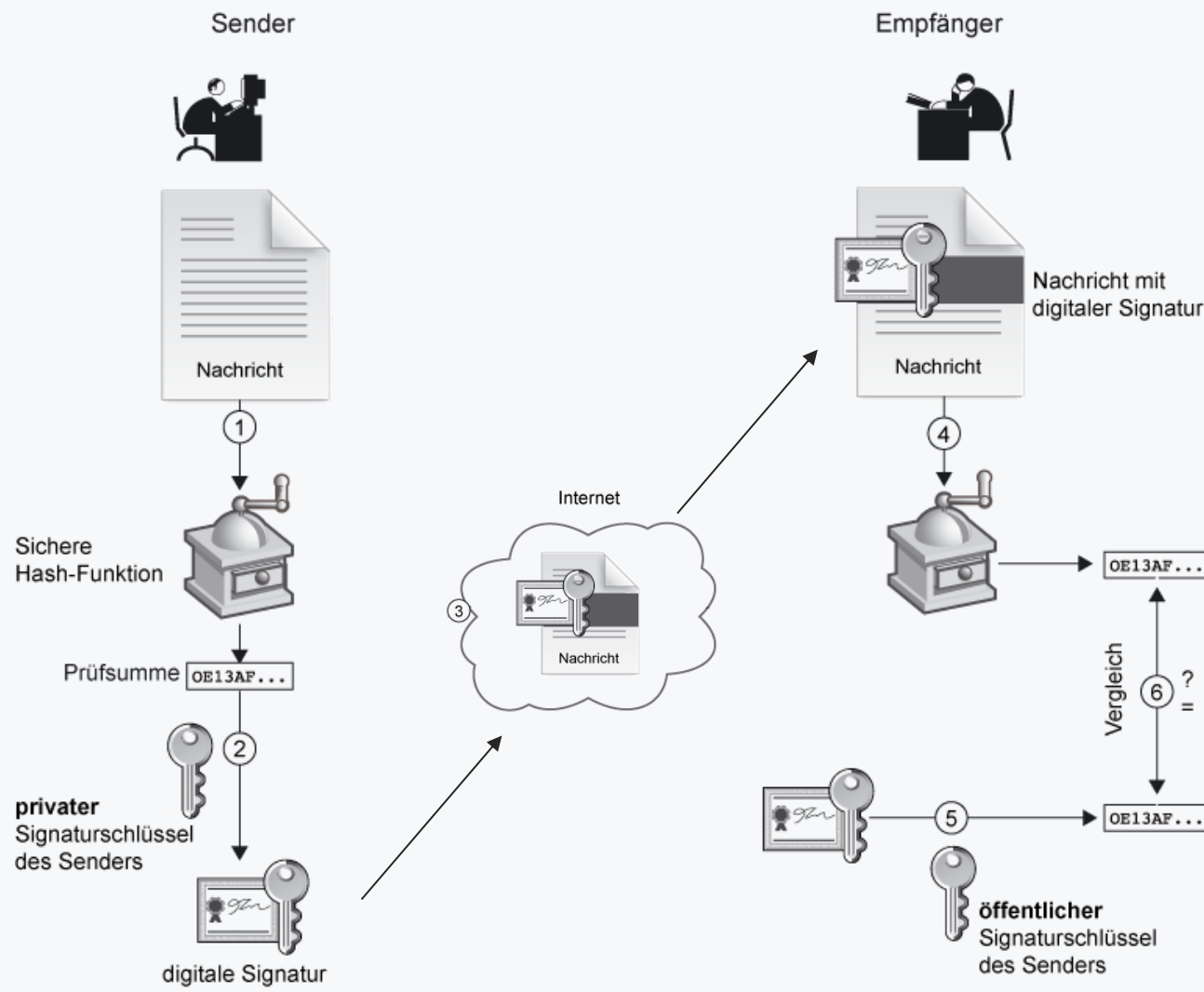
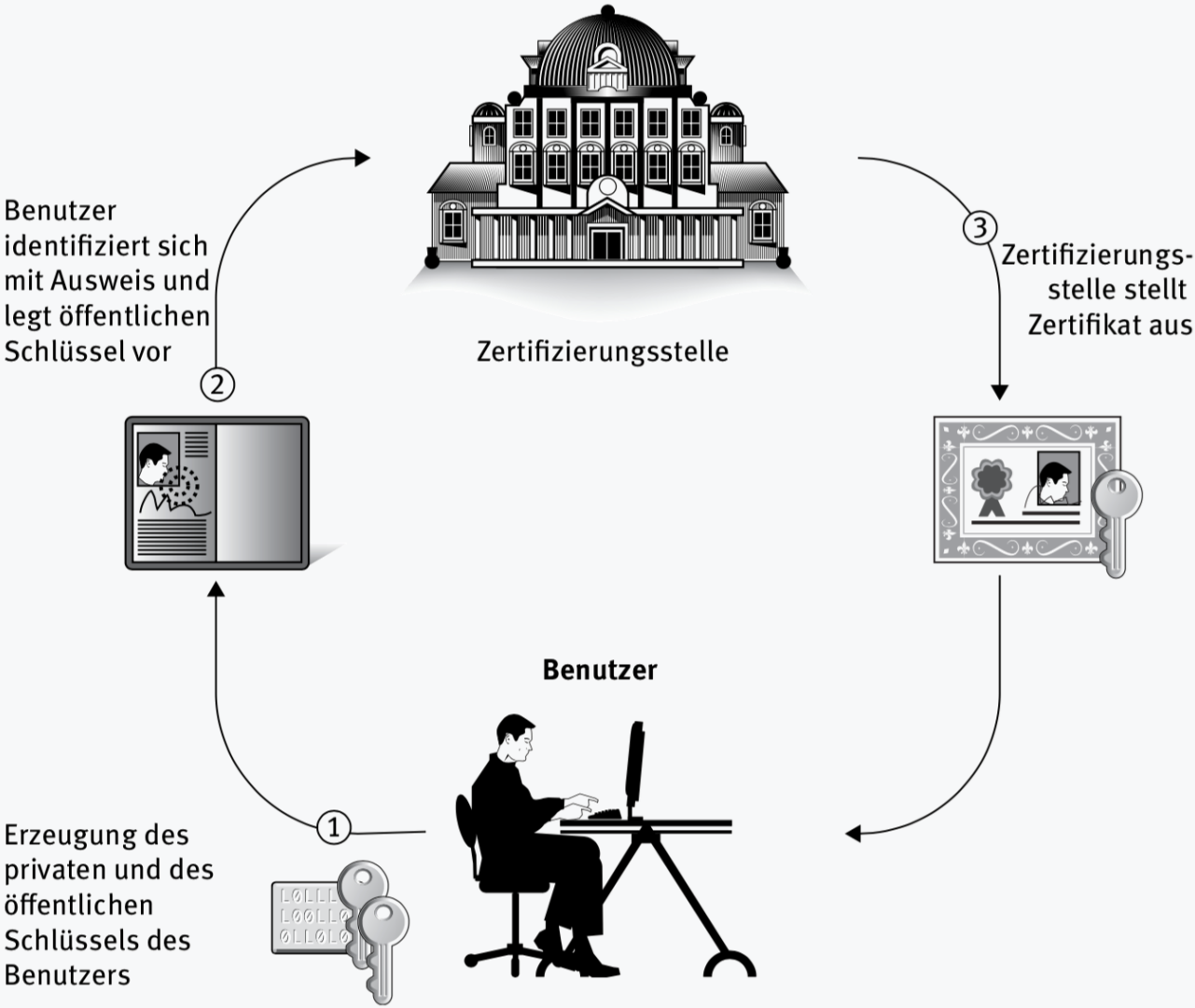


Figure: Integrity with Asymmetric Crypto (Signatures)

# Digitale Zertifikate (1/2)



Quelle: Hansen et al., 2015

## Digitale Zertifikate (2/2)

Die Zuordnung zwischen einem öffentlichen Schlüssel und seinem Inhaber muss fälschungssicher sein; dies wird durch die Verwendung einer digitalen Signatur gewährleistet.

### Zertifikate

Ein Zertifikat ist ein digital unterschriebenes – und damit nicht fälschbares – Dokument, das im wesentlichen zwei Informationen enthält: den öffentlichen Schlüssel und eine Identifizierung des Inhabers (im einfachsten Fall seine E-Mail-Adresse).

Die das Zertifikat ausstellende Zertifizierungsstelle (Certification Authority, CA, auch "Beglaubigungsinstanz") muss natürlich vertrauenswürdig sein; sie beglaubigt mit ihrer digitalen Unterschrift die korrekte Zuordnung zwischen Schlüssel und E-Mail-Adresse (vergleichbar einem Notar, der ein Dokument beglaubigt).

# Hybridverschlüsselung und Digitale Zertifikate

## Hybridverschlüsselung - Kombination aus asymmetrischer und symmetrischer Verschlüsselung

1. Generierung eines zufälligen symmetrischen Sitzungs-Schlüssels (Session Key)
2. Der Session Key wird - geschützt mit dem asymmetrischen Schlüssel - übertragen
3. Die Nachricht wird - geschützt mit dem Session Key - übertragen

### Problem : Man-in-the-middle Angriffe:

Gehört der öffentliche Schlüssel (Public Key) des Empfängers auch wirklich dem Empfänger?

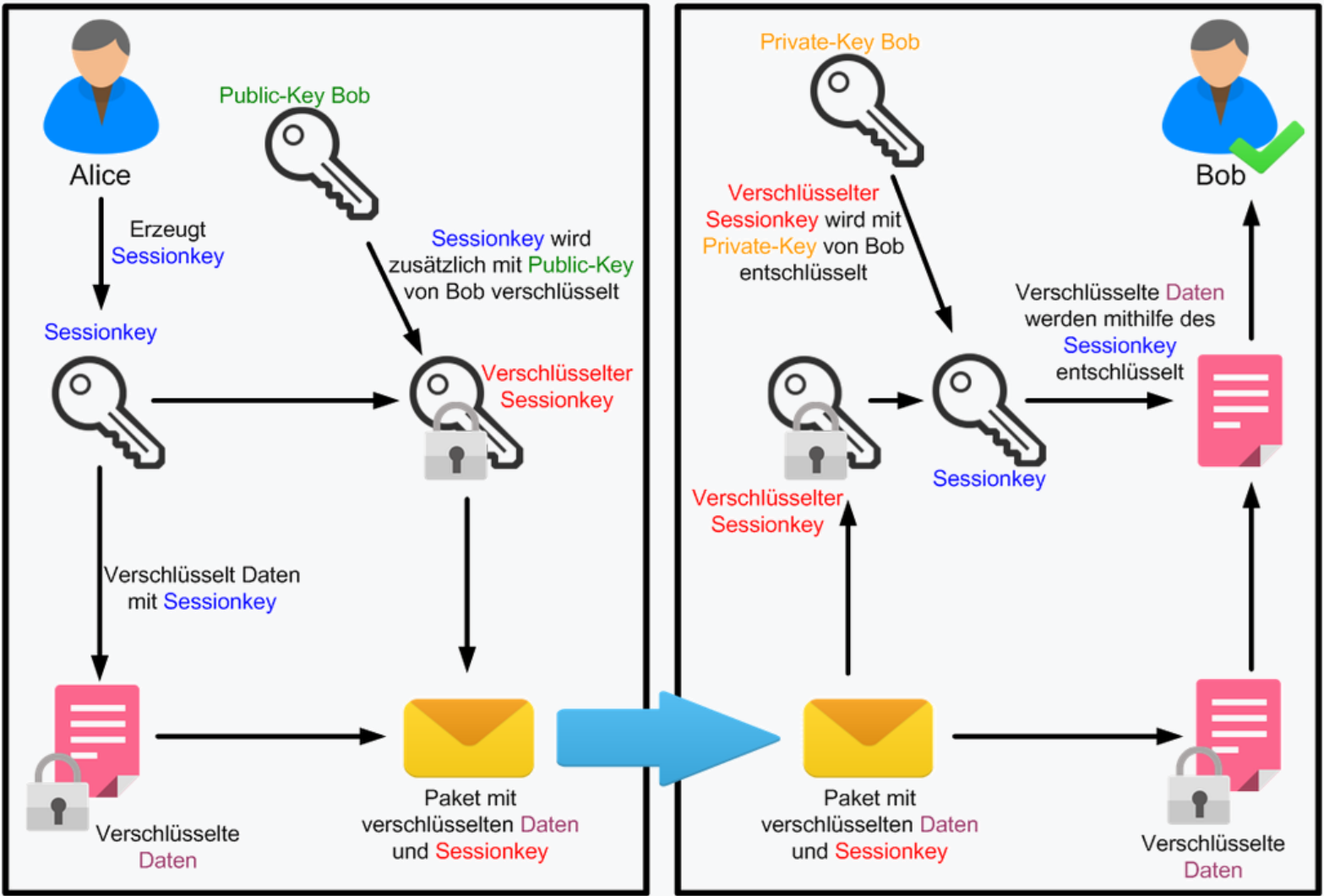
### Lösung: Digitale Zertifikate

Eine zentrale Instanz (z.B. VeriSign, Deutsche Bank PKI), der alle Benutzer trauen, garantiert die Authentizität des Zertifikates und des darin enthaltenen öffentlichen Schlüssels

Hybridverschlüsselung auf Basis von digitalen Zertifikaten ist die Grundlage für sichere elektronische Kommunikation, z.B.:

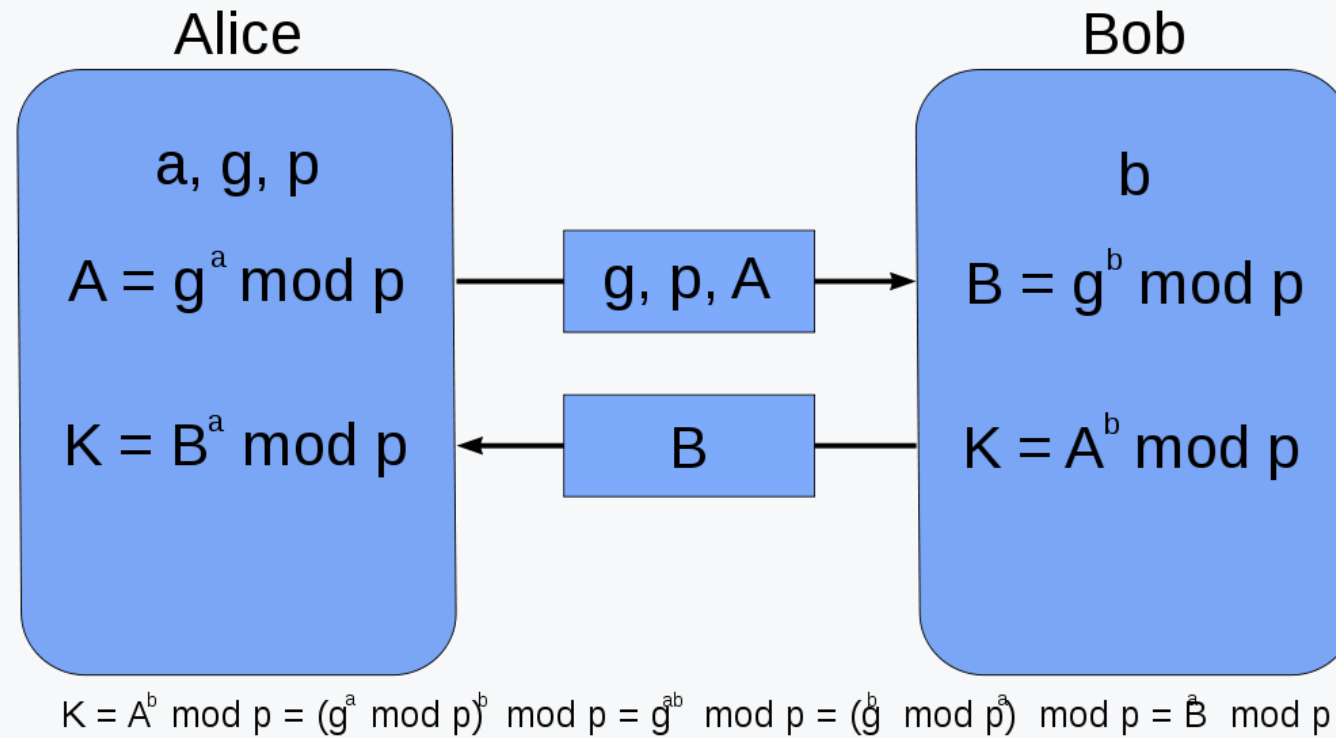
- Internet Shopping und Online Banking
- Sichere eMail

# Hybridverschlüsselung und Digitale Zertifikate (2/2)





# Diffie-Hellmann Schlüsselaustausch



# Diffie-Hellmann Schlüsselaustausch

## 1. Schritt: Bestimmung der öffentlichen Schlüssel

Die Personen wählen zwei öffentliche Zahlen (Public Keys; Primzahl/Primitivwurzel)

Bsp.  $p = 11$  und  $g = 7$ .

## 2. Schritt: Bestimmung der privaten Schlüssel

Person A wählt eine Zahl  $a < p$  (Private Key)

Bsp.  $a = 3$

## 3. Schritt: Bilden der Unterschrift A

Berechnung des Ergebnisses  $A = g^a \bmod p$

$$A = 7^3 \bmod 11 \quad A = 2$$

## 4. Schritt: Datenübermittlung

Das Ergebnis  $A = 2$  wird dem Empfänger (Person B) mitgeteilt.

## 5. Schritt:

Auch die Person B wählt eine Zahl  $b < p$ , berechnet sie und teilt das Ergebnis dem Sender (Person A) mit.

Bsp.:  $b = 6$ ,  $B = 7^6 \bmod 11$ , Ergebnis:  $B = 4$

## 6. Schritt: Prüfen der Unterschriften

Person A berechnet mit der bekannten Formel und dem Ergebnis B den Schlüssel K:  $4^3 \bmod 11 = 9$ .

Die Person B berechnet in diesem Fall: Schlüssel K =  $2^6 \bmod 11 = 9$

Schlüssel kann für die Kommunikation verwendet werden

# Kryptographie: Perfect Forward Secrecy (PFS)

... verhindert, dass eine in der Vergangenheit geführte, bereits abgeschlossene aber verschlüsselt aufgezeichnete Kommunikation durch nachträgliches Bekanntwerden des geheimen Schlüssels kompromittiert wird.

## Diffie-Hellman Schlüsselaustausch

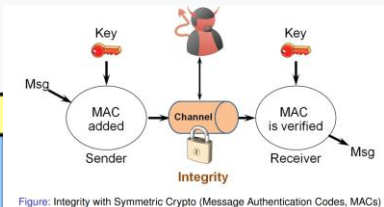
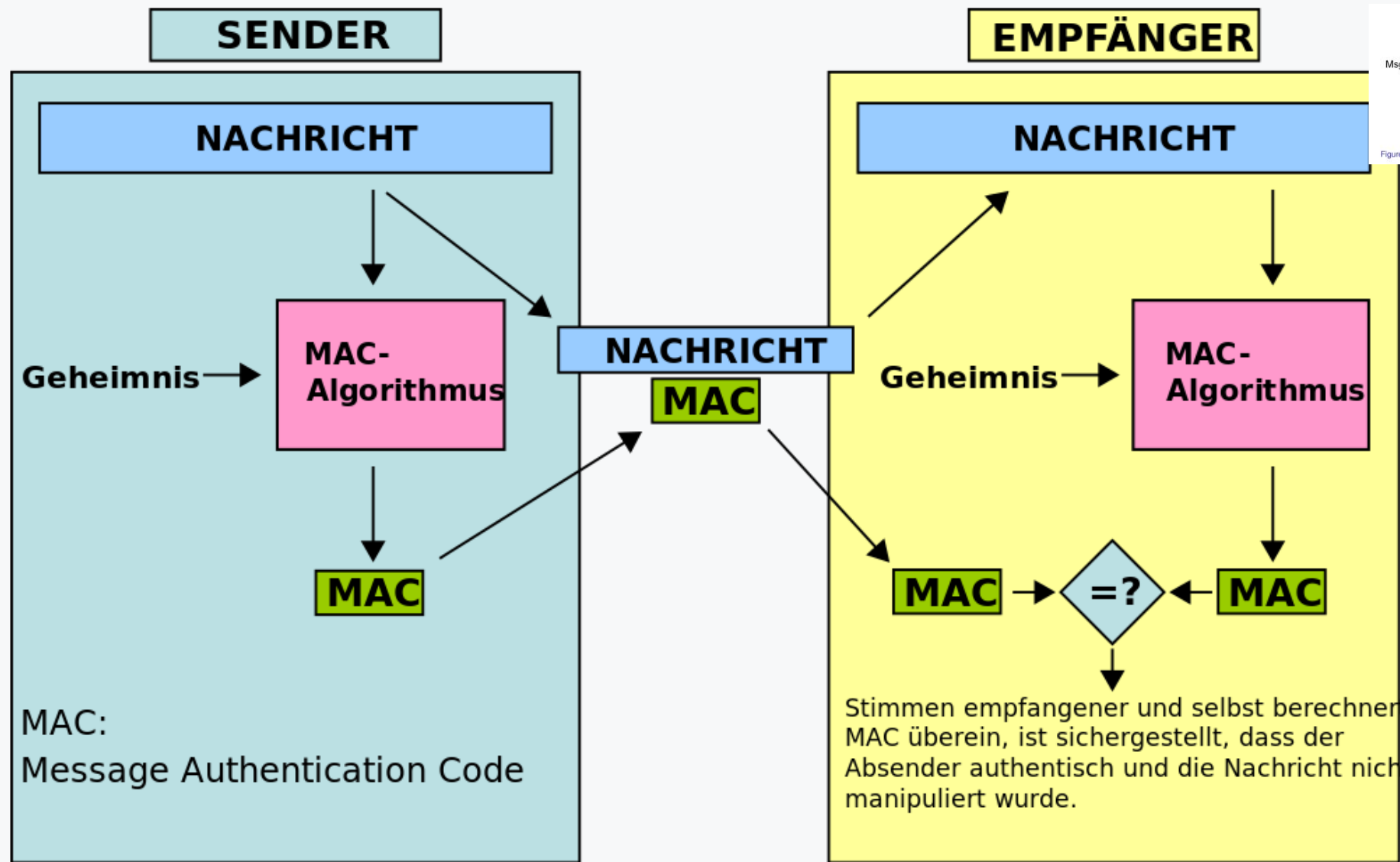
beide Kommunikationspartner einigen sich durch den Austausch mehrerer Nachrichten auf einen gemeinsamen, temporären Sitzungsschlüssel

dieser geht dabei nie "über die Leitung"

Nach dem Ende der Sitzung zerstören die beiden Kommunikationspartner ihre Kopie dieses Schlüssels, der damit nicht mehr existiert.

TLS 1.3 mit Unterstützung von PFS ist ab 08/2018 offizieller Standard für Transportverschlüsselung im Netz.

# MAC (Message Authentication Code)

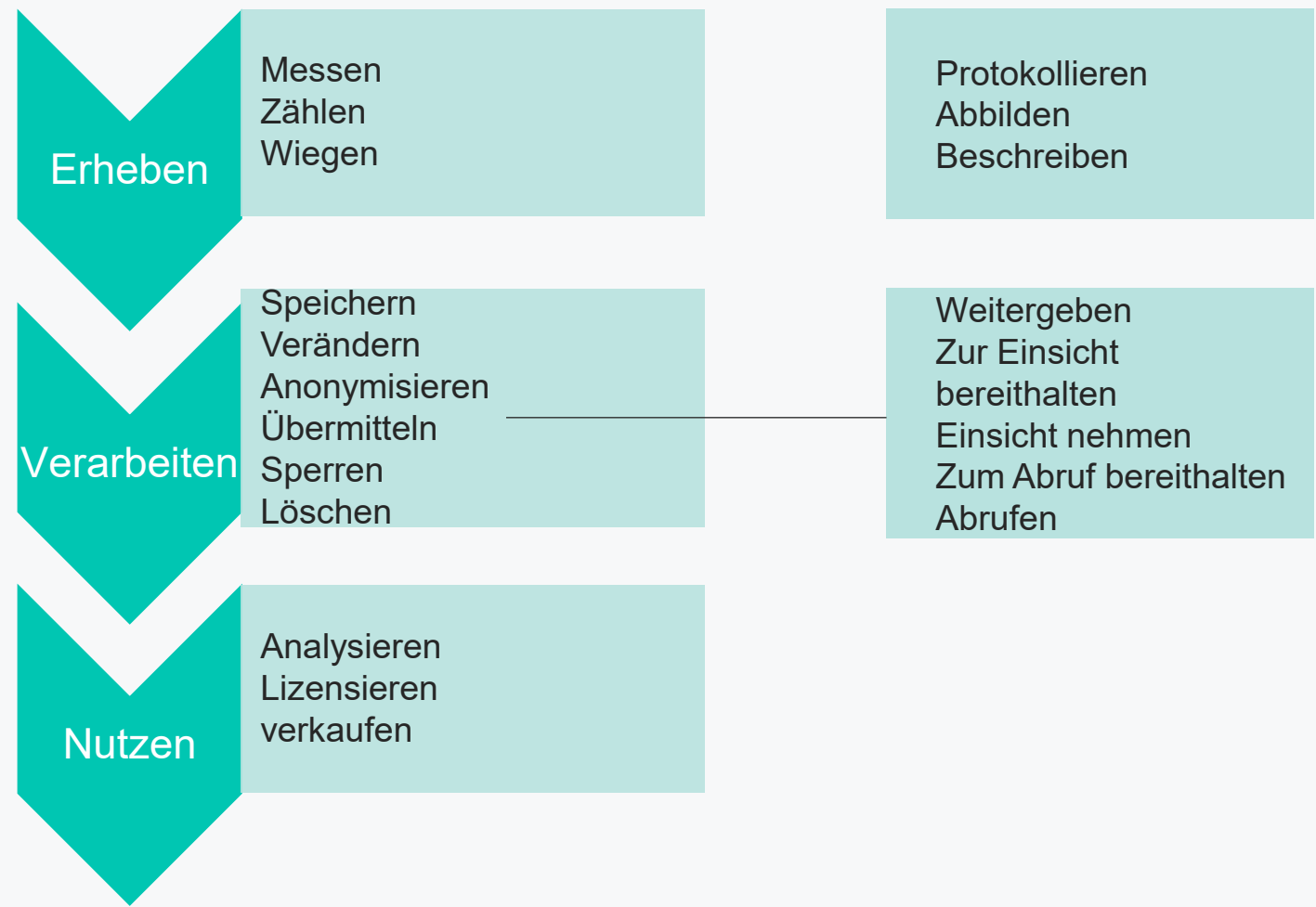


Quelle: Sevenofdoriath basierend auf Diagramm MAC.svg des Users Twisp, CC-by-sa 3.0/de

# 3.5

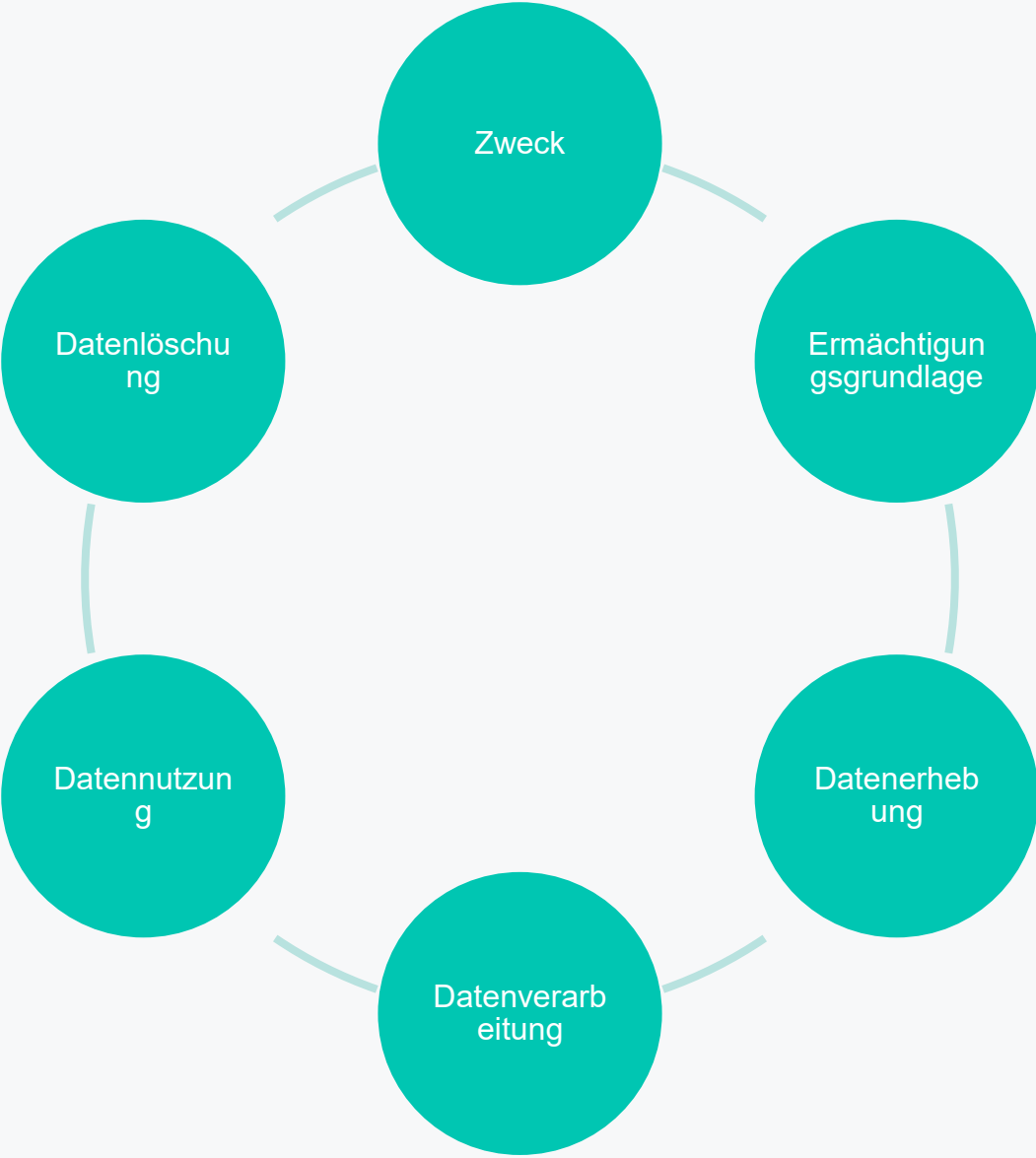
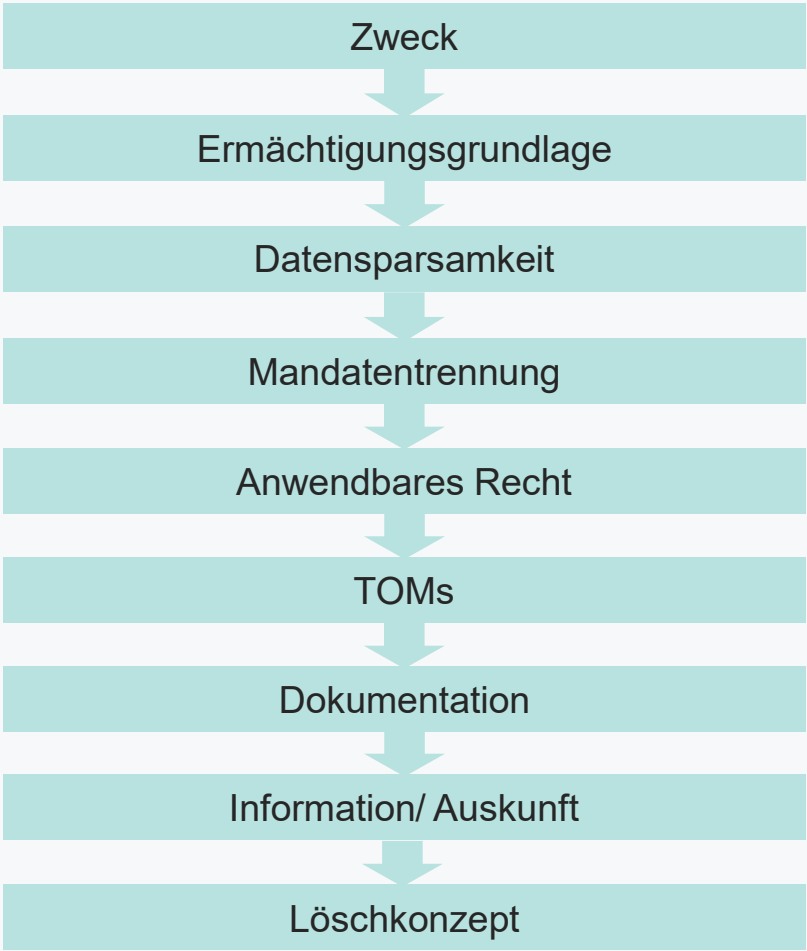
## Datenverarbeitung und TOMs

# Datenumgang/ Datenzweck



Quelle: vgl. Caldarola & Schrey, 2019

# Pflichten der verantwortlichen Stelle nach DSGVO



Quelle: Eigene Darstellung

# Gesetzliche Grundlagen: DSGVO

## Art. 5 Abs. 1

Zweckbindung (abgeschwächt)

Datenvermeidung/-sparsamkeit

Richtigkeitsgewähr

Datensicherheit nunmehr ausdrücklich bei den Grundsätzen genannt!

## Verbot mit Erlaubnisvorbehalt (Art. 6)

## Unterscheidung sensible/nicht sensible Daten (Art. 9, 10)

## Verbot automatisierter Entscheidungen (Art. 22)

## Verschärfte Dokumentationspflichten (Art. 5 Abs. 2)

Der Verantwortliche ist für die Einhaltung des Absatzes 1 verantwortlich und muss dessen Einhaltung nachweisen können ("Rechenschaftspflicht").



# Gesetzliche Grundlagen

## Art. 32 DSGVO

Unter Berücksichtigung

- des Stands der Technik,
- der Implementierungskosten und der Art, des Umfangs, der Umstände und der Zwecke der Verarbeitung
- sowie der unterschiedlichen Eintrittswahrscheinlichkeit und
- Schwere des **Risikos**
- für die Rechte und Freiheiten natürlicher Personen

treffen der Verantwortliche und der Auftragsverarbeiter geeignete

- **technische und**
- **organisatorische Maßnahmen,**

um ein **dem Risiko angemessenes Schutzniveau** zu gewährleisten!

## Beispielmaßnahmen des Gesetzgebers

- die Verschlüsselung pbD,
- die Fähigkeit, die Vertraulichkeit, Integrität, Verfügbarkeit und Belastbarkeit der Systeme und Dienste im Zusammenhang mit der Verarbeitung auf Dauer sicherzustellen,
- die Fähigkeit, die Verfügbarkeit der pbD und den Zugang zu ihnen bei einem physischen oder technischen Zwischenfall rasch wiederherzustellen, sowie
- Ein Verfahren zur regelmäßigen Überprüfung, Bewertung und Evaluierung der Wirksamkeit der TOM's zur Gewährleistung der Sicherheit der Verarbeitung.

# TOM's: Zutrittskontrolle

## Ziel

Kein unbefugter Zutritt zu Datenverarbeitungsanlagen (räumlich)

## Maßnahmen

Zutrittsüberwachungs- und kontrollsystem

- Magnet- oder Chipkarten, Schlüssel, elektrische Türöffner, Werkschutz bzw. Pförtner, Alarmanlagen, Videoanlagen, u.a.
- Register von Schlüsselinhabern
- Vorgaben für externe Personen/Fremdfirmen, Besucherausweise, Anwesenheitslisten
- Einrichtung von Sicherheitszonen mit Zugangsbeschränkungen
- Geschlossener RZ-Betrieb

# TOM's: Zugangskontrolle

## Ziel

Keine unbefugte Systembenutzung

## Maßnahmen

Benutzer-Identifikation und Authentifizierung

- Automatische Sperrmechanismen an Arbeitsplätzen,
- (Sichere) Kennwörter, Zwei-Faktor-Authentifizierung/U2F (Universal Second Factor), FIDO2 (FastIDentificationOnline)
- Funktionsgebundene Zuweisung von individuellen Arbeitsplatzrechnern, differenzierte Zugangsvoraussetzungen
- Kontrolle von Zugangsrechten (Mandatory Access Controls)
- Verpflichtung auf das Datengeheimnis (Art. 5, Abs. 1, lit. f DSGVO)
- Verschlüsselung von Datenträgern und Dateien
- Kontrollierte Vernichtung von Datenträgern
- Richtlinien für die Dateiorganisation
- Arbeitsanweisungen und Verfahren für die Datenerfassung
- Genehmigungs- und Monitoringsysteme

# TOM's: Zugriffskontrolle

## Ziel

Kein unbefugtes Lesen, Kopieren, Verändern oder Entfernen von Daten innerhalb des Systems

## Maßnahmen

Berechtigungskonzepte und bedarfsgerechte Zugriffsrechte

Protokollierung von Zugriffen, Analyse von Zugriffsprotokollen

Arbeitsplätze mit funktionsgebundenen Zugriffsschlüsseln, Karten und Kartenlesern

Regelmäßige Prüfung des Berechtigungskonzeptes und der Berechtigungen

Dokumentierte Prozesse für ausgeschiedene Mitarbeiter

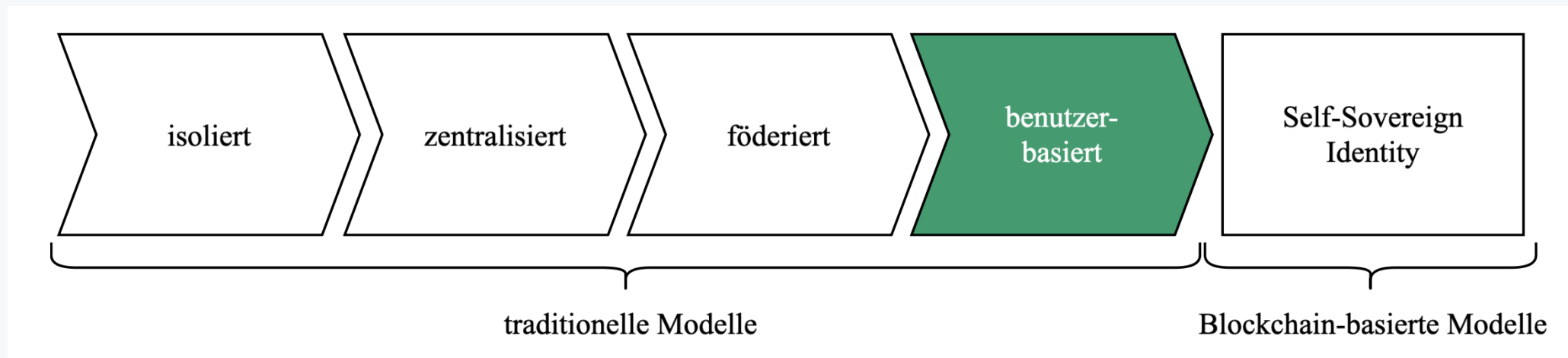
# Identity Management

## Bündelung identitätsbezogener Informationen:

- Integration aus verschiedenen Quellen
- Ermöglicht plattformspezifische Identitäts- und Zugriffsverwaltung

## Zielsetzung:

- Bereitstellung einer einheitlichen Sicht auf Identitäten von Nutzern und Ressourcen
- Unterstützung in heterogenen IT-Umgebungen



# Berechtigungsmanagement nach dem IAM-Modell

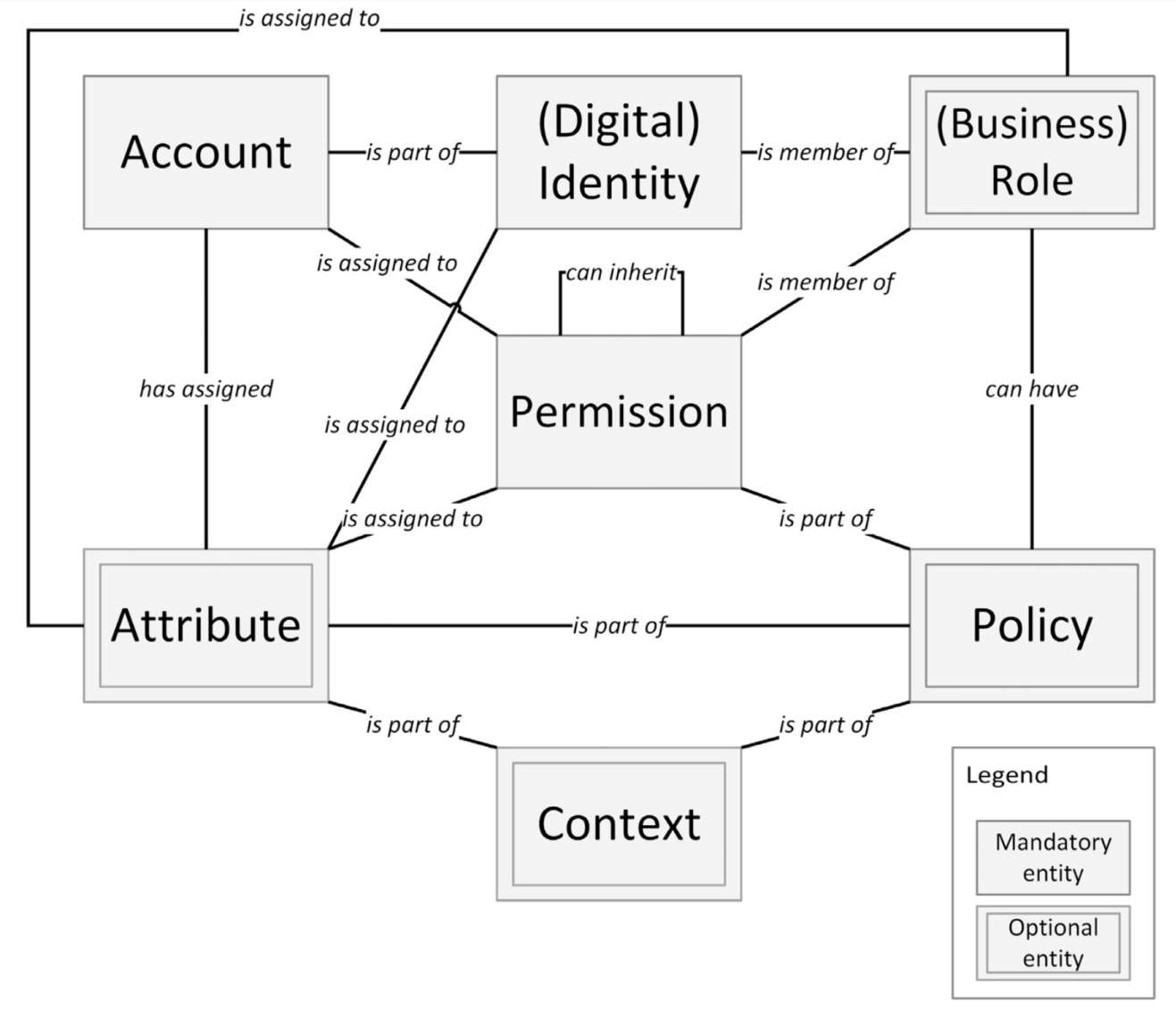
## Entitäten:

- Digitale Identität: Repräsentiert menschliche Nutzer (z.B. Personal)
  - Kann als Multi-Identity-Modell mit Sub-Identitäten auftreten.
- Account: Technische Abbildung der Identitäten in Zielsystemen (z.B. in LDAP-Verzeichnissen)
- Permission: Zugriffrechte innerhalb von Anwendungssystemen
  - Definiert durch Autorisierungsstatement und zugehöriges Objekt.
- Strukturierte Zuordnung:
  - Berechtigungsmanagement als Zuordnung von Accounts zu Permissions
  - Hierarchische Strukturierung von Berechtigungen möglich.

## Ergänzende Entitäten:

- Rollen:
  - Als Geschäftsrollen interpretiert, bündeln Zielsystem-Berechtigungen (RBAC).
- Richtlinien:
  - Bestimmen Zuordnung von Rollen bzw. Berechtigungen zu Identitäten/Accounts.
- Kontext:
  - Relevantes Umfeld, in dem die Richtlinie gilt.
- Attribute:
  - Metadaten über Identitäten, Accounts, Rollen, Richtlinien und Permissions (z.B. Zeitzone, geografischer Ort).

# Konzeptionelles IAM-Modell basierend auf IAM-Standards





# TOM's: Datenträgerkontrolle

## Ziel

Das unbefugte Lesen, Kopieren, Verändern, oder Löschen von Datenträgern ist zu verhindern

## Maßnahmen

Verschlüsseln von Datenträgern

Verschlusenes Aufbewahren von Datenträgern

Protokollierung der Aushändigung bzw. Rückgabe von Datenträgern

# TOM's: Weitergabe-, Übertragungs- und Transportkontrolle

## Ziel

Kein unbefugtes Lesen, Kopieren, Verändern oder Entfernen bei der elektronischen Übertragung oder beim Transport sowie die nachträgliche Überprüfung

## Maßnahmen

Geeignete Berechtigungsnachweise (Need-to-Know-Prinzip)

Gegenseitige Überwachung (Separation of Duties-, Rotation of Duties-Prinzip)

Verschlüsselung, Virtual Private Networks (VPN)

elektronische Signatur

Kontrolle der Anfertigung von Datenkopien

Dokumentation der Datenübermittlungsvorgänge und der involvierten Programme sowie von Übertragungsorten und -routen

Fernwartungskonzept und Protokollierung von Fernwartungsvorgängen

# TOM's: Eingabekontrolle

## Ziel

Feststellung und Nachvollziehbarkeit, ob und von wem personenbezogene Daten in Datenverarbeitungssysteme eingegeben, verändert oder entfernt worden sind

## Maßnahmen

Protokollierung von Zugriffen und Änderungen

Nachweis der Quellen von Daten (Authentizität)

Versionierung

Dokumentation der Verarbeitungsprozesse mittels Protokollen auf der Basis eines Protokollierungs- und Auswertungskonzepts

Verantwortung für Daten und Systeme, Arbeitsanweisungen

# TOM's: Auftragskontrolle

## Ziel

Weisungsgemäße Auftragsverarbeitung im Sinne von Art. 28 DSGVO durch Dritte  
Maßnahmen zur Abgrenzung der Kompetenzen zwischen Auftraggeber und Auftragnehmer

## Maßnahmen

Eindeutige Vertragsgestaltung  
formalisiertes Auftragsmanagement  
strenge Auswahl des Dienstleisters, Vorabüberzeugungspflicht  
Nachkontrollen  
Datenschutz- und IT-Sicherheitsaudits

# TOM's: Verfügbarkeitskontrolle

## Ziel

Schutz gegen zufällige oder mutwillige Zerstörung bzw. Verlust

## Maßnahmen

Backup-Strategie und –Verfahren (online/offline; on-site/off-site)

Brandfrüherkennung, Rauchmeldeanlagen

Unterbrechungsfreie Stromversorgung (USV)

Virenschutz

Firewall

Meldewege und Notfallpläne, „IT-Fluchtplan“ mit individuellen Maßnahmen

Erkennen von atypischen Nutzungsmustern

Beschränkung der Ressourcenzuweisungen an einzelne Benutzer

# TOM's: Trennungskontrolle

## Ziel

Getrennte Verarbeitung von Daten, die zu unterschiedlichen Zwecken erhoben wurden

## Maßnahmen

Mandantenfähigkeit, Gewährleistung der Zweckbindung

Trennung von Produktiv-, Test- und Entwicklungssystemen

getrennte Ordnerstrukturen (Kunden, Anwendungsbereiche, Auftragsverarbeitung), separate Tabellen innerhalb von Datenbanken, getrennte Datenbanken

Sandboxing

# TOM's: Wiederherstellbarkeit

## Ziel

Der Betrieb von Anwendungen und Systemen kann im Störfall rasch wiederhergestellt werden

## Maßnahmen

Schutzbedarfsfeststellungen

Notfallplan, Disaster Recovery Maßnahmen

Business Continuity Management

Schulung und Übungen, Dokumentation und Ermittlung des Verbesserungsbedarfs

# TOM's und AVV's \*

## 1. Vertraulichkeit (Art. 32 Abs. 1 lit. b DSGVO)

Zutrittskontrolle

Zugangskontrolle

Zugriffskontrolle

Trennungskontrolle

Pseudonymisierung (Art. 32 Abs. 1 lit. a DSGVO; Art. 25 Abs. 1 DSGVO)

## 2. Integrität (Art. 32 Abs. 1 lit. b DSGVO)

Weitergabekontrolle

Eingabekontrolle

**\* Auftragsverarbeitungsverträge in Anlehnung an Vorlage der GDD**



## **TOM's und AVV's \***

### **3. Verfügbarkeit und Belastbarkeit (Art. 32 Abs. 1 lit. b DSGVO)**

Verfügbarkeitskontrolle

Rasche Wiederherstellbarkeit (Art. 32 Abs. 1 lit. c DSGVO)

### **4. Verfahren zur regelmäßigen Überprüfung, Bewertung und Evaluierung (Art. 32 Abs. 1 lit. d DSGVO; Art. 25 Abs. 1 DSGVO)**

**Datenschutz-Management**

Incident-Response-Management

Datenschutzfreundliche Voreinstellungen (Art. 25 Abs. 2 DSGVO)

Auftragskontrolle

# Wirksamkeit von TOMs

## Wirksamkeit von TOMs muss (stichprobenartig) geprüft werden!

- Bsp. Zutrittskontrolle: „Beschränkte Zufahrt zum Werksgelände mit Authentifikation via Dienstausweis“ sieht auf dem Papier gut aus, aber was verbirgt sich dahinter?



## ÜA: „Stand der Technik“

**Gesetze (EU-DSGVO, ITSiG,...) und Standards (ISO, BSI, ...) verlangen Sicherheitsmaßnahmen nach dem „Stand der Technik“**

**Gruppenarbeit: Gehen Sie in Gruppen aus 3-5 Studierenden zusammen und erarbeiten Sie eine Kurzpräsentation (max. 5 Minuten) zu den folgenden Themen:**

- Welche aktuellen Anwendungsbeispiele gibt es für den Stand der Technik?
- Abgrenzung zum „Stand der Wissenschaft und Forschung“
- Abgrenzung zu „allgemein anerkannten Regeln der Technik“
- Welche Konsequenzen ergeben sich aus der Vorgabe Sicherheitsmechanismen nach dem „Stand der Technik“ einzusetzen für Investitionsentscheidungen in Unternehmen?

**Bearbeitungszeit: ca. 30min.**

# 4

## Cyber Security

# Cyber-Security: Einführung

„Die Frage ist nicht, ob man Sie angreifen wird, sondern wann ...“

[Cal Leeming]

## Schadensursachen

- Erfolgreiche, kriminelle Geschäftsmodelle einerseits,
- Mangelndes Cybersicherheitstraining andererseits.

## Maßnahmen

- Aufklären, Aufklären, ...
- Schulen, schulen, ...
- Cybersicherheit-Events mit unabhängigen Experten
- Red Team Assessments
- Haftung von IT-Dienstleistern

# Generische Ursachen, Auswirkungen und Maßnahmen

## Anwender

Anwenderfehler, z.B. bei:

- Phishing-E-Mails
- USB-Sticks dubioser Herkunft

Böswilliges Verhalten

## Maßnahmen

Aufklärung

Identitätsmanagement

Zugriffskontrollen

Prinzipien für die Gewährleistung der Integrität & Vertraulichkeit

- Need-to-Know-Prinzip
- Separation-of-Duties-Prinzip
- Rotation-of-Duties-Prinzip

## Computer und IT

Den größten Schaden verursacht i.d.R. nicht der Angriff, sondern die Ausfallzeit

Imageschäden und Bußgelder (Art. 83 DSGVO)

## Maßnahmen

Anti-Viren-Lösungen reichen nicht

TOMs gemäß Art. 32 DSGVO

Business- Continuity-Lösung

Disaster-Recovery-Plan

Backup

# Passwörter

## Angriffsvektoren

- Informationsverlust bei IT-Dienstleistern
- Sniffing (Abhören) eines unverschlüsselten WLANs
- Spear-Phishing in Kombination mit Social-Engineering
- USB-Sticks fremder Herkunft \*

## Maßnahmen

- Prüfen der eigenen e-Mail-Adresse  
[www.HaveIBeenPwned.com](http://www.HaveIBeenPwned.com)  
<https://sec.hpi.de/ilc/?lang=de>
- Prüfen des Passworts, Passwort-Routine/Individuelles Schema, Passwort-DB
- 2-Faktor-Authentifizierung aktivieren
- Nutzung eines VPN

# „PPP“ als generische Maßnahme

## Passwörter

- Starke und individuelle Passwörter für unterschiedliche Dienste
- MFA / 2-Faktor-Authentifizierung, insbesondere für hoch priorisierte Accounts und Remote-Zugänge
- Passkeys

## Patching

- Alter Grundsatz „never change a running system“ gilt nicht mehr
- Software-Updates sind unvermeidbar

## Prävention

- Aufklärung und Schulung
- Technische und organisatorische Maßnahmen
- Notfallplan



# Phishing

## Phishing

- Zusammengesetzt aus Password und Fishing

## Phishing-Mail

- Über den Versand von Phishing-Mails versuchen Kriminelle eine Vielzahl von potentiellen Opfern zu erreichen, um von diesen an sensible Nutzerdaten (PINs, Passwörter, Bankverbindungsdaten, TAN...) oder personenbezogene Daten (Name, Anschrift, Geburtsdatum, Geburtsort...) abzugreifen.

## Phishing-Seiten

- sind gefälschte Internetseiten, die vom Aufbau und der Optik einer realen Internetseite nachempfunden sind.
- Dem Besucher der soll vermittelt werden, er befindet sich auf der tatsächlichen Internetseite des Unternehmens.
- Zielsetzung: Eingabe von personenbezogenen Daten oder sensiblen Nutzerdaten in Formularen oder Eingabemasken
- Download von Schadsoftware

# Catphishing

## Sachverhalt

- Nutzung von Dating-Websites, Chatrooms und Foren zur Vernetzung, z.B. Tinder
- Profile mit gefälschten Bildern, Antworten auf Fragen, Neigungen, ...
- Mit Komplimenten, rührseligen Geschichten, romantischen Versprechungen wird ein Catphish interessierte Personen überreden, bestimmte Dinge zu tun
- Oft werden dramatische Geschichten verwendet, um den Prozess zu beschleunigen, z.B.: Seelenverwandtschaft oder Liebe auf den ersten Blick.
- Es darum geht, große Geldbeträge zu überweisen oder persönliche Daten wie E-Mail- oder Amazon-Passwörter preiszugeben.

## Alternative und Beispiel

- Während ihrer Romanze gab sich eine Frau als jüngeres Mädchen aus.
- Anschließend „wurde“ diese dann zur Mutter des Teenagers, um die interessierte Person zu erpressen (Zahlung von Schweigegeld).

# Phishing / Vishing

## Dynamit-Phishing / Spear-Phishing

- Der Angreifer sammelt bei seinen Opfern Informationen darüber, wer in einer Firma mit wem kommuniziert.
- Dabei werden auch Inhalte der Mail-Kommunikation werden abgegriffen. Es lassen sich Phishing-Mails bauen, die nahezu perfekt an das normale Kommunikationsverhalten in einer Firma angepasst sind.
- Angreifer verschicken sehr gut auf eine Zielperson zugeschnittene E-Mails, mit der Absicht, diese dazu zu verleiten, z.B. den Mail-Anhang zu öffnen.

## Vishing

- eine erneute Abwandlung des Worts Phishing in Kombination mit dem englischen Wort voice (deutsch: Stimme)
- "Abfischen" von Daten über das Telefon, in Verbindung mit Social-Engineering
- Vorab wird versucht an möglichst umfangreiche Informationen des Betroffenen zu gelangen.
- Im persönlichen Gespräch wird unter einem „plausiblen“ Vorwand versucht, vom potentiellen Opfer Informationen abzugreifen, bzw. diese Person zur Ausführung einer Aktion (z.B. die Ausführung einer Überweisung an die Kriminellen) zu überzeugen.

# Smishing

- ... ist eine Erweiterung der Wortschöpfung Phishing mit der Integration des Worts SMS.
- Generell geht es Angreifern darum, mithilfe gefälschter Kurzmitteilungen Zugangsdaten etwa zum Online-Banking und anderen Nutzerkonten zu ergattern.
- Seit letztem Herbst gaukeln die Täter dabei dem BSI zufolge Nutzern immer öfter vor, eine zunächst nicht zustellbare Sprachnachricht ("Voicemail") empfangen zu haben oder dass das Smartphone bereits mit einem Schadprogramm infiziert sei.
- Auch sind besonders häufig SMS im Umlauf, bei denen der Empfänger auf ein Video hingewiesen wird, auf dem er zu sehen sei. Das soll neugierig und leichtsinnig machen.

## Empfehlungen

- Klicken Sie nicht auf enthaltene Links.
- Laden Sie keine Dateien aus unbekannter Quelle herunter.
- Löschen Sie die verdächtige SMS-Nachricht unverzüglich.

## Quishing / Attagging

- Beim "Attagging" wird ein echter QR-Code durch einen geklonten ersetzt, der dann die Person, die den Code scannt, auf eine ähnliche Website umleitet, auf der persönliche Daten abgefangen und abgegriffen werden können.
- Dies geschieht, ohne dass die meisten Nutzer bemerken, dass sich der Domänenname der Website geändert hat.
- Sind COVID-Test-Codes ein Sicherheitsrisiko?



# „Smarte“ Geräte für Zuhause

## Eine Untersuchung mehrerer Hersteller zeigte dass:

- sowohl im privaten als auch im Unternehmenskontext viele Geräte Sicherheitsmängel aufweisen.
- viele Anbieter legen ihre Standards weder offen, noch reagieren sie auf Hinweise von Sicherheitsforschern.
- Einmal verkaufte Geräte werden später nicht gepatcht und bleiben oft auf dem Sicherheitsniveau, welches sie bei der Auslieferung hatten. Das wiederum ist meist zum Zeitpunkt des Verkaufs schon problematisch.

## Maßnahmen

- Technische Informationen einholen
- AGBs und Datenschutzbestimmungen prüfen
- Initial Risk Assessment vor Beschaffung durchführen

# Weniger bekannte Angriffe

## Brute-Force

- Eindringlinge probieren verschiedene Passwörter für einen Benutzer durch
- Dies lässt sich durch den Einsatz von Multi-Faktor-Authentifizierung (MFA) deutlich erschweren.

## Password-Spraying

- Funktioniert wie eine umgekehrte Brute-Force-Attacke
- Hierbei wird ein Passwort bei vielen verschiedenen Benutzerkonten ausprobiert
- Auch dieser Angriff lässt sich per MFA deutlich erschweren.

## OAuth-Phishing

- Über einen per E-Mail gesendeten Link übergibt der Benutzer Rechte an eine App
- Webdienste oder Apps erhalten Zugriff, ohne dass diese jedes Mal nach dem Passwort oder einem zweiten Faktor fragen müssen
- App erhält ein spezielles OAuth-Token, mit dem sie sich gegenüber dem Dienst ausweisen kann
- MFA reicht nicht aus
- Falls nicht benötigt, Rechteweitergabe an eine App für Benutzer unterbinden.
- Sensibilisierung und Schulung zu dieser neuen Angriffsform!

# Ransomware 2.0

## Fakten

- Ransomware ist ein lukratives Geschäft
- die „Branche“ findet immer wieder neue Wege, um noch verlässlicher Geld zu erpressen.
- Aktuelle „Schwäche“ der kriminellen Geschäftsmodelle ist die gute Vorbereitung der potentiellen Opfer, z.B. durch:  
Offsite-Backups  
Disaster-Recovery-Prozesse
- aber ...

## Neue Bedrohungsvektoren

- Kopieren der Daten vor der Verschlüsselung
- Druckmittel: Veröffentlichung geheimer Daten
- „Vertraulichkeit bricht ... bis in alle Ewigkeit ...“
- Ransomware-Infektionen sind zugleich auch Datenlecks

## Erkenntnisse

- Business Continuity ist nicht ausreichend
- Vertraulichkeit gemäß Stand der Technik (siehe DSGVO) ist nicht ausreichend
- Bedrohungsanalyse und proaktives Risikomanagement erforderlich

[vgl. Fuhr, 2020]



# Diebstahl von Kreditkartendaten für Zahlungen per Handy

## Hintergrund

- Auf aktuellen Smartphones und Smartwatches lassen sich auch die Daten von Kredit- oder Debitkarten hinterlegen und mittels Apple Pay oder Google Pay nutzen.
- Nach einer Bestätigung etwa mit einer Mobile-PIN hinterlegt man so die Daten in der Wallet auf dem Gerät. Künftig genügt das Öffnen der Wallet und die Bestätigung der Zahlung etwa per Fingerabdruck, Gesichtserkennung oder Telefon-PIN, um die Zahlung über die Karte abzuwickeln.

## Angriffsvektor

- Die Betrüger nutzen dem LKA Niedersachsen zufolge Phishing-Seiten, um an die Daten der Debit- oder Kreditkarten zu gelangen.
- Tags darauf rufen sie bei den potenziellen Opfern an und geben sich als Bank-Mitarbeiter aus. Im Laufe des Gesprächs erfolgte stets eine Aufforderung, eine Push-TAN zu bestätigen – diese kommt während des Gesprächs an.
- Fällt das Opfer darauf rein und bestätigt die TAN, schaltet das die Karte auf dem Betrügerhandy frei. Ohne weitere PINs, TANs oder gar physische Kreditkarte können die Betrüger ab dem Zeitpunkt mit der Kreditkarte einkaufen und zahlen.

## Maßnahmen

- Online-Banking-Webseite ausschließlich über die bekannte URL und nicht durch Klicken auf Links etwa in E-Mails, SMS oder Messenger-Nachrichten aufsuchen.
- Banken und Kreditinstitute forderten zudem niemals per Telefon oder Nachrichten dazu auf, sensible Daten oder TANs zu nennen.

# Phishing mit Amazon-Kontoübernahme(n)

## Hintergrund

- Nutzung eines Käufer- als auch Verkäufer-Kontos bei Amazon
- Keine Verkaufsaktivitäten in den letzten Monaten

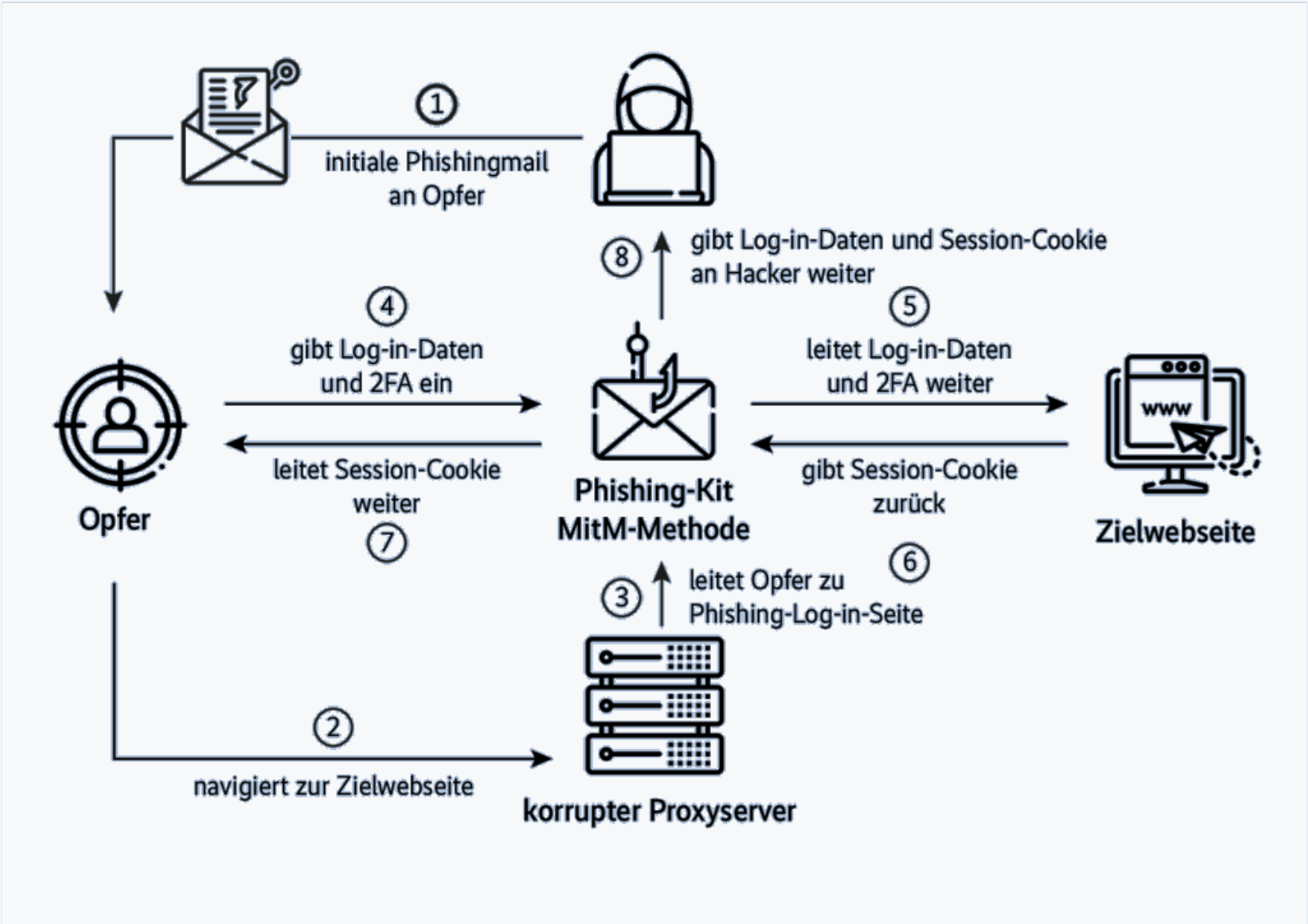
## Angriffsvektor

- Hinweis von „Amazon“ (Fake), dass das Verkäufer-Konto aktualisiert werden muss, ansonsten wird es geschlossen.
- Phishing-Kits (vorgefertigte Phishingseiten), mit denen selbst technische Laien die Anmeldeseiten bekannter Unternehmen und Onlinedienste nachahmen, auf die sie ihre Opfer dann mit täuschend echt wirkenden Phishingmails locken.
- „Phishing-as-a-Service“-Angebote (PHaaS)
- Man in the Middle als Angriffstrick (siehe nächste Folie)

## Maßnahmen

- Amazon-Webseite ausschließlich über die bekannte URL und nicht durch Klicken auf Links, etwa in E-Mails, SMS oder Messenger-Nachrichten aufsuchen.
- IT-Sicherheitsstrategie mit drei Bausteine: Mindset – Skillset – Toolset (Einstellung, Fähigkeiten, Werkzeuge).
- Neben dem neuesten Stand der 2FA-Technik sollte der Fokus auf nachhaltigen Security-Awareness-Trainings liegen.

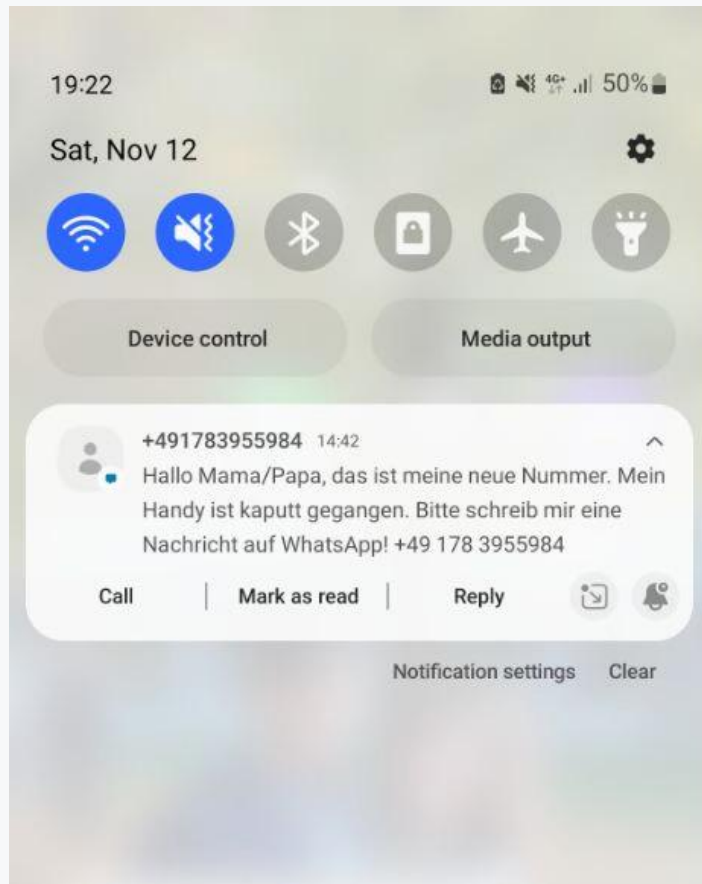
# Man in the Middle als Angriffstrick



Quelle: Kelm, D. (2022): Angriffswelle auf Log-in-Daten, iX10/2022, S. 100

# WhatsApp-Nachricht von Sohn oder Tochter

Betrüger erschleichen Vertrauen und täuschen Notsituation vor



## Angriffsvektor

- Gegenseite hat die Kontaktdaten auf zweifelhaften Wegen erhalten.
- Die angezeigte Rufnummer ist technisch manipuliert (Caller ID Spoofing)
- Falls Sie antworten, erhalten Sie kurz darauf eine weitere SMS oder WhatsApp-Nachricht (ggf. eine Mail) die Sie auffordert, eine Geldüberweisung vorzunehmen oder einen Gefallen zu leisten.
- Ob Zahlungsproblem oder Bitte um einen Gefallen: die Nachricht fordert Sie auf, auf einen Link zu klicken und ggf. Ihre Kreditkartendaten einzugeben.

## Maßnahmen

- Identität des Kontaktes prüfen
- Alternative Kommunikationswege nutzen
- Kontakt abbrechen
- Anzeige erstatten!

# Sicherheitslücken und Responsible Disclosure

Unbekannt

➔ Verwundbar

Bekannt

➔ Sicherheits-Patch ggf. irgendwann verfügbar



Entdecken und  
melden

90 Tage Zeitfrist  
zum Patchen

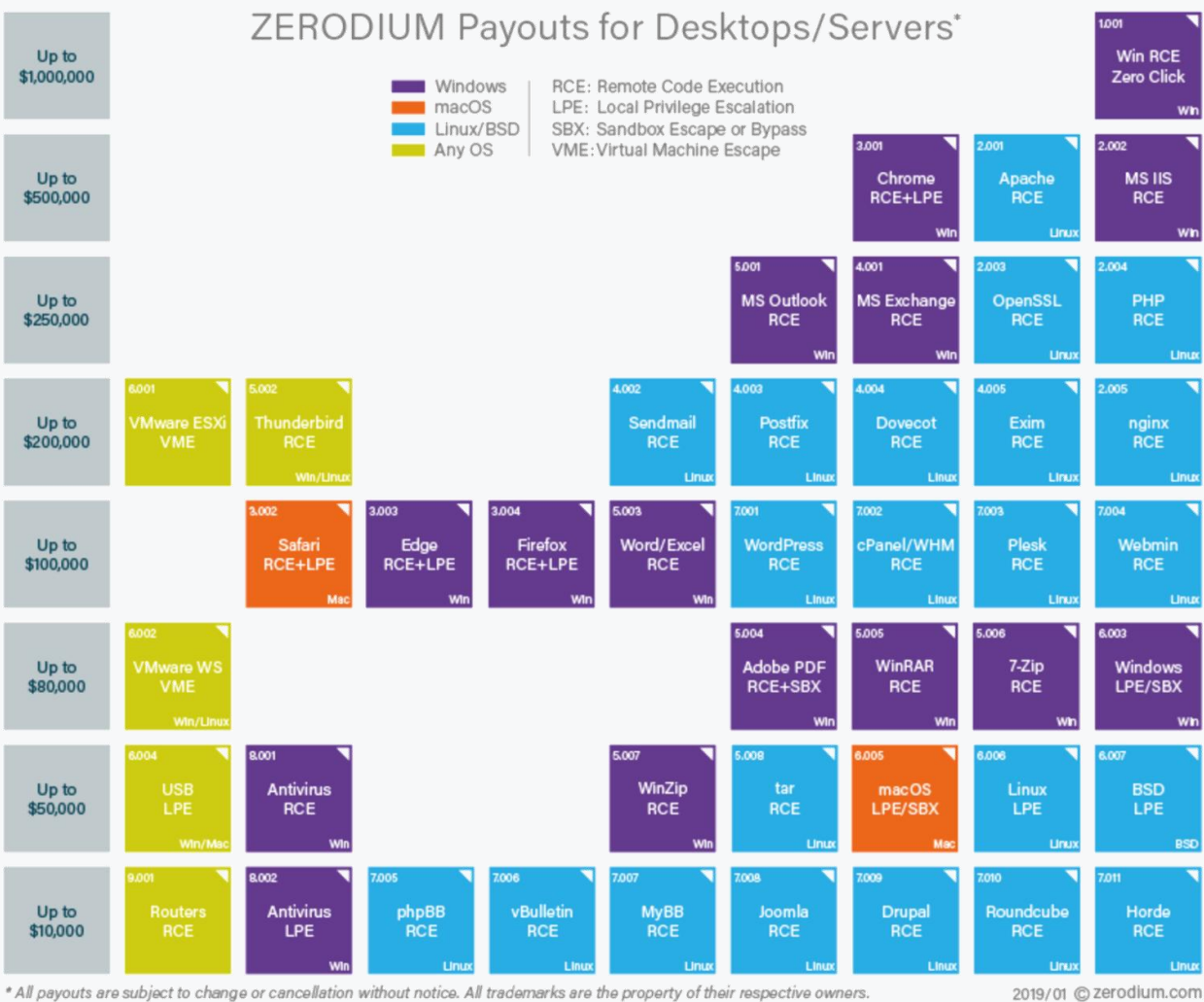
Responsible  
Disclosure

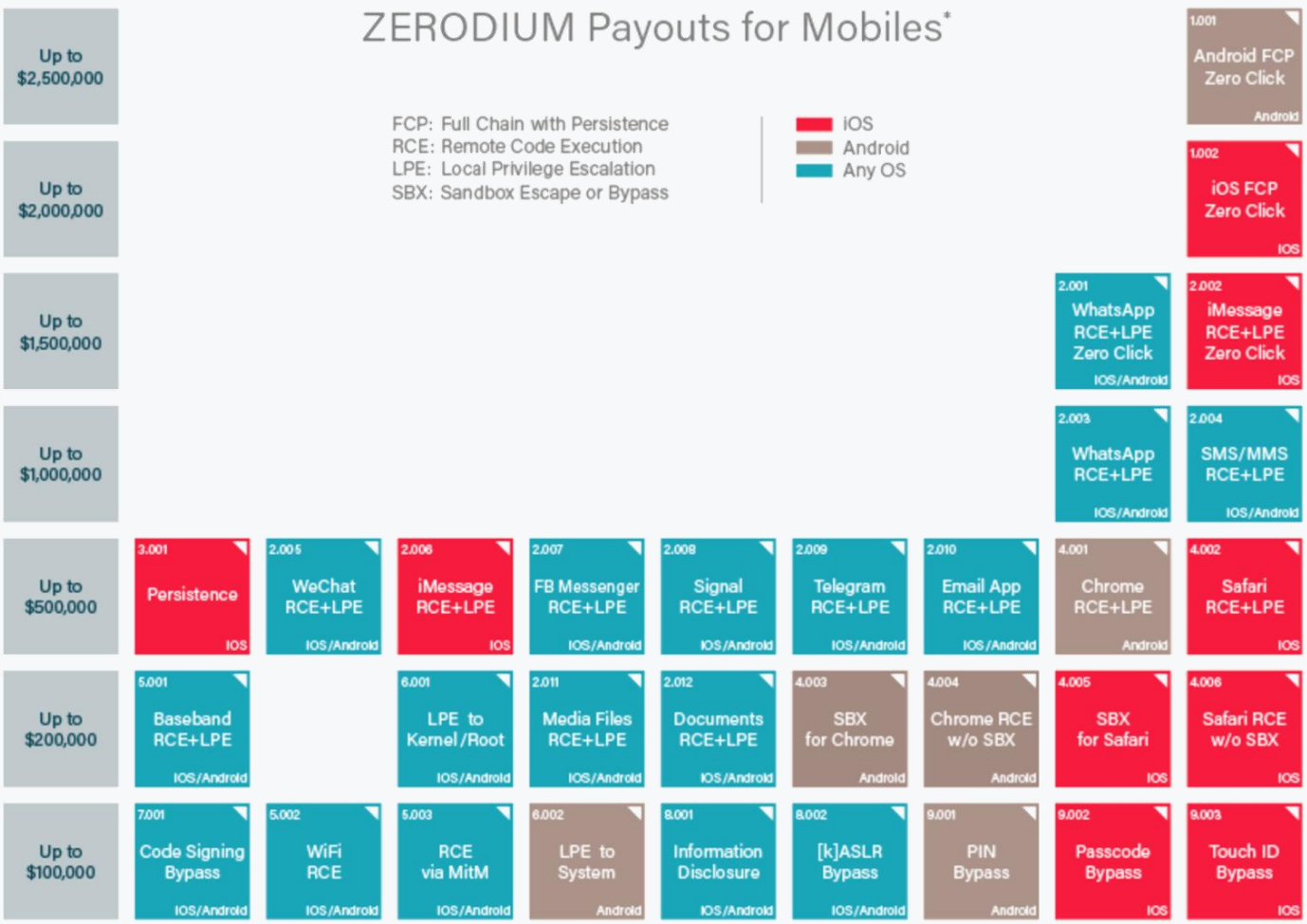
Softwareentwickler

Patch entwickeln  
und veröffentlichen

Day 0

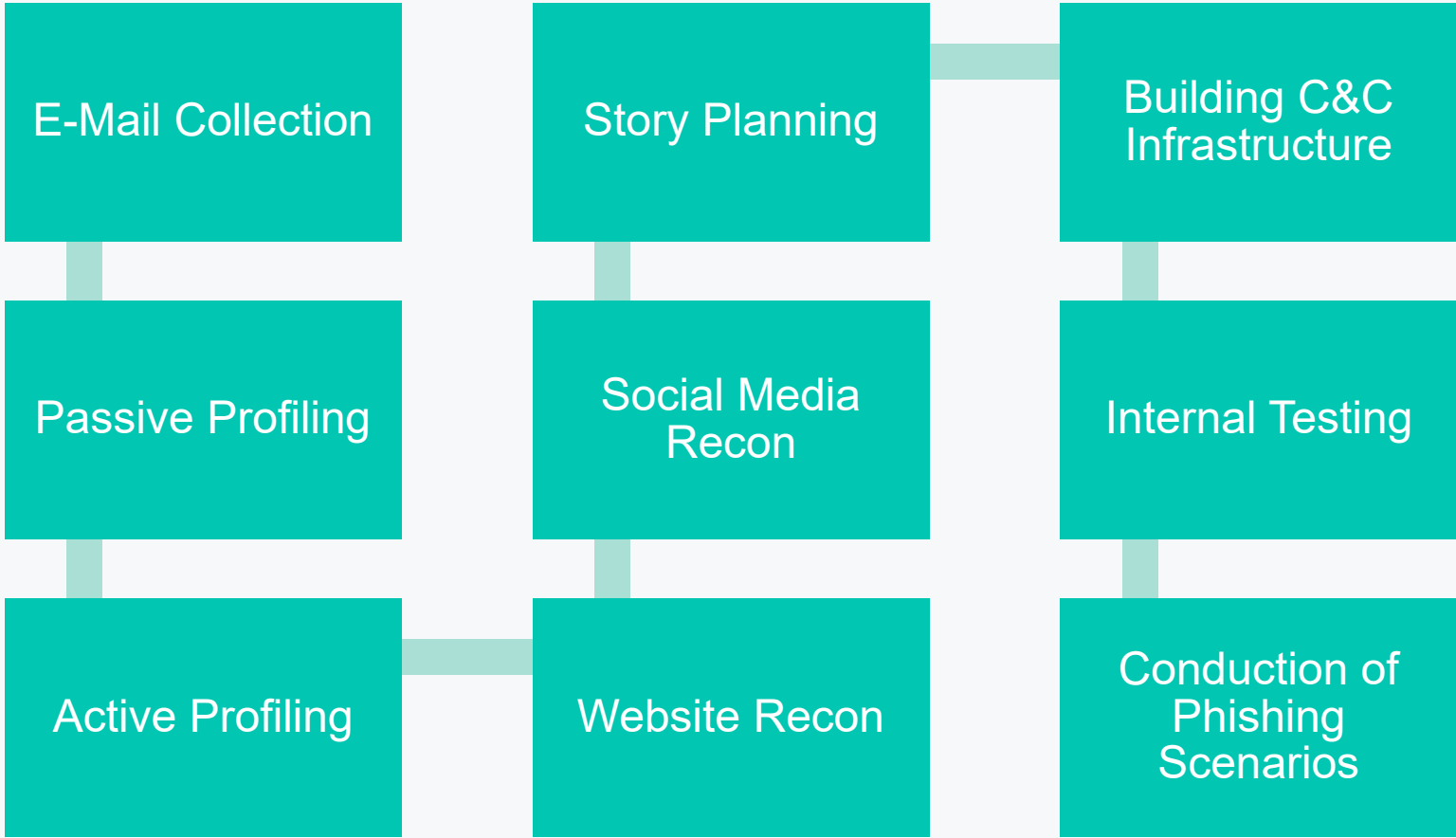
Quelle: Eigene Darstellung





\* All payouts are subject to change or cancellation without notice. All trademarks are the property of their respective owners. 2019/09 © zerodium.com

# Red Team Assessments





# Red Team Assessments – Was passiert nach der Vorbereitung? (1/2)

## Der ultimative Pentest

### Red-Team-Assessments – „echte“ Angriffe für mehr Sicherheit

Beim Versuch, sich ein vollständiges Bild über alle möglichen Schwachstellen zu machen, bleiben bisweilen blinde Flecke. Red-Team-Assessments begnügen sich mit der Suche nach dem Übersehenen, dem leichtesten Weg zu sensiblen Unternehmensdaten – ganz so, wie es ein wirklicher Angreifer täte.

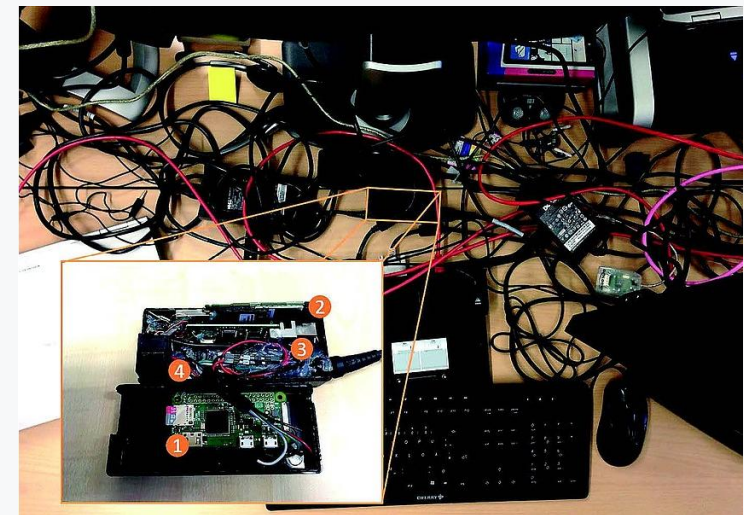
Kein typischer Arbeitsbeginn für die IT-Sicherheit: Draußen dämmert es noch und leichter Nebel liegt über den umliegenden Feldern. Mein Kollege und ich sind mit dem Auto vom Hotel zu unserem Zielobjekt unterwegs – eine halbe Stunde später parken wir das Auto etwas entfernt auf einem Parkplatz. Ausgestattet mit Anzug und einer Aktentasche voller nützlicher Gadgets gehen wir die letzten paar Meter zu Fuß. Der einzige Weg führt uns vorbei an einem Mitarbeiter des Sicherheitspersonals; er schaut flüchtig auf unsere gefälschten Mitarbeiterausweise und lässt uns aufs Gelände.

Das Hauptgebäude unseres Kunden liegt direkt vor uns. Doch anstatt geradeaus hineinzugehen, biegen wir nach rechts ab und betreten das Treppenhaus der Tiefgarage. Ein Stockwerk tiefer drückt der Kollege den Nottaster des Fluchtwegsicherungssystems und die daneben liegende Tür lässt sich öffnen. Als die schwere Sicherheitstür hinter uns ins Schloss fällt, ist der schrille Alarm nur noch leise zu hören. Wir betreten den nächsten Fahrstuhl, mischen uns unter die Mitarbeiter und lassen unsere Blicke schweifen. Das anwesende Sicherheitspersonal verhält sich ruhig und alles läuft normal. Jetzt kann es so richtig losgehen [...]

## Red Team Assessments – Was passiert nach der Vorbereitung? (2/2)

[...]

Nachdem mein Kollege und ich uns unter die Mitarbeiter gemischt haben, machen wir uns auf die Suche nach einem VoIP-Telefon – schnell werden wir fündig. Wir notieren uns seine MAC-Adresse und konfigurieren den Raspberry Pi im mitgebrachten umgebauten Netzteil (vgl. Abb.) mit der MAC-Adresse des Telefons. Mein Kollege zieht das Netzkabel des Telefons aus der Wanddose und steckt stattdessen unser Gerät an. Über das eingebaute LTE-Modem prüfen wir, ob sich unser Gerät erfolgreich mit dem Netzwerk verbunden hat. Jetzt nur noch einen Zettel mit „Defekt. Techniker ist informiert“ auf das Telefon kleben und das umgebaute Netzteil im Kabelgewirr verstecken. Der vom eingeschleusten Gerät durchgeführte Netzwerksan servierte uns anschließend einen internen Tomcat-Server mit aktiver Management-Oberfläche und Standardpasswörtern. Ab da war alles ein Kinderspiel ...



## Hackerparagraph - §202 StGB

**Neben Computersabotage wird auch die Anwendung von Hackertools unter Strafe gestellt**

**Absatz C: Bereits der Besitz solcher Tools wird potentiell unter Strafe gestellt:**

§202c StGB: Vorbereiten des Ausspähens und Abfangens von Daten

- (1) Wer eine Straftat nach §202a oder §202b vorbereitet, indem er Passwörter oder sonstige Sicherungscodes, die den Zugang zu Daten (§202a, Abs. 2) ermöglichen, oder Computerprogramme, deren Zweck die Begehung einer solchen Tat ist, herstellt, verbreitet oder sonst zugänglich macht, wird mit Freiheitsstrafe bis zu einem Jahr oder mit Geldstrafe bestraft.
- Es liegt keine explizite Ausnahme für Sicherheitsprüfungen vor, deswegen ...

# Nutzung von Sicherheitstools

## Bemerkung zur Rechtslage in Deutschland

- WLAN-Sniffer: Das absichtliche Abhören oder Protokollieren von fremden Funkverbindungen ist verboten, sofern es vom Netzbetreiber nicht explizit erlaubt wurde.
- Ungewolltes Abhören scheint nach dem deutschen Telekommunikationsgesetz erlaubt zu sein, jedoch ist eine Speicherung, Weitergabe oder Verwendung der so erlangten Daten ebenfalls nicht zulässig.

## Entscheidung des BverfG vom 18.05.2009:

- Im Rahmen von reinen Sicherheitstests ist nicht nur die Verwendung von „Dual use“-Software gestattet, es dürfen sogar Hacking-Tools verwendet werden.

## Sicherheitstests: Vermeidung juristischer Probleme (1/2)

### Empfehlungen des Bitkom:

- Eindeutige Autorisierung von festgelegten Personen zur Testdurchführung durch das Management.
- Die Durchführung solcher Tests ist in der Aufgabenbeschreibung dieser Personen enthalten.
- Der Einsatz der Programme außerhalb dienstlicher Tätigkeit ist untersagt.
- Das Einverständnis des Systemeigentümers muss vorliegen und der Test mitsamt Ablauf muss mit ihm abgesprochen sein.
- Tests für interne oder externe Kunden benötigen einen schriftlichen Auftrag. Dieser Auftrag muss Art, Umfang und die zu testenden Systeme benennen, sowie die beauftragten Mitarbeiter namentlich enthalten.
- Während der Testdurchführung sind aussagekräftige Protokolle zu führen.
- Die Testergebnisse und Informationen sind sicher zu verwahren und unterliegen der Geheimhaltung.

## Sicherheitstests: Vermeidung juristischer Probleme (2/2)

- Werden Tests außerhalb der internen Räumlichkeiten durchgeführt, sollte eine Kopie des schriftlichen Auftrags als Nachweis für strafrechtliche Ermittlungen vor Ort mitgeführt werden.
- Die zutreffenden gesetzlichen Regelungen (BDSG, Fernmeldegeheimnis nach dem TKG) sind zu beachten.
- Bei versehentlichen Schädigung Dritter ist der Test unverzüglich abubrechen und der Geschädigte ist zu informieren. Die Ursache ist zu ermitteln und zu dokumentieren, besonders warum nicht von einer Schädigung Dritter ausgegangen wurde.
- Ergeben sich in einem Test Zugriffsmöglichkeiten auf Daten außerhalb der Autorisierung, darf auf diese Daten nicht zugegriffen werden.

# Auswahlthemen

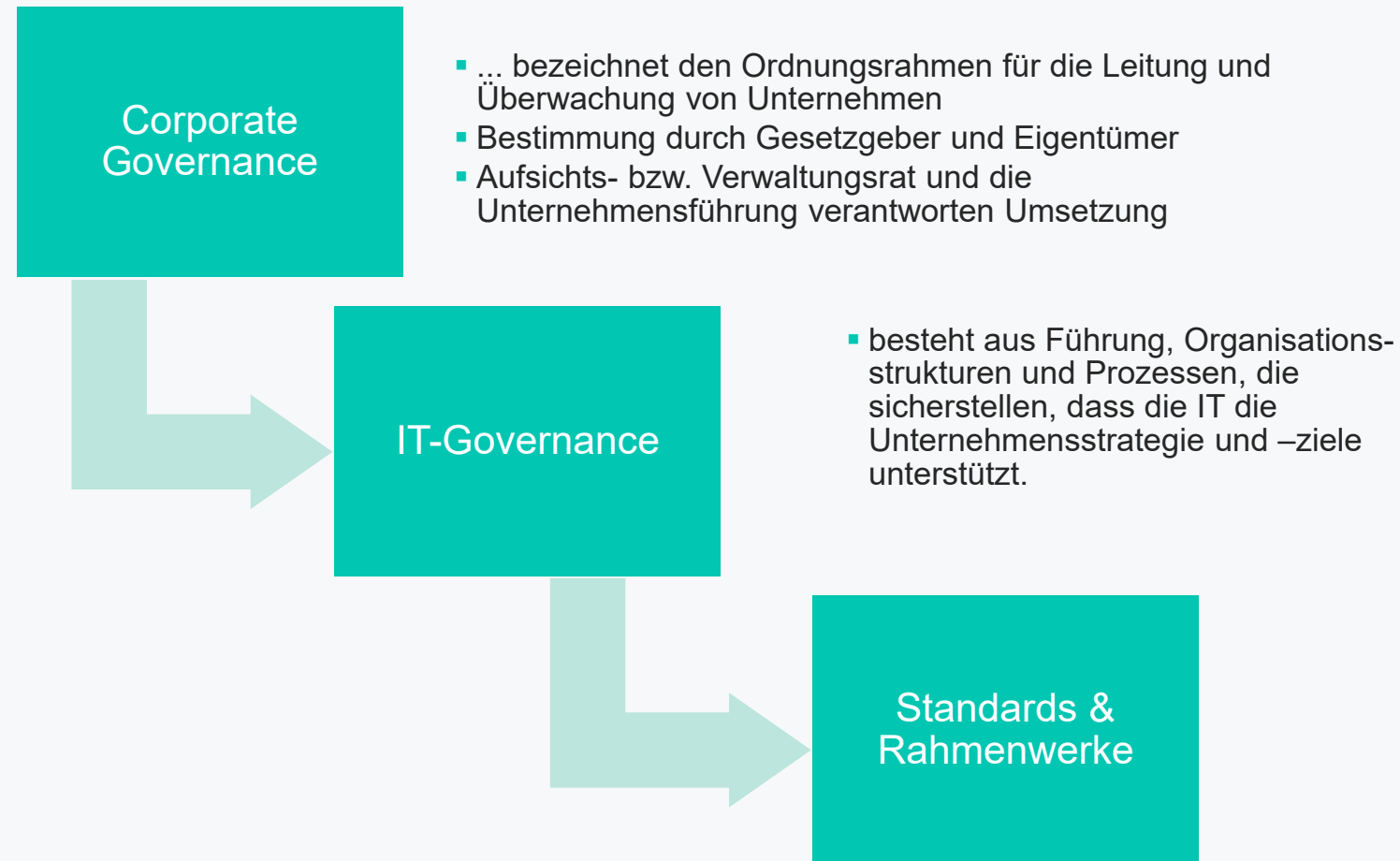
1. Spurenarmes Surfen
2. Nutzung eines VPN
3. Verschlüsselung von Datenträgern
4. Demonstration zu IT-Sicherheit und aktivem Datenschutz
  - Sniffing eines (unverschlüsselten) WLANs
  - WLAN Spoofing
  - Spear-Phishing in Kombination mit Social-Engineering
5. E-Mail-Verschlüsselung mit OpenPGP
  - Installation/Konfiguration der PlugIns unter Windows/Linux/Mac OS X
  - Beglaubigung von OpenPGP-Schlüsseln
  - Austausch signierter/verschlüsselter e-Mails
6. Kennwörter
  - Kennwortroutine/individuelles Schema entwickeln
  - 2-Faktor Authentifizierung (U2F), Passkeys und FIDO2
7. Qualifizierte, elektronische Signatur
  - Umsetzung und Anwendung
8. Sichere Cloud-Lösungen
  - CASB (Cloud Access Security Broker)
  - CDP (Cloud Data Protection)
9. Darknet
  - Aufbau, legale/illegale Inhalte
  - Live-Demo
10. Weitere Themen, z.B. Sicheres Telefonieren und Instant Messaging, Steganographie, ...

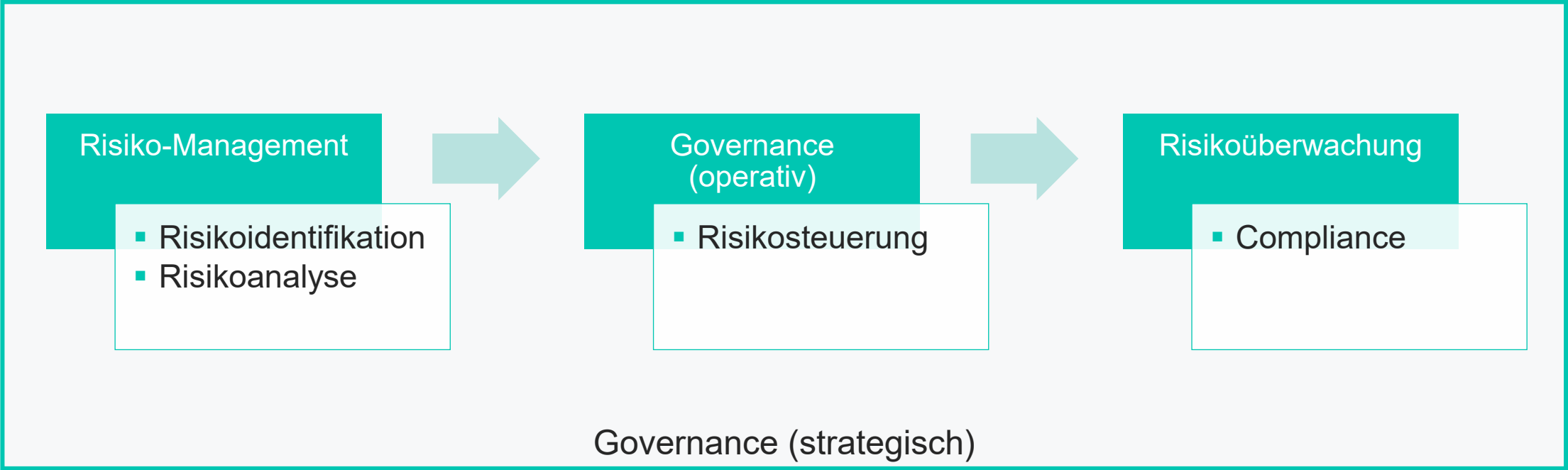
# 5.1

## Governance, Risk & Compliance Management (GRC)



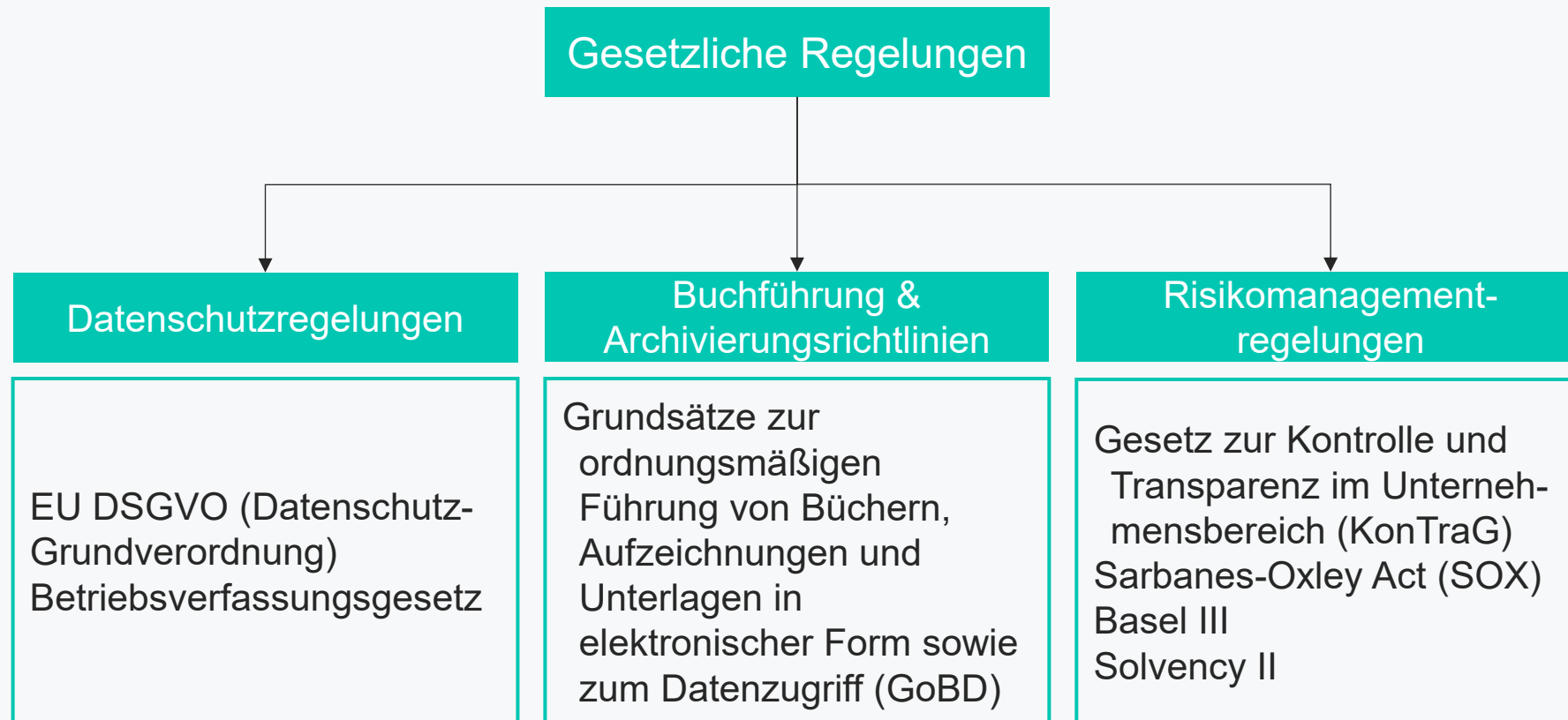
# IT-Governance







# Wesentliche gesetzliche Regelungen



# IT-Governance und Risikomanagement als Managementaufgabe

## Managementaufgabe 1: Risiken und Maßnahmenfestlegen

- Sind die kritischen Anwendungen bekannt?
- Sind die Risiken wirklich identifiziert?
- Wie tragbar ist das Restrisiko?
- Ist das Unternehmen nach einer RZ-Katastrophe noch arbeitsfähig?
- Welche Funktionen sind bei Netzausfall beeinträchtigt?
- Sind Maßnahmen gegen unberechtigten Zugang zu den Systemen und Zugriffe auf Daten und Programme implementiert?
- Welche Vorkehrungen wurden gegen das Eindringen von Viren und Trojanern getroffen?

## Managementaufgabe 2: Wirksamkeit und Aktualität prüfen

- Sind die Sicherheitsmaßnahmen noch aktuell?
- Sind Mitarbeiter und Führungskräfte ausreichend sensibilisiert und trainiert?

## Managementaufgabe 3: Risikokontrolle

- Risikokontrolle gemäß Anforderungen des KonTraG (Gesetz zur Kontrolle und Transparenz im Unternehmen)

# Umsetzung mittels Prozessen und Policies

## Policies (auch „Leitlinien“, „Richtlinien“ oder „Arbeitsanweisungen“) für

- Sicherheits-Organisation
- Sicherheits-Technik
- Kontrolle und Beobachtung
- Objektschutz
- Notfallplanung/Wiederaufbauplanung

## Prozesse und Regelungen auf allen Ebenen

- Vorstands-Ebene
- Zentrale Unternehmensebene (Beauftragter für Informationssicherheit)
- Bereichs-Ebene (Zentraler IT-Service-Bereich)
- Umsetzungsebene (Leitung Informationssicherheit)
- Bereitstellungsebene (Organisation/Technik)

## Allgemeine Sicherheitsmaßnahmen:

- Die regelmäßige Aktualisierung der für das Webseitenangebot verwendeten Software (Einspielen von Sicherheits-Patches).
- Darüber hinaus wird explizit davon gesprochen, dass Werbedienstleister, denen Werbefläche eingeräumt wird, vertraglich zu notwendigen Schutzmaßnahmen zu verpflichten sind.
- Zur Absicherung der IT-Systeme und zum Schutz vor unberechtigttem Zugriff wird insbesondere die Anwendung eines als sicher anerkannten Verschlüsselungsverfahrens genannt; bei personalisierten Telemedien eines angemessenen Authentifizierungsverfahrens.

## Nicht nur für Betreiber kritischer Infrastrukturen ...

- Webseitenbetreiber müssen ab sofort angemessen sicherstellen, dass kein unerlaubter Zugriff auf die für ihre Onlineangebote genutzten technischen Einrichtungen möglich ist.
- Zusätzlich müssen diese Einrichtungen gegen Verletzungen des Schutzes personenbezogener Daten und Störungen gesichert sein.
- Es werden dabei nur die Maßnahmen – technisch wie organisatorisch – gefordert, die für das Unternehmen technisch möglich und wirtschaftlich zumutbar sind.
- Welche technischen und organisatorischen Maßnahmen dabei konkret zu ergreifen sind, lässt das Gesetz leider offen.

# “Entpersonalisierung“ von Daten bei Big-Data

## Privacy Enhancing Technologies (PET)

- “... are a coherent system of ICT measures that protects privacy [...] by eliminating or reducing personal data or by preventing unnecessary and/or undesired processing of personal data; all without losing the functionality of the data system.” [Borking / Raab, 2001]
- Verschlüsselung, Protokolle für sichere bzw. anonyme Kommunikation, Attribut-basierende Berechtigungsnachweise, private Recherchemöglichkeiten
- Reduzierung von Risiken der IKT

## “Privacy by Design” bzw. “Data Protection by Design”

- Entwicklungsansatz für datenschutzfreundliche Systeme und Dienste;
- nicht nur technische Lösungsansätze, sondern auch organisatorische Umsetzungsmöglichkeiten und entsprechende Geschäftsmodelle.
- Obwohl Vorgabe der neuen EU DS-GVO, bleiben konkrete Implementierungsanforderungen unklar



# IT-Sicherheitsstandards

## IT-Sicherheitsstandards

- Methoden und Anforderungen an ein leistungsfähiges Managementsystem für IT-Sicherheit
- Sicherheitsmaßnahmen und Checklisten für deren Implementierung

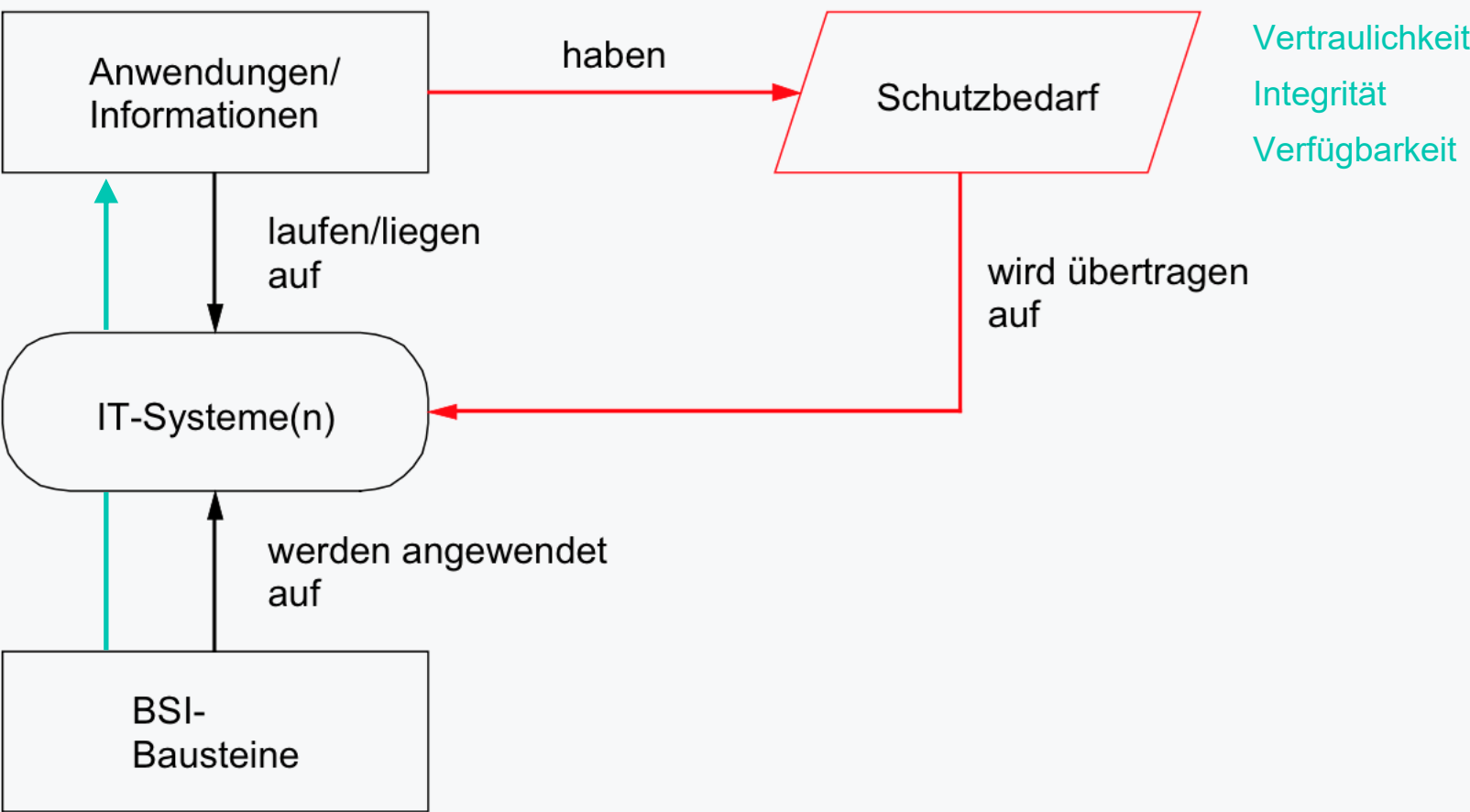
## Nutzeffekte [BITKOM, 2009]

- Kostensenkung durch Nutzung vorhandener und praxiserprobter Vorgehensmodelle, z.B. BSI-Grundschutzmodell
- Einführung eines angemessenen Sicherheitsniveaus durch Standards, Orientierung am aktuellen Stand von Wissenschaft und Technik
- Wettbewerbsvorteile: für die Vergabeverfahren werden zunehmend auf IT-Sicherheitsstandards basierende Zertifikate als Voraussetzung für die Teilnahme gefordert.

# 5.2

## Schutzbedarfsanalyse und Risikomanagement

# Schutzbedarfsanalyse nach BSI



Quelle: Vgl. Friberg, C. et al., 2002

# Bestimmung von Informationswerten (1/3)

## Vertraulichkeit

- (0) Öffentlich: Information für internen Gebrauch und für Kunden / Partner; möglicher finanzieller Verlust zwischen 0 und 5.000, Bruch von Gesetzesvorgaben oder Vertragsbedingungen mit finanzieller Auswirkung ist möglich.
- (1) Externer Gebrauch: Information für internen Gebrauch und für Kunden / Partner. Möglicher finanzieller Verlust zwischen ??? und ???, Bruch von Gesetzesvorgaben oder Vertragsbedingungen mit finanzieller Auswirkung ist möglich.
- (2) Interner Gebrauch: Informationen ausschließlich für internen Gebrauch. Möglicher finanzieller Verlust zwischen ??? und ???. Bruch von Gesetzesvorgaben oder Vertragsbedingungen mit hohem finanziellen Schaden möglich. Vertrauensbruch kann zu Personenschäden führen.
- (3) Vertraulich: Möglicher finanzieller Verlust von mehr als ???. Bruch von gesetzlichen Anforderungen kann zu Strafverfolgung mit möglicher Gefängnisstrafe führen. Informationsverlust kann zu schwerer Verletzung von Personen oder dem Verlust von Menschenleben führen.

## Bestimmung von Informationswerten (2/3)

### Integrität

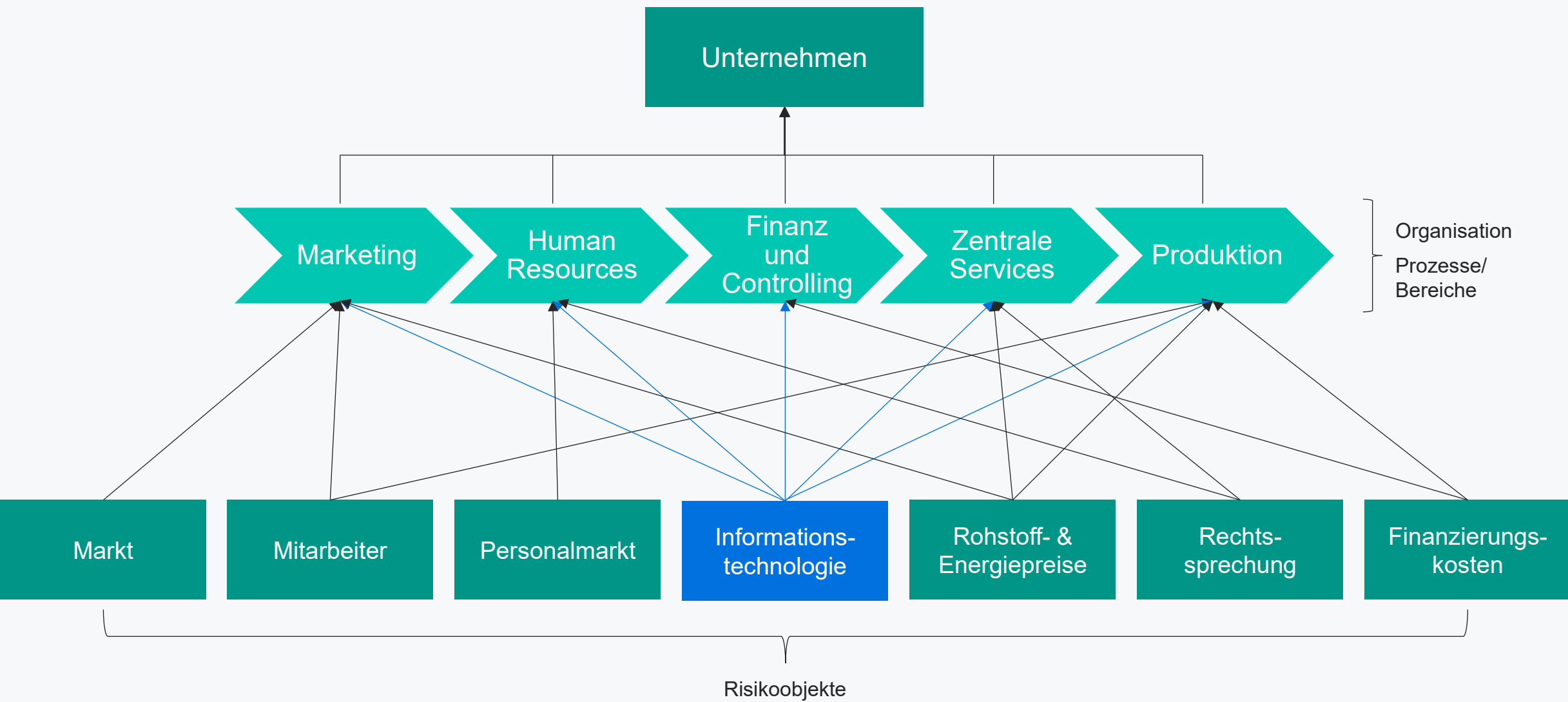
- (0) Keine: Möglicher finanzieller Verlust unter ???.
- (1) Normal: Möglicher finanzieller Verlust zwischen ??? und ???. Bruch von Gesetzesvorgaben oder Vertragsbedingungen mit finanzieller Auswirkung ist möglich. Verstoß kann zu Personenschäden führen.
- (2) Hoch: Möglicher finanzieller Verlust höher als ???. Bruch von Gesetzesvorgaben kann zu Haftstrafe führen. Verstoß kann zu Personenschäden oder Verlust von Menschenleben führen.

# Bestimmung von Informationswerten (3/3)

## Verfügbarkeit

- (0) Basis: Möglicher finanzieller Verlust durch einen Ausfall unter ????. RTO (Recovery Time Objective) größer als ??? Woche(n).
- (1) Normal: Möglicher finanzieller Verlust durch einen Ausfall zwischen ??? und ???. RTO liegt unter ???. Ausfall kann öffentlichen Imageschaden bedeuten.
- (2) Hoch: Möglicher finanzieller Verlust durch einen Ausfall zwischen ??? und ???. RTO liegt unter ???. Ausfall kann Schaden für Unternehmens-Image oder Beeinträchtigung von Kundenbeziehungen bedeuten.
- (3) Sehr hoch: Möglicher finanzieller Verlust durch einen Ausfall zwischen ??? und ???. RTO liegt unter ???. Ausfall kann ernsthaften Schaden für Unternehmens-Image oder Verlust eines Kunden bedeuten.
- (4) Außergewöhnlich: Besondere Vereinbarungen mit einzelnen Kunden, die nicht in eine der o.g. Kategorien fallen.

# IT-Risiko im Unternehmensverbund



Quelle: CALPANA Business Consulting; Eigene Darstellung

# Risikomanagement: Begriffe

## Schwachstelle

- Verwundbarer (vulnerable) Punkt eines IT-System, durch den Sicherheitsziele umgangen werden können

## Bedrohung

- liegt vor, wenn darauf abgezielt wird, eine oder mehrere Schwachstellen eines IT-Systems zu nutzen, die zu einem Verlust der Authentizität, der Verfügbarkeit, der Vertraulichkeit oder der Integrität führen

## Risikoszenario (nach ISO 27001/27005) oder Gefährdung (nach BSI- Grundschutz)

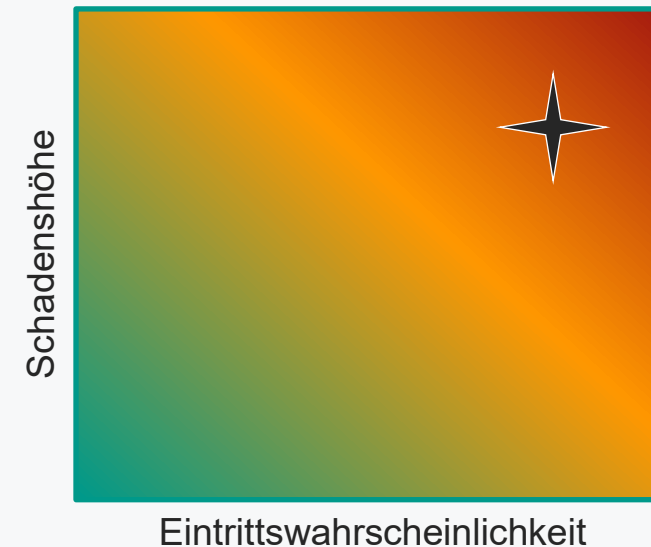
- liegt vor, wenn eine Schwachstelle auf eine Bedrohung trifft



# Risikomanagement: Risiko (1/2)

Ein Risiko liegt vor, wenn eine Bedrohung auf eine Schwachstelle trifft.

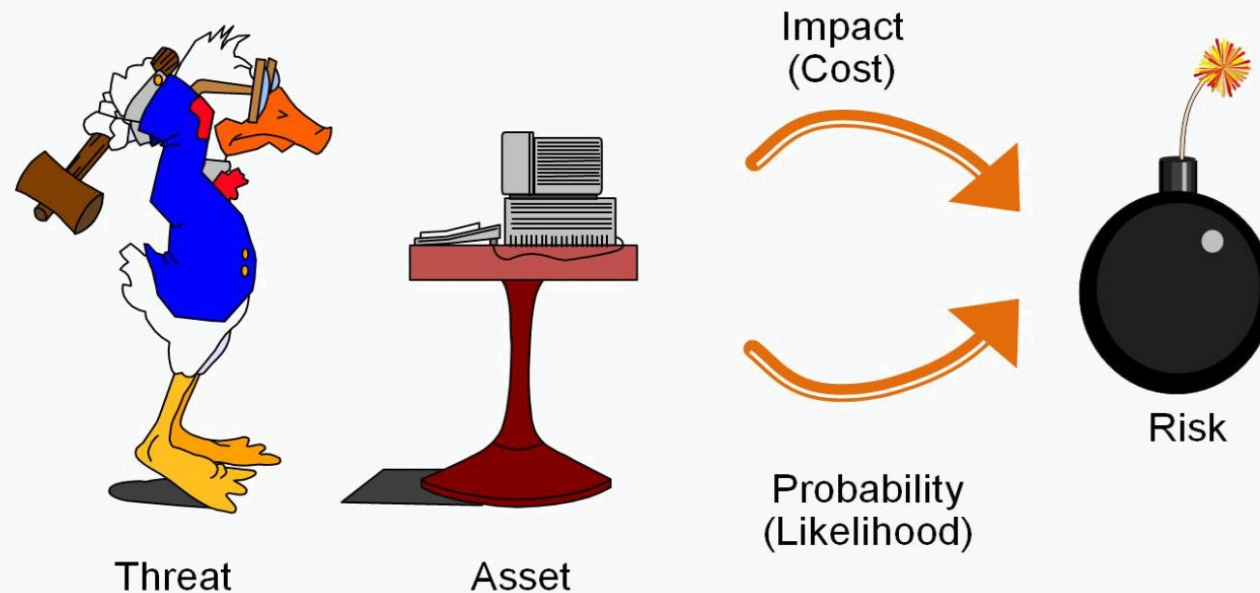
Die Klassifizierung eines Risikos wird anhand der Eintrittswahrscheinlichkeit und der Schadenshöhe vorgenommen.



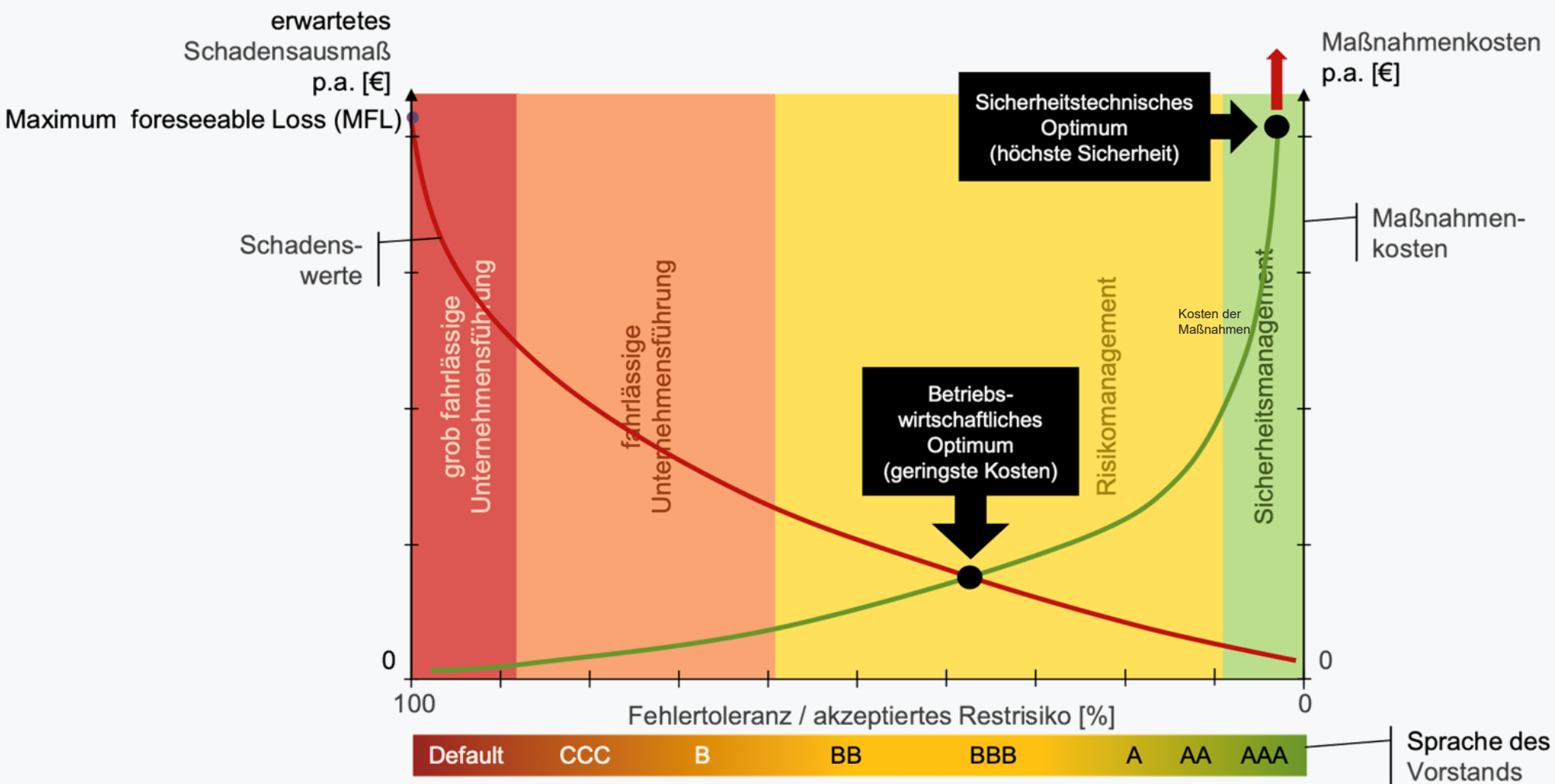
# Risikomanagement: Risiko (2/2)

## Andere Darstellung:

- Bedrohung durch (hier physische) Gewaltbereitschaft
- Wirkt auf Asset Computer mit potentieller Schwachstelle
- Die Risikohöhe bemisst sich nach Eintrittswahrscheinlichkeit multipliziert mit der potenziellen Schadenhöhe



# Definieren der Risikoakzeptanz



Quelle: CALPANA Business Consulting

# Bedrohungsmodellierung

## STRIDE

- Wurde ursprünglich als Teil der Prozesse rund um "threat modeling" entwickelt
- Erkennung von Bedrohungen für ein System
- Vollständige Aufschlüsselung der Prozesse, Datenspeicher, Datenflüsse und Vertrauensgrenzen

## 6 Kategorien an Sicherheitsrisiken und Bedrohungen

- Spoofing  
Identitätsverschleierung → Bruch der Authentizität
- Tampering  
Manipulation → Bruch der Integrität
- Repudiation  
Abstreiten/Verleugnung → Bruch der Nichtabstreitbarkeit beziehungsweise Nachvollziehbarkeit
- Information disclosure  
Verletzung der Privatsphäre oder Datenpanne, Offenlegung von Informationen → Bruch der Vertraulichkeit
- Denial of service  
Verweigerung des Dienstes → Bruch der Verfügbarkeit
- Elevation of privilege  
Rechteauserweiterung → Bruch der Autorisierung

# Prozesse in der IT-Sicherheit

## Aspekte:

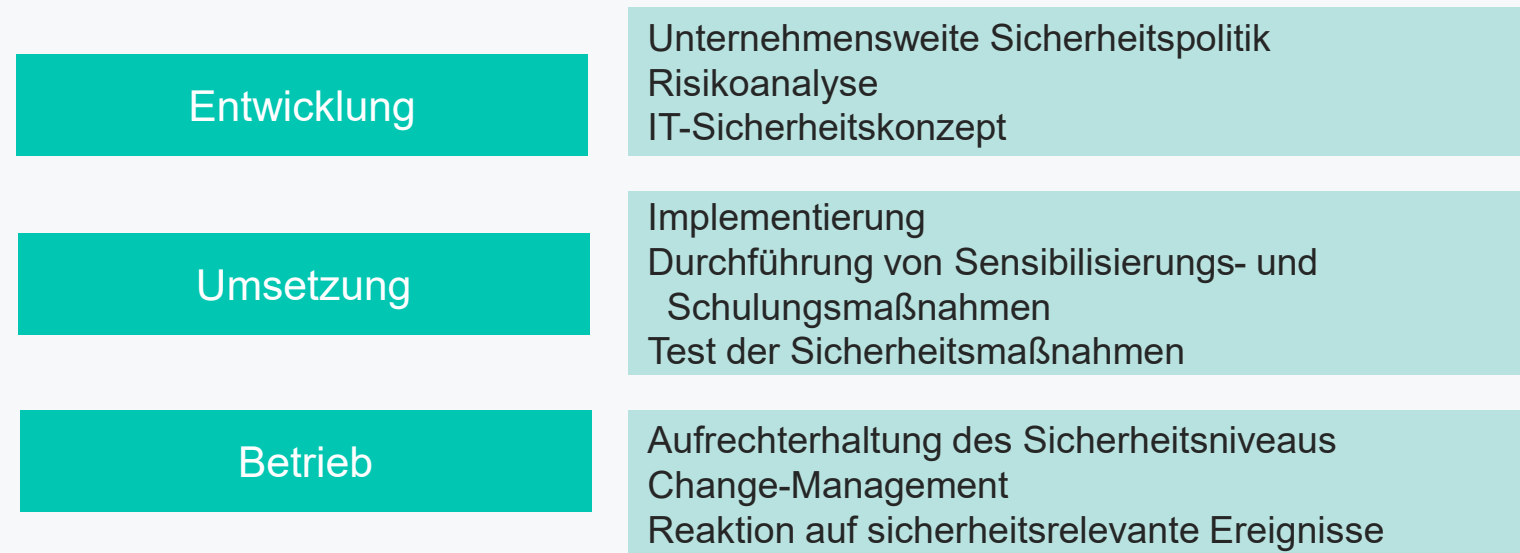
Informationssysteme

Sicherheitsanforderungen

SSLA (Security Service Level Agreements)

Sicherheitsfreigabe

Change-Management



# IT-Prozesse: Security-Workflow Fachbereich

## Risikoanalyse

Informations-/Anwendungssysteme

- Neuentwicklung
- Altsysteme

Risikoklassifizierung

**Sicherheitsanforderungen für System und Anwendung**  
**SSLA (aus Sicht des Fachbereichs)**

# IT-Prozesse: Security-Workflow Organisation/Technik

## Abgleich der Sicherheitsanforderungen aus dem Fachbereich mit:

Schutzzonenkonzept

Lokationsspezifischem Sicherheitskonzept (LSiK)

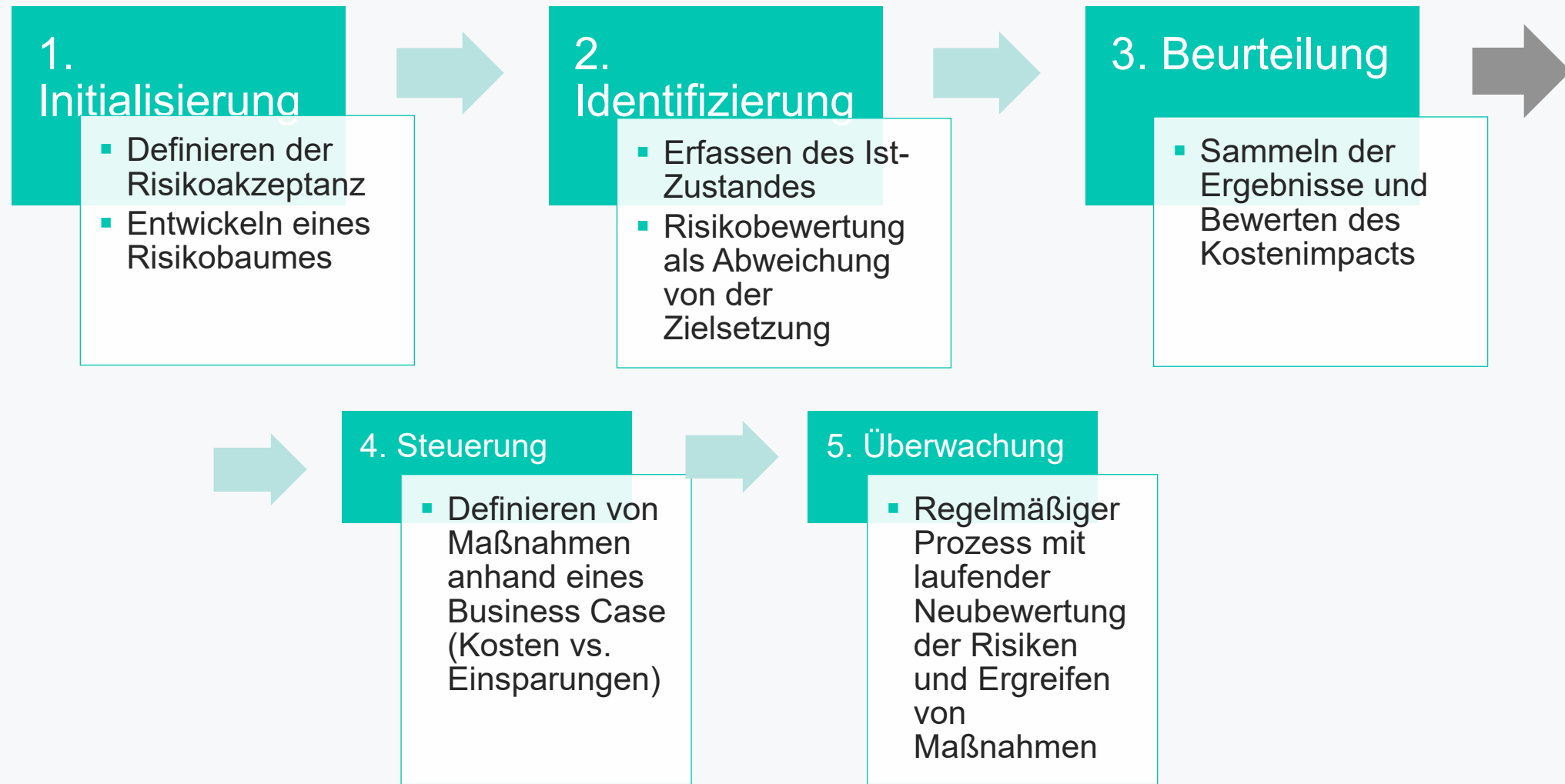
Technischer Schwachstellenanalyse

**Abschluss des SSLA**

**Sicherheitsfreigabe**

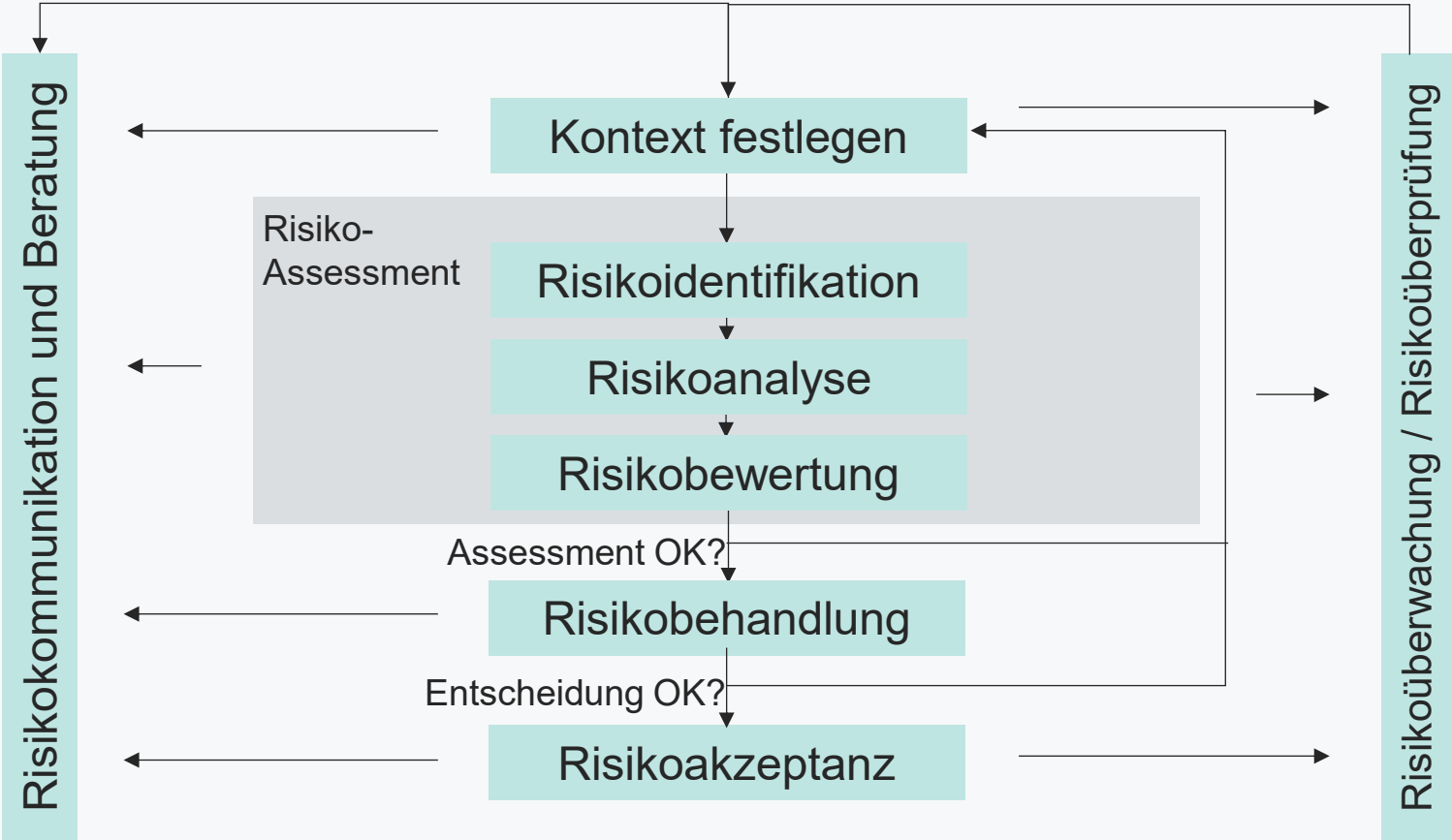
**Change-Management**

# Risikomanagement

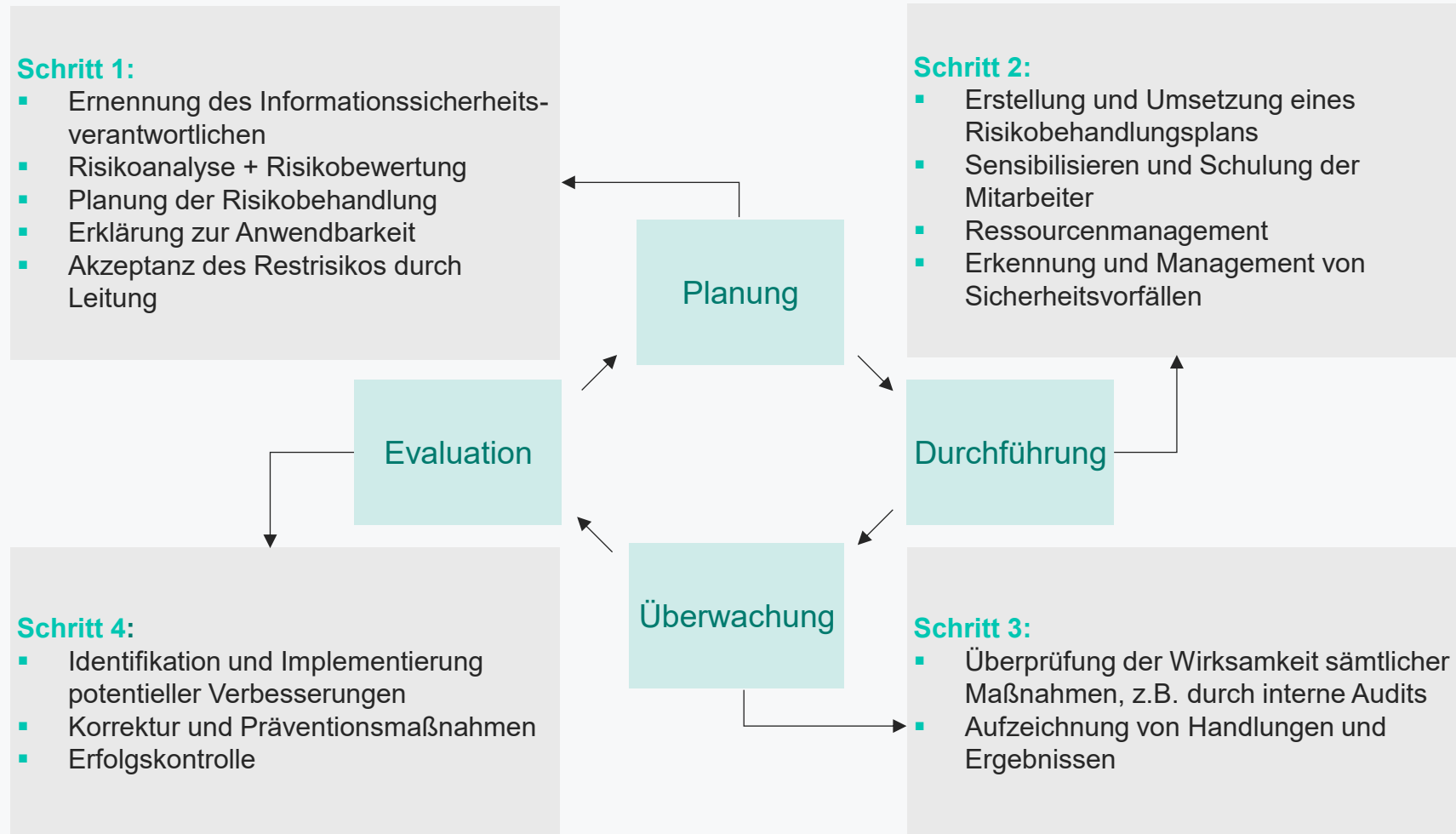




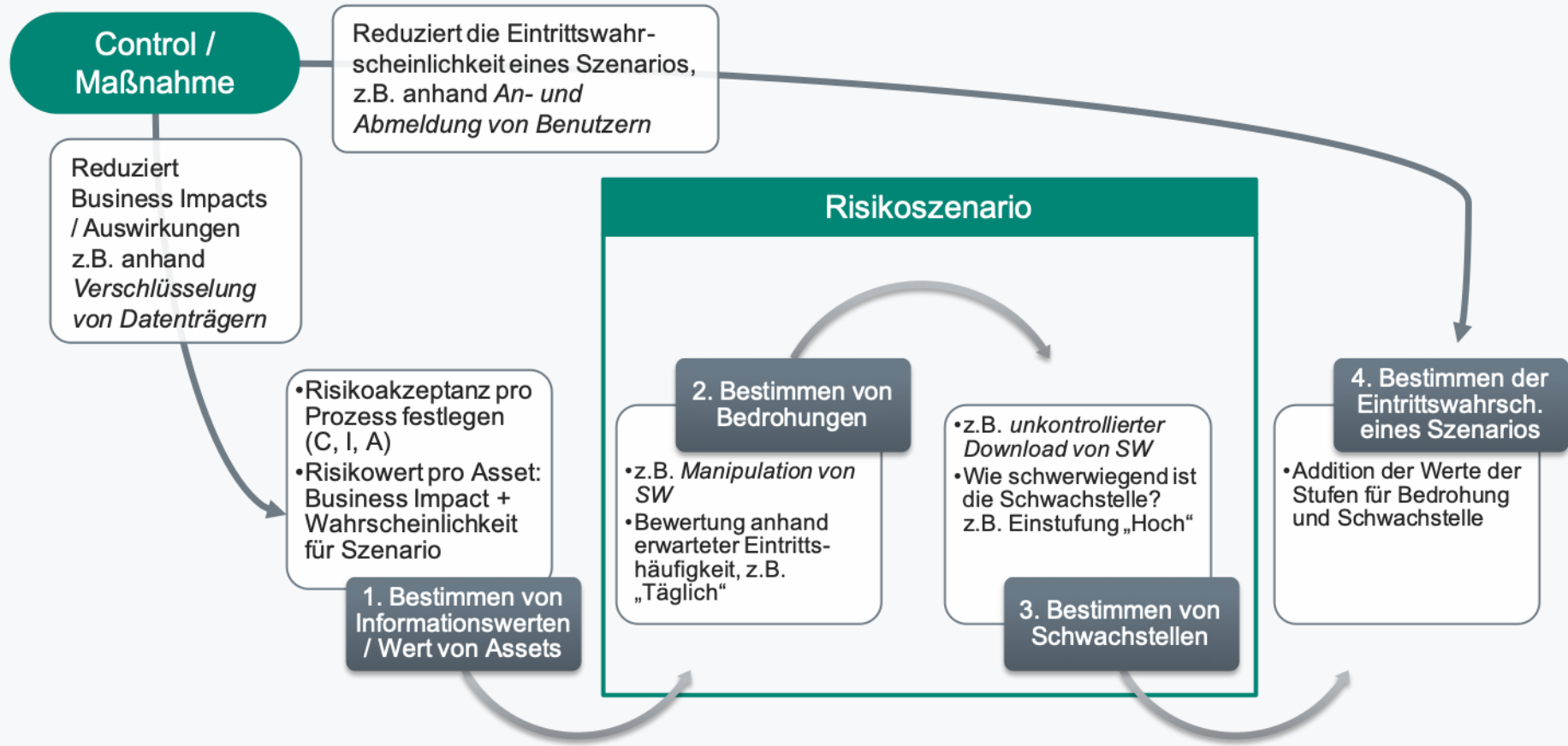
# Risikomanagement: Vorgehen nach ISO/IEC 27005



# Risikomanagement: Vorgehen nach ISO/IEC 27001



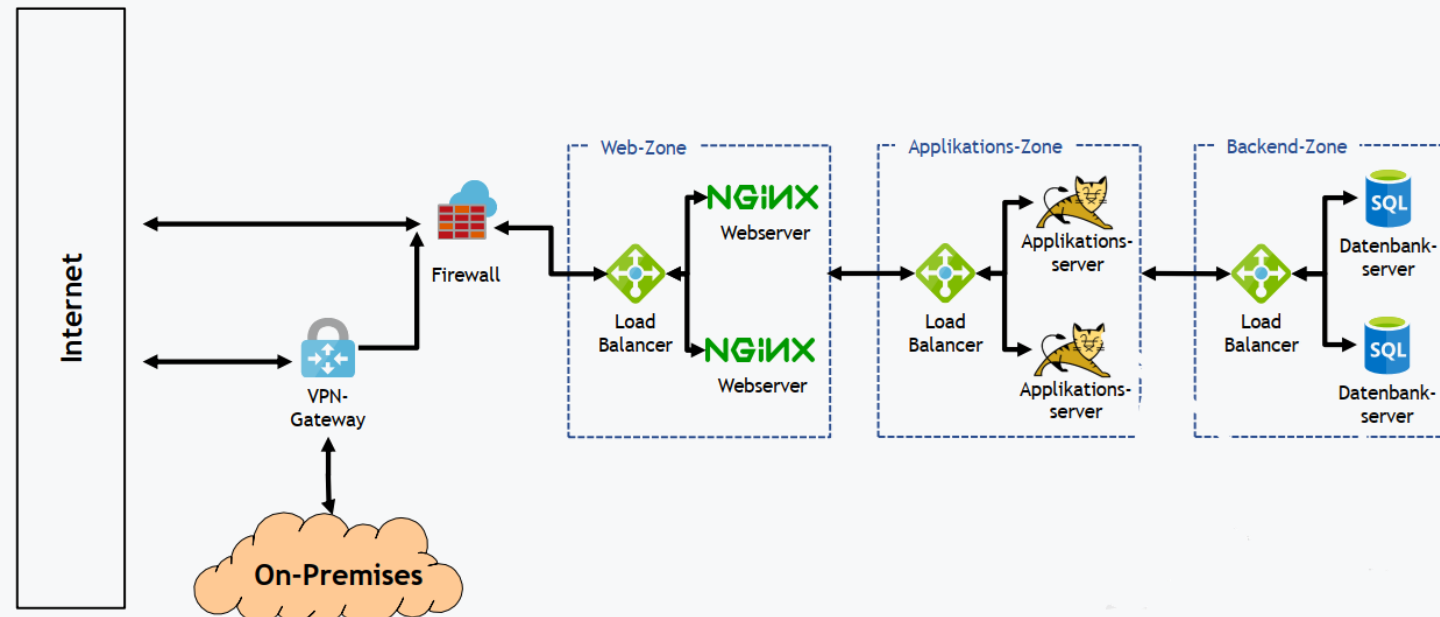
# IT-Risikomanagement in Anlehnung an die ISO 27005



# Übung IT-Sicherheits-Risiko-Assessment

Sie sind in Ihrem Unternehmen für die IT-Sicherheit zuständig. In diesem Zusammenhang begleiten Sie ein Projekt, welches ein neues Kundenportal erstellt. Eine erste Architekturskizze der neuen Cloud-basierten Infrastruktur ist bereits fertiggestellt.

- Welche Sicherheitsrisiken könnten bei den unterschiedlichen Komponenten bestehen?
- Wie hoch könnten Ihrer Meinung nach Eintrittswahrscheinlichkeit und Auswirkungen sein?
- Welche Gegenmaßnahmen würden Sie empfehlen?
- Verwenden Sie die Vorlage Risiko\_Assessment\_Vorlage\_FOM.xlsx



# 6

## ISMS/ DSMS

# Management-System

Als Management-System für ein Thema X bezeichnet man allgemein alles, was eingesetzt wird, um die wesentlichen Ziele für das Thema X zu ermitteln, diese Ziele zu erreichen und ihre Aufrechterhaltung zu überwachen. Typisch ist:

- Ziele in Form von Leitlinien zu formulieren,
- Risiken und Chancen für diese Ziele zu analysieren,
- Rollen bzw. Verantwortlichkeiten für bestimmte (Teil-)Ziele zu definieren,
- Methoden oder Verfahren zu deren Erreichung zu vermitteln,
- den vom Thema X Betroffenen besondere Regelwerke oder Richtlinien aufzugeben,
- Prozesse bzw. Abläufe und dafür erforderliche Maßnahmen zu planen und umzusetzen,
- Überprüfungen der Zielerreichung zu planen, durchzuführen und auszuwerten.

# Schnittmengen Informationssicherheits- & Datenschutzmanagement

## Managementsysteme

- Verbund aller organisatorischen und technischen Einrichtungen um ein Ziel (z.B. Datenschutz-Compliance) zu erreichen
- Risikoanalyse
- Definition von Rollen und Zuständigkeiten
- Definition von Prozessen
- Prüfung der Zielerreichung

# ISMS – Informations-Sicherheit-Management-System

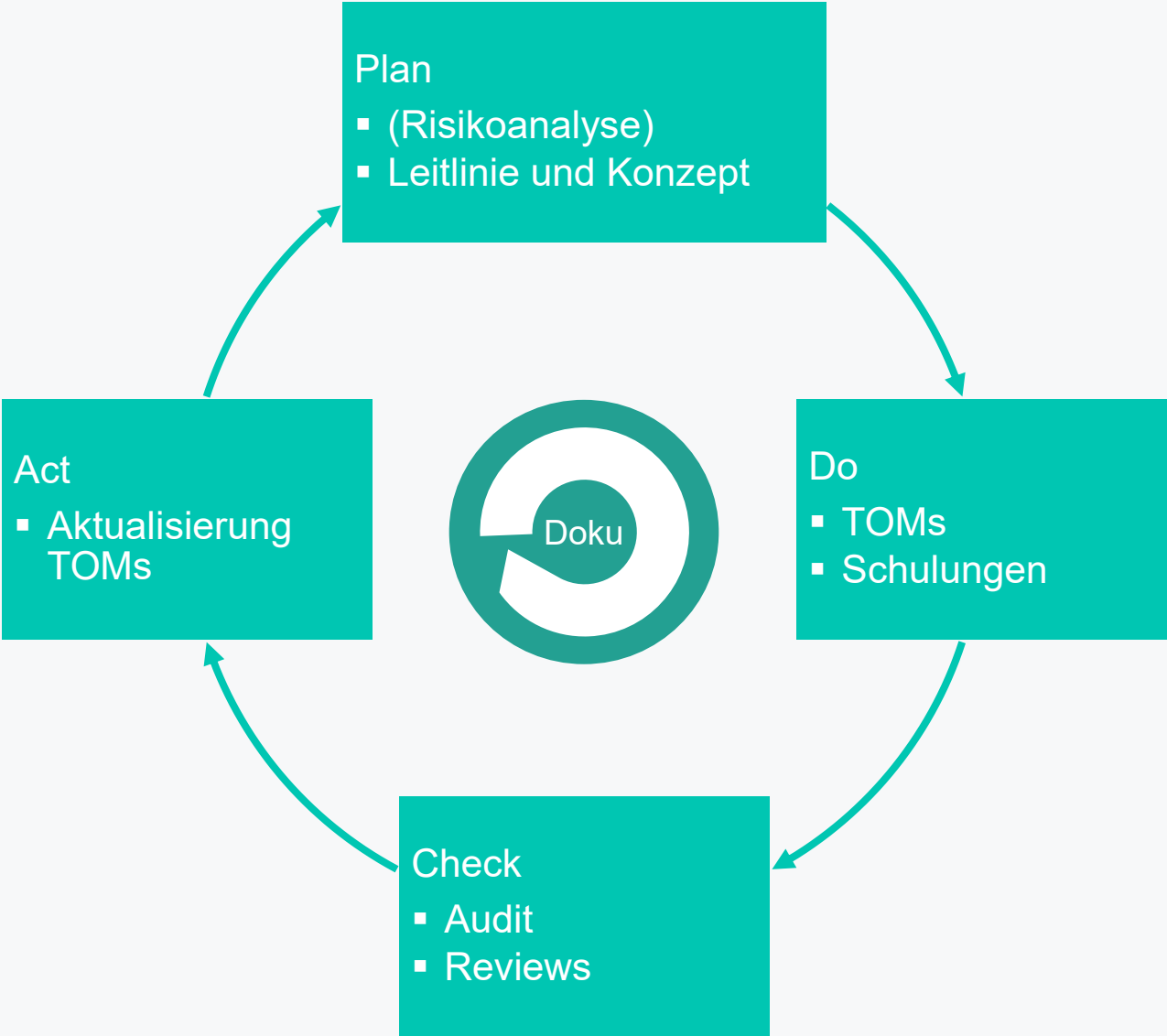
Wichtige Aufgaben eines ISMS sind:

- die Formulierung von (Sicherheits-)Zielen
- die Bestimmung der Assets
- die Risikobeurteilung
- die Risikobehandlung
- die kontinuierliche Verbesserung

Die ISO 2700X Normenreihen sowie der BSI-200-X Reihe beschreiben Anforderungen an ein System zum Management der Informationssicherheit!



# Der Sicherheitsprozess im integrierten MS

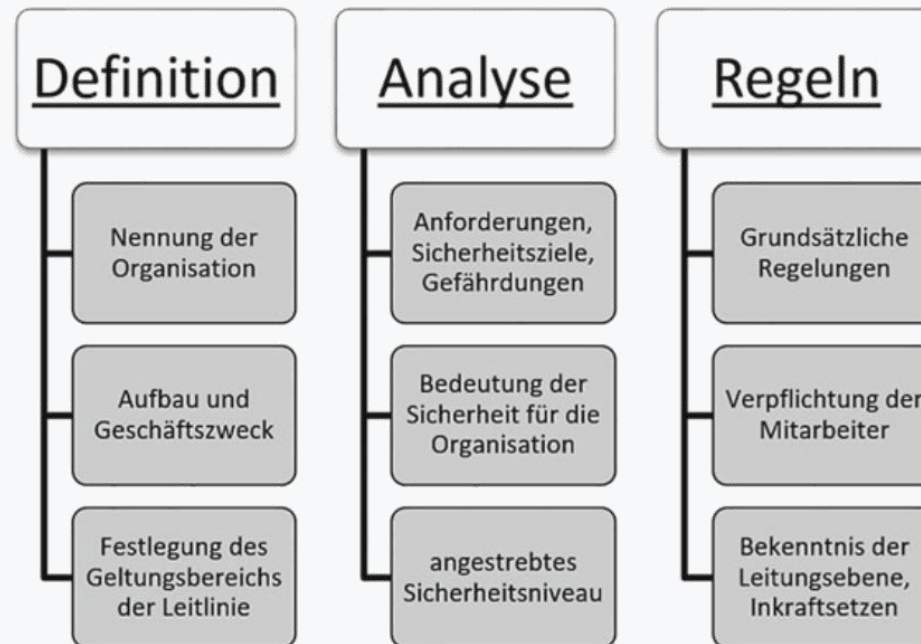


Quelle: Schrahe & Städter, 2019

# ISO 27001 - Leitlinie

## Security Policy – bzw. Sicherheitsleitlinie

- Dokumentation von Zielen, Zuständigkeiten, Ressourcen, etc.
- Abstraktes „Management-Dokument“



# Checkliste „IT-Sicherheitsleitlinie“

## Verantwortung der Leitung

## Geltungsbereich

## Inhalt

Stellenwert der IT-Sicherheit und die Bedeutung der IT für die Produktivität

Zusammenhang zwischen den Sicherheitszielen und den Geschäftszielen

Sicherheitsziele und Rahmenbedingungen der Sicherheitsstrategie im vorliegenden IT-System

Verbindlichkeit der Sicherheitsleitlinie für das Unternehmen

Beschreibung der zur Umsetzung etablierten Organisationsstruktur

Optional

- Aufzählung relevanter Gefährdungen
- Auflistung einzuhaltender gesetzlicher Vorgaben

## Einsetzen einer Entwicklungsgruppe

## Bekanntgabe der IT-Sicherheitsleitlinie

## Aktualisierung

# Sicherheitskonzept

**Um die Sicherheitsziele zu erreichen, müssen in einem Konzept geeignete technische und organisatorische Maßnahmen festgelegt werden:**

- Maßnahmen zur physischen Absicherung von Gebäuden und Räumlichkeiten,
- technische Vorkehrungen zur Absicherung der Schnittstellen eines Netzes und seiner Segmente,
- Regelungen zum Umgang mit klassifizierten Informationen,
- ein geeignetes Identitäts- und Berechtigungsmanagement,
- die Anwendung kryptographischer Maßnahmen,
- ausreichende Datensicherungsverfahren,
- Verfahren zur Erkennung und Abwehr von Schadsoftware.

# Erstellung eines IT-Sicherheitskonzeptes

Auswahl der IT-  
Sicherheitsmaßnahmen

Physisch  
Organisatorisch  
Personell  
IT-bezogen

Risikoakzeptanz

Akzeptanz Restrisiko  
Ergreifen weiterer Maßnahmen  
Abwälzen des Restrisikos (Versicherungen)

Erstellen von  
Systemsicherheits-  
politiken

PC-Sicherheitspolitik  
Netzsicherheitspolitik  
Internetsicherheitspolitik  
Social-Media Politik

Erstellen des IT-  
Sicherheitsplans

Prioritätenplan  
Ressourcenplan  
Zeitplan  
Festlegung Kontrollmechanismen

# Checkliste „Richtlinie zur IT-Nutzung“

- Umgang mit vertraulichen Informationen
- Relevante Gesetze und Vorgaben
- Kurzbeschreibung relevanter Rollen
- Schulung des Personals
- Pflicht zur Einrichtung von Vertretungsregelungen
- Verwaltungsanforderungen an die IT (Beschaffung, Betrieb, Wartung, Entsorgung)
- Grundlegende Sicherheitsmaßnahmen
- Regelung spezifischer IT-Dienste (Datenübermittlung, Internetnutzung)
- Organisatorische Regelungen zu personen- und funktionsbezogenen e-Mail-Adressen sowie Vertretungsregelungen
- Anforderungen an eine Firewall
- Erlaubte und nicht erlaubte Dienste und Protokolle
- Grundlegende Einstellung von Browser und e-Mail-Client
- Verhaltensregeln
- Virenschutzhinweis
- Übertragen und Herunterladen von Dateien

# Checkliste „Festlegung der Sicherheitsmaßnahmen“

- Schulungen
- Viren-Schutzprogramm
- e-Mail zentral auf dem File-Server prüfen
- Aktiven Inhalt beim Browsen im Internet verbieten
- Download von Programmen nur durch berechtigte Personen aus vertrauenswürdigen Quellen zulassen
- Firewall
- Spy- und Adware-Schutz
- Schutz vor Makroviren
- BIOS-Einstellungen
- Verhaltensregeln zur Vorbeugung
- Verhaltensregeln bei Virenbefall
- Glossar

# Checkliste Datensicherungsrichtlinie

- Wo werden Daten gespeichert?
- Welche Daten sind zu sichern?
- Wer ist zuständig für die Sicherung?
- Wie wird gesichert (Technik, Medien, Intervalle)?
- Wie lange werden Sicherungen aufbewahrt?
- Wie wird mit Notebooks (ohne ständigen Netzanschluss) umgegangen?
- Wie wird die Zuverlässigkeit der Datensicherung überprüft?
- Wie werden Daten im Schadenfall rekonstruiert?



# Checkliste Archivierungsrichtlinie

- Aufbewahrungsfristen
- Auswahl des Archivsystems (technische, organisatorische und rechtliche Faktoren)
- Gestaltung der Archivierung (Archivräume, Archivmedien, Datenformate, Aufbewahrungsstruktur, Indizierung, Entnahme, Vernichtung)

# Checkliste Notfallvorsorgerichtlinie

- Regelung der Verantwortlichkeiten
- Erstellen spezieller Notfallpläne (Brand, Stromausfall, HW-Ausfall, SW-Ausfall, Virenbefall, Sabotage)
- Dokumentationen (Prozesse, IT-Anwendungen, IT-Systeme, Verfügbarkeitsanforderungen, Wiederanlaufreihenfolge u.a.)
- Verhaltensregeln bei Sicherheitsvorfällen und Notfällen
- Alarmierungspläne
- Eskalationsstrategie
- Notfallübungen

## Checkliste „Zusatz zum Arbeitsvertrag“

- Verpflichtung auf die Einhaltung relevanter Gesetze
- Teilnahme an der Schulung vor Programmnutzung
- Regelungen zu privater Hard- und Software
- Installation und Konfiguration von Anwendungen
- Regelung für sichere Passwortgestaltung
- Umgang mit vertraulichen Informationen
- Hinweise zur Nutzung von Antivirenprogrammen
- Hinweise zur Datensicherung
- Verhalten bei Sicherheitsvorfällen

# Checkliste zur Einschätzung der Gefährdung

- Zeigt die Geschäftsleitung den erklärten Willen, für die Prävention Ressourcen (z.B. Personal) zur Verfügung zu stellen?
- Steht ein ausreichendes Budget für die Integration bzw. planvolle Vorbereitung der Nutzung neuer Technologien zur Verfügung?
- Wurden Schutzbedarf und darauf beruhende Gefahren als Teil eines ganzheitlichen betrieblichen Kontinuitätsmanagement analysiert?
- Wird die IT-Infrastruktur in Audits regelmäßig auf IT-Sicherheit, insbesondere konkrete Sicherheitslücken, überprüft? Sind dabei auch Angriffsvektoren durch Innentäter berücksichtigt?
- Besteht der Wille, erkannte Probleme im festgelegten Umfang zu beseitigen und darüber hinausgehende Präventivmaßnahmen zu ergreifen?
- Werden Präventions- und Reaktionspläne getestet?
- Erhalten Administratoren und IT-Anwender regelmäßig Schulungen, damit sie Gefährdungspotentiale besser einschätzen und qualifiziert reagieren können?
- Wird eine aktive Sicherheitskultur gelebt und gefördert?

**BSI-Standard 200-1: Managementsysteme für IT-Sicherheit (ISMS)**

- Managementprinzipien  
Managementpflichten  
reibungsloser Informationsfluss
- Ressourcen
- Mitarbeiter
- Sicherheitsprozess  
Ausgehend von Sicherheitszielen und einer davon abgeleiteten Sicherheitsstrategie wird ein Sicherheitskonzept erstellt.  
Ausgestaltung unter ...

**BSI-Standard 200-2: IT-Grundschutzvorgehensweise**

- Einführung eines ISMS

**BSI-Standard 200-3: Risikoanalyse auf der Basis von IT-Grundschutz**

ergänzende Sicherheitsanalyse zumeist in Form einer Risikoanalyse

**BSI-Standard 200-4: Notfallmanagement**

- eigenständiges Managementsystem
- Basis: Ergebnisse der klassischen IT-Grundschutz-Vorgehensweise
- Ziel: Vermeidung von Notfällen und Minimierung von Schäden

# ISO 27001

Sicherheitsziele werden in der Norm nur beispielhaft aufgezählt und sind meist mit den Begriffen Vertraulichkeit, Integrität und Verfügbarkeit verbunden.

Die Vertraulichkeit von Informationen zu wahren meint, dass diese nur einem entsprechend autorisierten Personenkreis zur Kenntnis gelangen.

Ähnlich meint die Wahrung der Integrität von Daten, dass nur autorisierte Änderungen vorgenommen werden dürfen. Bei der Verfügbarkeit geht es darum, dass Daten, Systeme und Services für autorisierte Zwecke ausreichend schnell zur Verfügung stehen müssen – Verzögerungen sind nur in akzeptablen Umfang zulässig.

# ISO 27001: Policies

**Policies (auch „Richtlinien“ oder „Arbeitsanweisungen“) müssen für konkrete Themen erarbeitet und umgesetzt werden**

- Mobiles Arbeiten (Home Office)
- Arbeiten mit mobilen Endgeräten (Dienst-Smartphone)
- Durchführung von Datensicherungen
- Umgang mit Sicherheitsvorfällen



# ISO 27001 - Begriffe

## Assets

- Alles, was für eine Organisation einen Wert darstellt, z.B. Grundstücke, Gebäude, Maschinen und Anlagen, Geschäftsprozesse etc.
- Information Assets (Informationswerte) wie Daten, Systeme, Anwendungen, IT- Services.
- Ergänzend kann man auch Soft Assets betrachten, wie z.B. das Image oder die Kreditwürdigkeit einer Organisation.

## Ereignis (Event)

- Jede Änderung des Zustands einer Informationsverarbeitung im Rahmen der Risikobeurteilung

## Sicherheitsereignis (Security Event)

- hat Auswirkungen auf die Sicherheit

## Sicherheitsvorfall (Security Incident)

- Ereignis, bei dem eine hohe Wahrscheinlichkeit für Auswirkungen auf die Sicherheit besteht
- In der Norm wird sehr genau zwischen Events und Incidents unterschieden.

## Sicherheits-Notfall

- ist ein Sicherheitsvorfall mit gravierenden oder sogar katastrophalen Auswirkungen auf die Sicherheit.

# ISO 27005: Risiken

## Risiko

- der mögliche Eintritt von Sicherheitsereignissen in der Informationssicherheit
- Ein Risiko wird in aller Regel als eine Kombination aus Eintrittswahrscheinlichkeit und Schadenhöhe definiert.
- Ein Risiko kann immer dann eintreten, wenn **Schwachstellen** vorhanden sind, d.h. wenn Sicherheitsmaßnahmen fehlen, ungeeignet konstruiert oder fehlerhaft angewendet werden. Man spricht von konstruktiven bzw. operativen Schwachstellen.

## Risikoidentifizierung

- Ermittlung von einzelnen Risiken für die Informationswerte der Organisation, soweit sie im Anwendungsbereich des ISMS liegen.
- Diese Ermittlung muss im Zusammenspiel mit den Verantwortlichen (Asset Owner bzw. Risk Owner) für die einzelnen Informationswerte geschehen.

## Risikoanalyse

- Für jedes Risiko wird die Schadenhöhe und die Eintrittshäufigkeit abgeschätzt, das Risiko dementsprechend festgelegt – z. B. in eine Risikoklasse eingeordnet.

## Risikobewertung

- Feststellung, welche Auswirkungen ein Risiko auf die Organisation hat: Meist geschieht dies durch eine Bewertung der Risiken mit Stufen wie TOLERABEL, MITTEL, HOCH, KATASTROPHAL.
- **In der Norm wird Risikobeurteilung als Zusammenfassung aus Risikoidentifizierung, Risikoanalyse und Risikobewertung betrachtet.**

# ISO 27001: Risikobehandlung

## Optionen und Sicherheitsmaßnahmen

Dienen zur Behandlung ermittelter Risiken nach Vorgaben der Norm.

Typische Optionen zur Risikobehandlung sind:

- Risikoakzeptanz  
man übernimmt einfach das Risiko ohne weitere Maßnahmen,
- Risikoverlagerung  
z. B. durch Verlagerung der betroffenen Informationsverarbeitung an einen sichereren Ort, etwa an einen qualifizierten Dienstleister,  
oder durch Versicherung der möglichen Schäden
- die Risikoreduktion  
z.B. durch Einsatz geeigneter Sicherheitsmaßnahmen,
- Risikobeseitigung  
z.B. durch Änderung des fraglichen Geschäftsprozesses und der unterstützenden IT, oder durch Einstellung des risikoreichen Geschäftsprozesses.

# ISO 27001: Controls / Maßnahmen

## Control

- Sicherheitsanforderungen, die eine Organisation zu erfüllen hat,
- immer dann, wenn die betreffende Anforderung im geschäftlichen Umfeld der Organisation relevant ist.
- Falls ein Control als irrelevant betrachtet wird, ist dies zu begründen.

## Praktische Vorgehensweise

- Tabelle, in der in der ersten Spalte die 114 Controls eingetragen werden,
- anschließend wird für jedes Top Level Asset eine weitere Spalte vorgesehen.
- Für jedes Asset und jedes Control wird dann in das entsprechende Feld eingetragen, ob das Control relevant ist.
- Zentrale Baustein für die Risikobehandlung
- Für die geplanten Optionen und Maßnahmen lassen sich auch Kostenschätzungen ableiten, die wiederum in den Genehmigungsprozess bei der Leitung einfließen müssen.
- Die Zusammenfassung dieser Daten wird als **Statement of Applicability (SoA)** bezeichnet.

# ISO 27001:2022 und ISO 27002:2022

## Neue Version 2022 als Update von 2013:

- ISO 27001 nur Annex A = Controls getauscht
- ISO 27002 komplett neu, mehr Details
- 114 -> 93 Controls
- 11 neu z.B. Cloud Service, Web Filtering, Secure Coding

## Kategorisierung: 4 statt 14 sections

- Organizational Controls
- People Controls
- Physical Controls
- Technological Controls

## 2 Jahre Transition Period: 1.4.22 – 1.4.24

**27001:2022 als Entwurf in Englisch verfügbar (Beuth Verlag)**

**27002:2022 als pdf bestellbar in Englisch (Beuth Verlag)**

**ISO/IEC 27001: Zertifizierung auf der Basis von IT-Grundschutz**

Prüfung des ISMS

Prüfung der konkreten Sicherheitsmaßnahmen

Prüfung durch persönlich zertifizierte Auditoren

- Sichtung der vom Unternehmen vorgelegten Referenzdokumente
- Durchführung einer Vor-Ort-Prüfung
- Erstellung eines Audit-Reports

Erteilung eines Zertifikates!

# ISO 2700X:2013 vs. BSI Grundschatz

## ISO 2700X:2013

- Bestehend aus Managementrahmen und Controls (Anhang A ISO 27001)
- Vergleichsweise abstrakt, lässt viel Interpretationsspielraum.
- Beispiel Telearbeit: Control A.6.2.1  
„Eine Richtlinie und unterstützende Sicherheitsmaßnahmen sind umgesetzt, um die Risiken, welche durch die Nutzung von Mobilgeräten bedingt sind, zu handhaben.“
- Die ISO 27002 liefert weitere 2,5 Seiten Umsetzungshinweise (nicht normativ)

## BSI Grundschatz

- Bestehend aus BSI-Standards und Gefährdungen sowie Maßnahmen aus Grundschatz-Kompendium
- Zeigt konkrete Maßnahmen auf.
- Beispiel Telearbeit: OPS 1.2.4 beschreibt auf 6 Seiten ausführlich die Gefährdungslage, welche Maßnahmen getroffen werden müssen, und verweist auf weiterführende Informationen.
- Unter INF.8 und INF.9 werden auf jeweils 6 weiteren Seiten Spezifika von Heim- und Mobilarbeitsplätzen weiter vertieft und weitere Maßnahmen definiert.

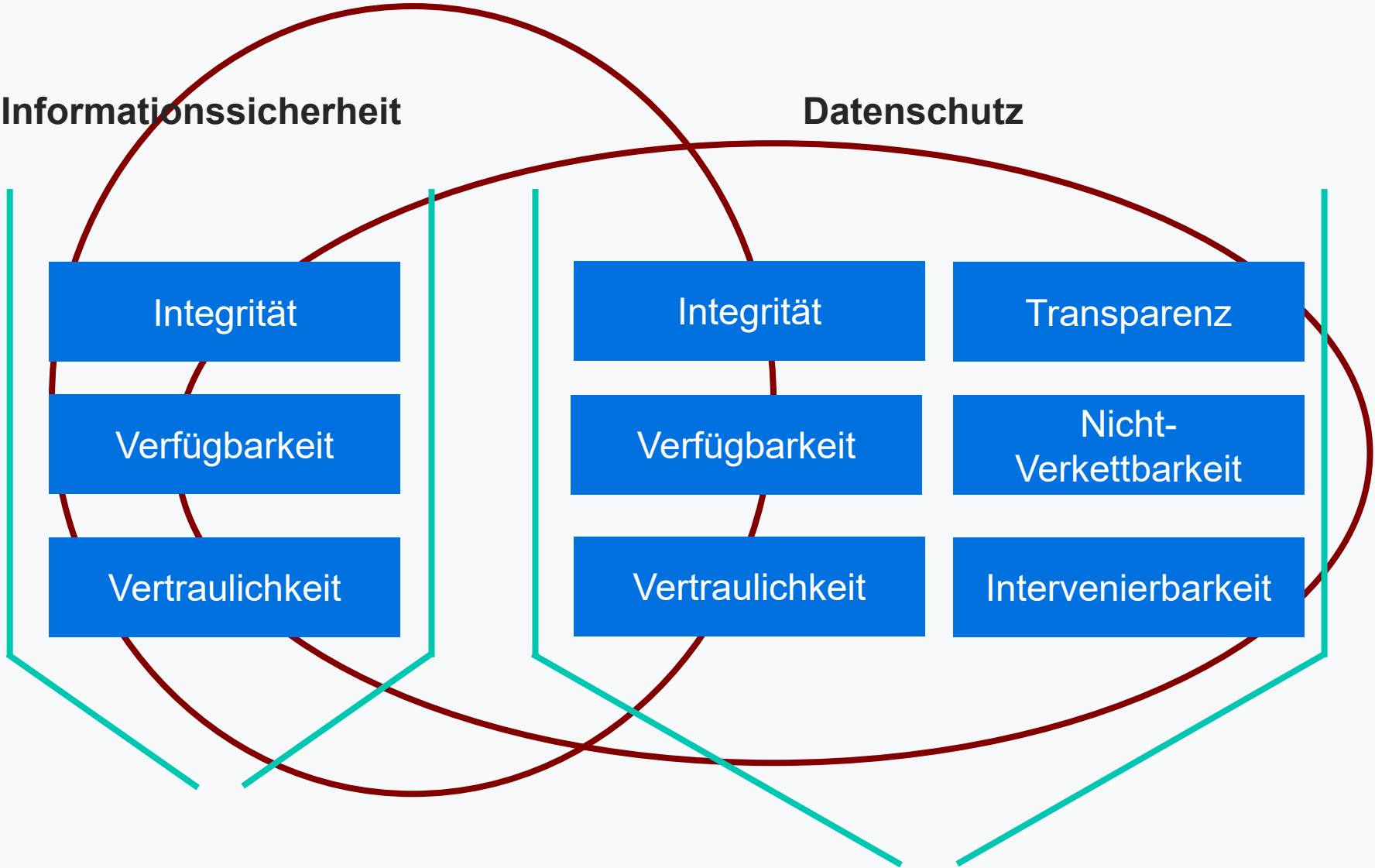
# Notwendigkeit eines DSMS?

- Aus der Forderung der DSGVO nach vorbeugenden sowie reaktiven technischen als auch organisatorischen Maßnahmen zum Zwecke des Schutzes personenbezogener Daten, die zudem regelmäßig zu überprüfen sind, kann die Notwendigkeit eines sogenannten Datenschutzmanagementsystems (DSMS) abgeleitet werden [Vgl. Gennen, 2017; Jandt, 2017; Krader, 2017]
- Bei den Schutzzielen Verfügbarkeit, Integrität und Vertraulichkeit ergeben sich Überschneidungen zwischen ISM und DSM, was den Einsatz derselben TOMs erforderlich macht.
- Durch den Stellenwert der Informationssicherheit für den Datenschutz müsste ein eigenständiges DSMS nahezu alle ISMS-Bestandteile abbilden [Vgl. Quiring-Kock, 2012].
- Das Ziel der Informationssicherheit nach Rechtskonformität bedingt auch, dass der Datenschutz als Voraussetzung für die Informationssicherheit betrachtet werden muss.
- Aber: Eine Trennung zwischen DSMS und ISMS ist erforderlich, um den Kontrollfunktionen des DSMS gegenüber dem ISMS gerecht werden zu können [Vgl. Rost, 2013]



# Informationssicherheit vs. Datenschutz

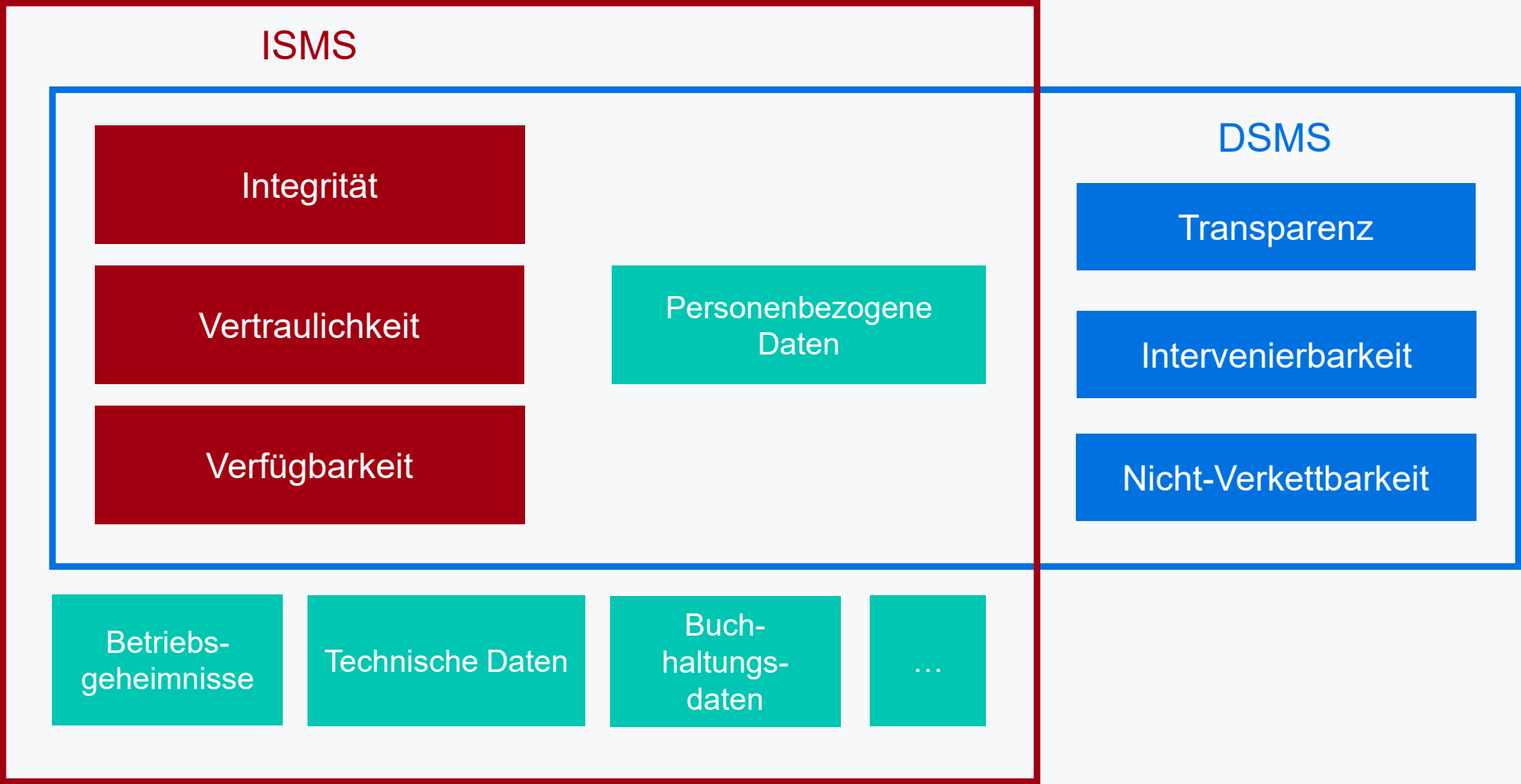
## Schutzziele



Quelle: Schrahe & Städter, 2019

# Schnittmengen Informationssicherheits- & Datenschutzmanagement

## Überschneidungen bei Schutzziele von ISMS und DSMS



Quelle: Schrahe & Städter, 2019

| Name                 | Bedeutung                                                                                                                                                                         | ISMS | DSMS |
|----------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------|------|
| Integrität           | Korrektheit, Unmodifiziertheit und Aktualität von Daten                                                                                                                           | ✓    | ✓    |
| Verfügbarkeit        | Zugreifbarkeit von Daten für autorisierte Benutzer                                                                                                                                | ✓    | ✓    |
| Vertraulichkeit      | Beschränkung der Zugreifbarkeit auf Berechtigte                                                                                                                                   | ✓    | ✓    |
| Nicht-Verkettbarkeit | Ausschließliche Verarbeitung für den Zweck, für den die Erhebung stattfand                                                                                                        | ✗    | ✓    |
| Transparenz          | Sichtbarkeit für Betroffene, welche Daten zu welchem Zweck erhoben und verarbeitet werden, wer die Verantwortung hierfür trägt und unter welchen Bedingungen die Löschung erfolgt | ✗    | ✓    |
| Intervenierbarkeit   | Betroffenenrechte Berichtigung, Sperrung und Löschung sind jederzeit ausübbar                                                                                                     | ✗    | ✓    |
| Datenminimierung     | Übergeordnetes Ziel die Datenerhebung und -verarbeitung auf das notwendige Maß zu beschränken                                                                                     | ✗    | ✓    |

Quelle: vgl. Schrahe & Städter, 2019

# Integration DSMS mit ISMS

- Durch eine Integration ergeben sich Synergieeffekte von gemeinsamen Sensibilisierungsmaßnahmen über die Dokumentation von TOMs und Abläufen bis hin zu einheitlichen Prozessen zur Gewährleistung von Informationssicherheit.
- Durch die Notwendigkeit im Rahmen eines ISMS Zuständigkeiten zu definieren, fachliche Qualifikationen herbeizuführen, Richtlinien zu schaffen sowie ein Berichtswesen aufzubauen und alle hierfür erforderlichen Aktivitäten zu dokumentieren, wird bereits ein Großteil der Rechenschaftspflichten nach Art. 5 Abs. 2 der EU-DSGVO abgedeckt.
- Eine Trennung bedingt eine Doppelbesetzung gleicher Funktionen sowie doppelte Dokumentationsaufwände.
- Da viele Unternehmen bereits heute ein ISMS verwenden, ist die Integration weiterer Datenschutzmaßnahmen ohnehin wirtschaftlicher, als der Aufbau eines separaten Managementsystems.
- Der Nachweis der Umsetzung eines Managementsystems wirkt sich positiv auf Geschäftspartner und Kunden aus, gegenüber denen ein professioneller Eindruck vermittelt und das Vertrauen gestärkt wird.

| Name/Standard                           | Schwerpunkt                                                                  | Zertifizierbarkeit       |
|-----------------------------------------|------------------------------------------------------------------------------|--------------------------|
| BSI-Grundschutzmodul 1.5                | Datenschutz                                                                  | ✗                        |
| EU DSGVO                                | Datenschutz                                                                  | ✗                        |
| European Privacy Seal                   | Datenschutz                                                                  | ✓                        |
| General Accepted Privacy Principels     | Datenschutz                                                                  | ✗                        |
| ISO 27.001                              | Informationssicherheit                                                       | ✓                        |
| ISO 27.002                              | Informationssicherheit                                                       | Indirekt über ISO 27.001 |
| ISO 27.018                              | Datenschutz                                                                  | Indirekt über ISO 27.001 |
| ISO 27.701                              | Erweiterung zu ISO/IEC 27001 und ISO/IEC 27002 für das Datenschutzmanagement | Indirekt über ISO 27.001 |
| ISO 29.100                              | Datenschutz                                                                  | ✗                        |
| Nymity Privacy Accountability Framework | Datenschutz                                                                  | ✗                        |
| Standard-Datenschutzmodell              | Datenschutz                                                                  | ✗                        |

Quelle: Schrahe & Städter, 2019

# Integriertes MS-System

## Das Fundament eines integrierten Managementsystems umfasst:

- Strukturierte Dokumentation von Prozessen/Verarbeitungstätigkeiten, Assets (Informationen, HW, SW), Datenkategorien, Verantwortlichkeiten, Verarbeitungszwecken, TOMs
- Risikoanalyse beziehungsweise DSFA
- Umgang mit Betroffenenanfragen und Sicherheitsvorfällen

Aus der Bedeutung einer strukturierten Dokumentation ergibt sich die Notwendigkeit der Verwendung von Softwaretools.

Diese SW-Tools sollen eine standardkonforme Dokumentation – z.B. Nach ISO 27.001 – unterstützen. Damit erleichtern sie eine spätere Zertifizierung.

Die Dokumentationserfordernis muss allen Phasen des Managementzyklus zugeordnet werden.

# 6.4

## Fallstudie

# Vorgaben des BSI

## Aufgabe

Bitte das Dokument ISMS.1 Sicherheitsmanagement (Edition\_2023) des BSI durchlesen! Dies ist auch verfügbar unter:

[https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/Grundschutz/IT-GS-Kompendium\\_Einzel\\_PDFs\\_2023/01\\_ISMS\\_Sicherheitsmanagement/ISMS\\_1\\_Sicherheitsmanagement\\_Edition\\_2023.html](https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/Grundschutz/IT-GS-Kompendium_Einzel_PDFs_2023/01_ISMS_Sicherheitsmanagement/ISMS_1_Sicherheitsmanagement_Edition_2023.html)

Im weiteren Verlauf der Lehrveranstaltung sollten auch die folgenden Lektionen des Online-Kurses „Informationssicherheit mit IT-Grundschutz“ im Eigenstudium abgearbeitet werden: <https://www.bsi.bund.de/dok/10990040>

Lektion 1: Einstieg

Lektion 2: Sicherheitsmanagement

Lektion 3: Strukturanalyse

Lektion 4: Schutzbedarfsfeststellung

Lektion 5: Modellierung

Lektion 6: IT-Grundschutz-Check

Lektion 7: Risikoanalyse

Lektion 8: Umsetzungsplanung

Lektion 9: Aufrechterhaltung und Verbesserung



# Umsetzung eines ISMS mit verinice

## Live Demo: ISMS verinice

- Hinweise zur Installation und Konfiguration von verinice
- Funktionalitäten des ISMS
- Präsentationen und weitere Informationen zu verinice unter <https://www.youtube.com/c/verinice/videos>, z.B.: verinice.XP 2023: Chefsache Informationssicherheit, <https://www.youtube.com/watch?v=yPZR0Gf0NbA>

verinice kann je nach Bedarf und Einsatzszenario um verschiedene Zusatz-Module erweitert werden. Dazu gehören als kostenloses Angebot u.a. Mindeststandards des BSI und IT-Grundschutz-Profile.

Als kostenpflichtige Zusatzmodule sind erhältlich: Risikokatalog sowie Risikokatalog Plus (ISO 27001 / ISO 27019), Datenschutzmodul, Branchenstandard B3S Krankenhaus und PCI DSS.

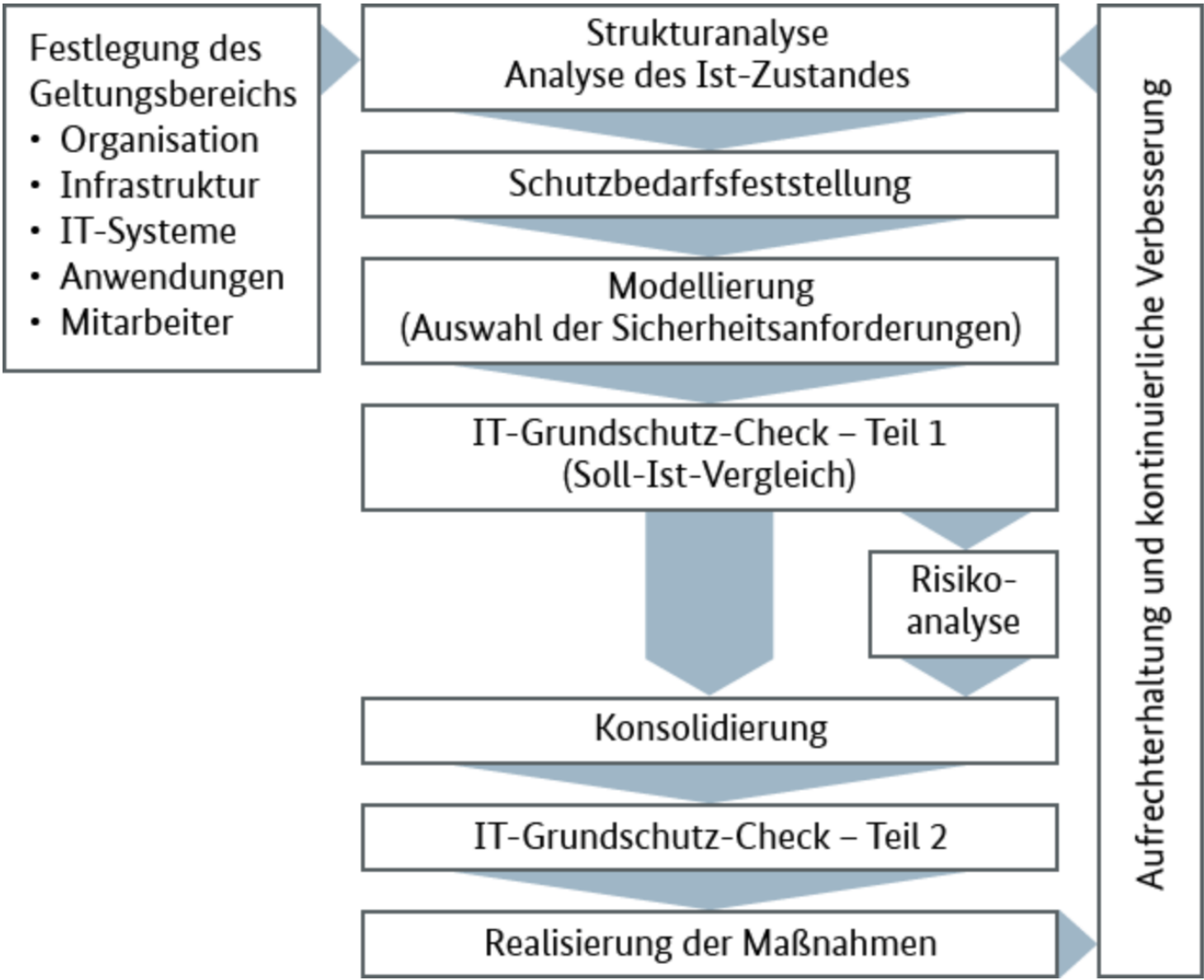
# ISMS: Übungsaufgaben und Gruppenarbeiten

## Vorstellung des Beispielunternehmens RECPLAST

### Lässt sich dieses Beispiel auf Ihr Unternehmen bzw. Ihre Behörde übertragen?

- Gibt es einen ISB, wie wurde er bestimmt, aus welchem Bereich kommt er?
- Wie ist er organisatorisch zugeordnet?
- Gibt es ein IS-Management-Team? Wie ist es besetzt?
- Falls Sie einen Produktionsbereich – mit Industrial Control Systems – haben, gibt es einen ICS-ISB? Wie arbeitet er mit dem ISB zusammen?

# Vorgehensweise der Standard-Absicherung



Quelle: BSI, Informationssicherheit mit IT-Grundschutz, 2021

# Strukturanalyse

## Teamarbeit

- Es soll ein typisches Unternehmen einer bestimmten Branche oder eine Behörde ausgewählt werden.
- verinice kann in der virtuellen Umgebung oder im Rahmen einer eigenen Installation (Download-Link wird bei Bedarf durch den Dozenten herausgegeben) genutzt werden.
- Eine Multi-User-Fähigkeit der entsprechenden virtuellen Umgebungen ist nicht gegeben. Die Teilnehmer sollen deswegen im Rahmen einer MS-Teams-Sitzung ggf. gemeinsam an ihrem Informationsverbund arbeiten.
- Orientieren Sie sich bitte am Beispiel RECPLAST.
- Der erstellte Informationsverbund in verinice kann im Rahmen der folgenden Übungen erweitert werden.
- Am Ende der Veranstaltung wird die Export-Datei des jeweiligen Verbunds über den entsprechenden Teams-Kanal für die weitere Verwendung gesichert.

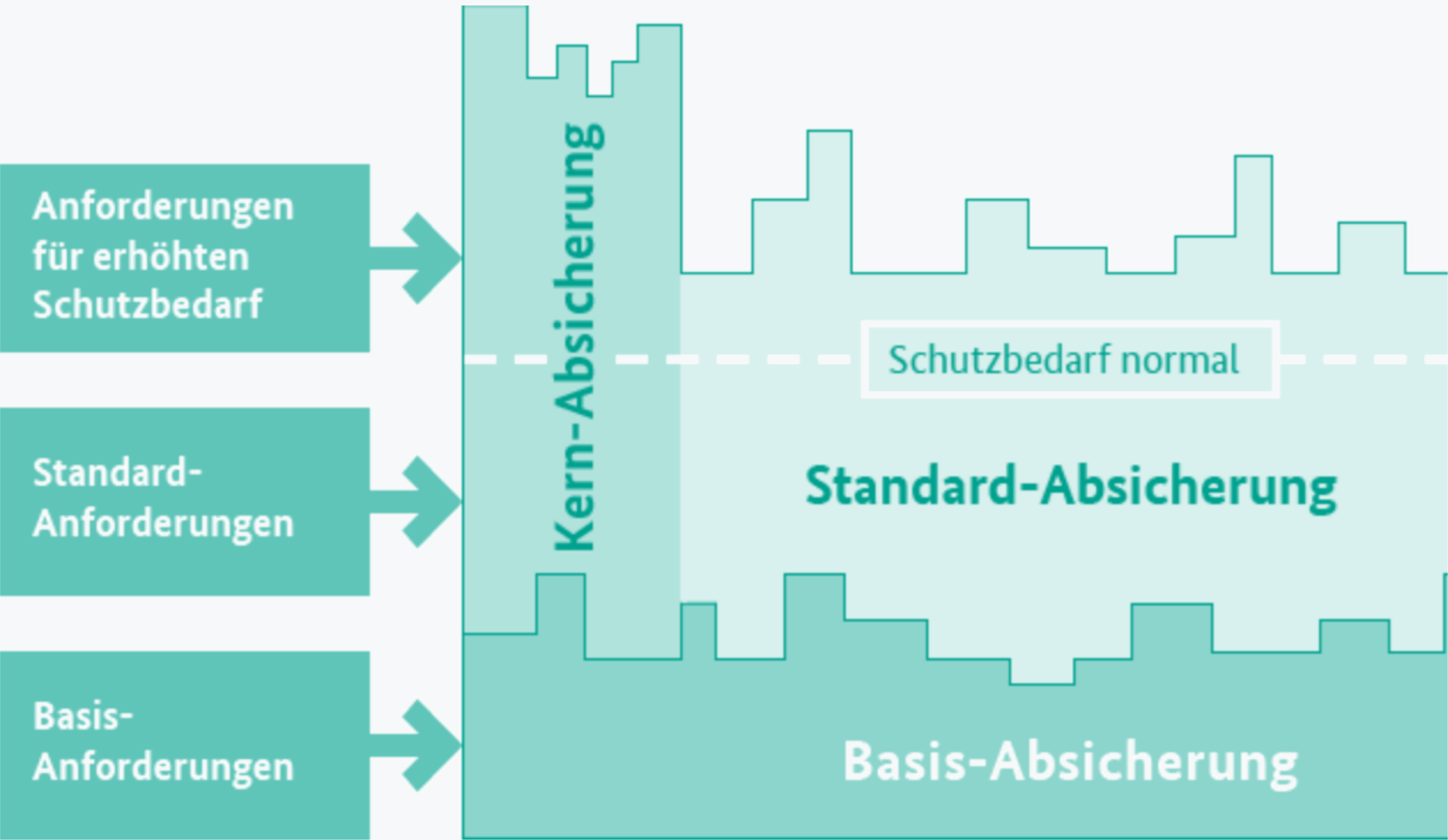
## Folgende Aufgaben sind hierbei umzusetzen:

- Dokumentieren Sie jeweils mindestens drei Geschäftsprozesse, Anwendungen und die in ihnen verwendeten wichtigen Informationen.
- Dokumentieren Sie den individuellen Netzplan mit den notwendigen Angaben. Drei bis fünf Komponenten sollten ausreichend sein.
- Dokumentieren Sie die Informationen zu den verschiedenen Arten von IT-Systemen, die im Informationsverbund in Betrieb sind oder deren Einsatz geplant wird (min. 3 Systeme).
- Erfassen Sie die räumlichen Gegebenheiten (Liegenschaften, Gebäude, Räume, auch Produktionsstätten).

# Schutzbedarfsanalyse und Modellierung des Informationsverbunds

## Teamarbeit

- ...
- Führen Sie eine Schutzbedarfsanalyse im eigenen Informationsverbund durch.
- Ordnen Sie den erfassten Komponenten in Ihrem Informationsverbund die passenden Prozess- und System-Bausteine des BSI zu.
- Maßnahmen und Umsetzungshinweise werden im Rahmen der folgenden Übungen definiert.
- Orientieren Sie sich bitte am Beispiel RECPLAST.
- Der erstellte Informationsverbund in verinice kann im Rahmen der folgenden Übungen erweitert werden.
- Am Ende der Veranstaltung wird die Export-Datei des jeweiligen Informationsverbunds über den entsprechenden Teams-Kanal für die weitere Verwendung gesichert.



# Realisierungsplanung

## Vorgehensweise nach BSI

Zusammenstellung der zu realisierenden Maßnahmen

Prüfung auf Redundanz bzw. möglichen Wegfall von Maßnahmen

Schätzen des finanziellen und personellen Aufwandes

- Einmaliger Aufwand für die Einführung der Maßnahmen
- permanente Aufwand für den laufenden Betrieb

Umsetzungsreihenfolge mit Zeitplanung

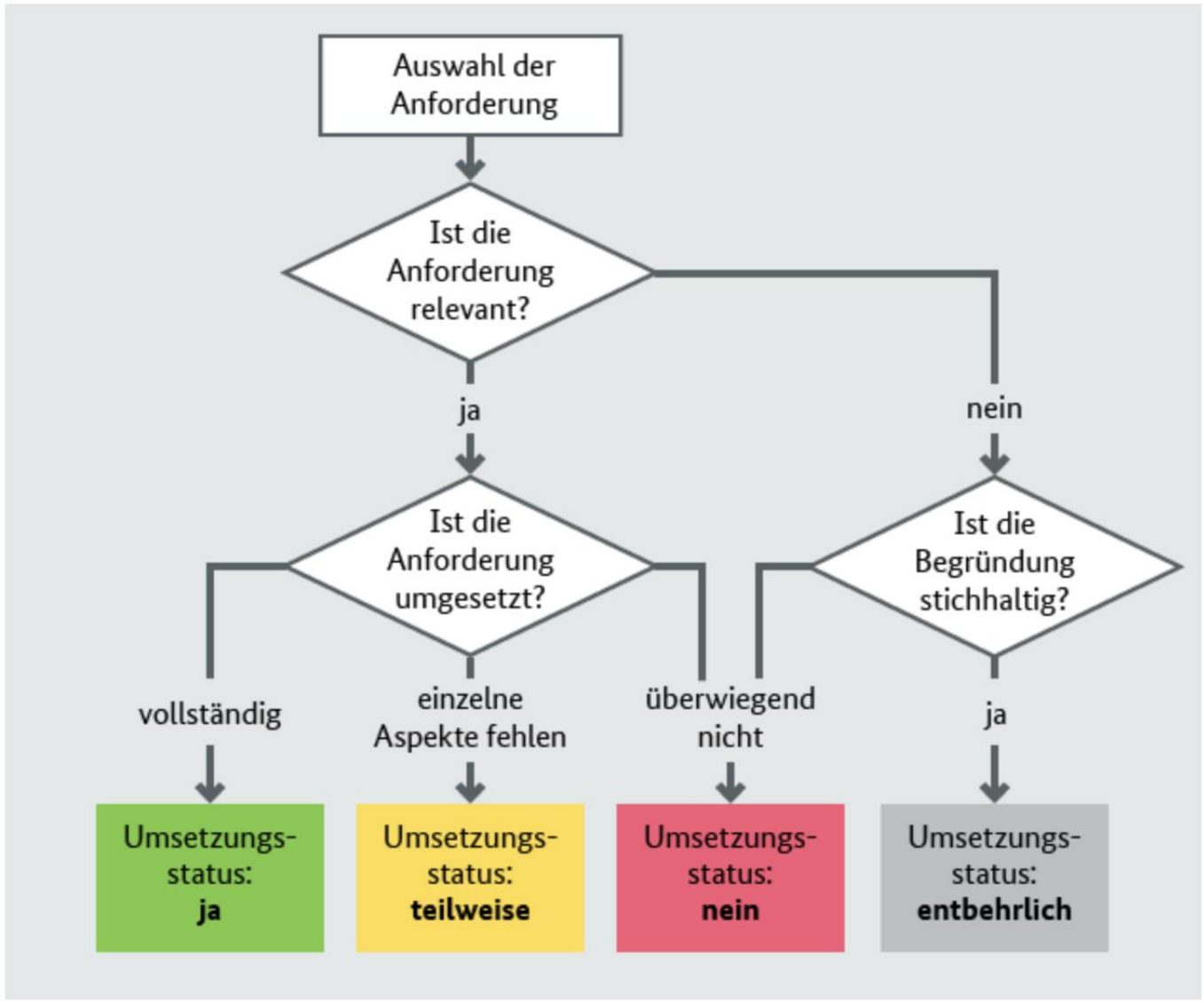
Transformationsmanagement

- Sensibilisierung der Mitarbeiter
- Schulungsmaßnahmen

Umsetzung der Sicherheitsmaßnahmen

Regelmäßige Überprüfung der Sicherheitsmaßnahmen auf ihre Wirksamkeit

# Vorbereitung und Umsetzung der notwendigen Maßnahmen

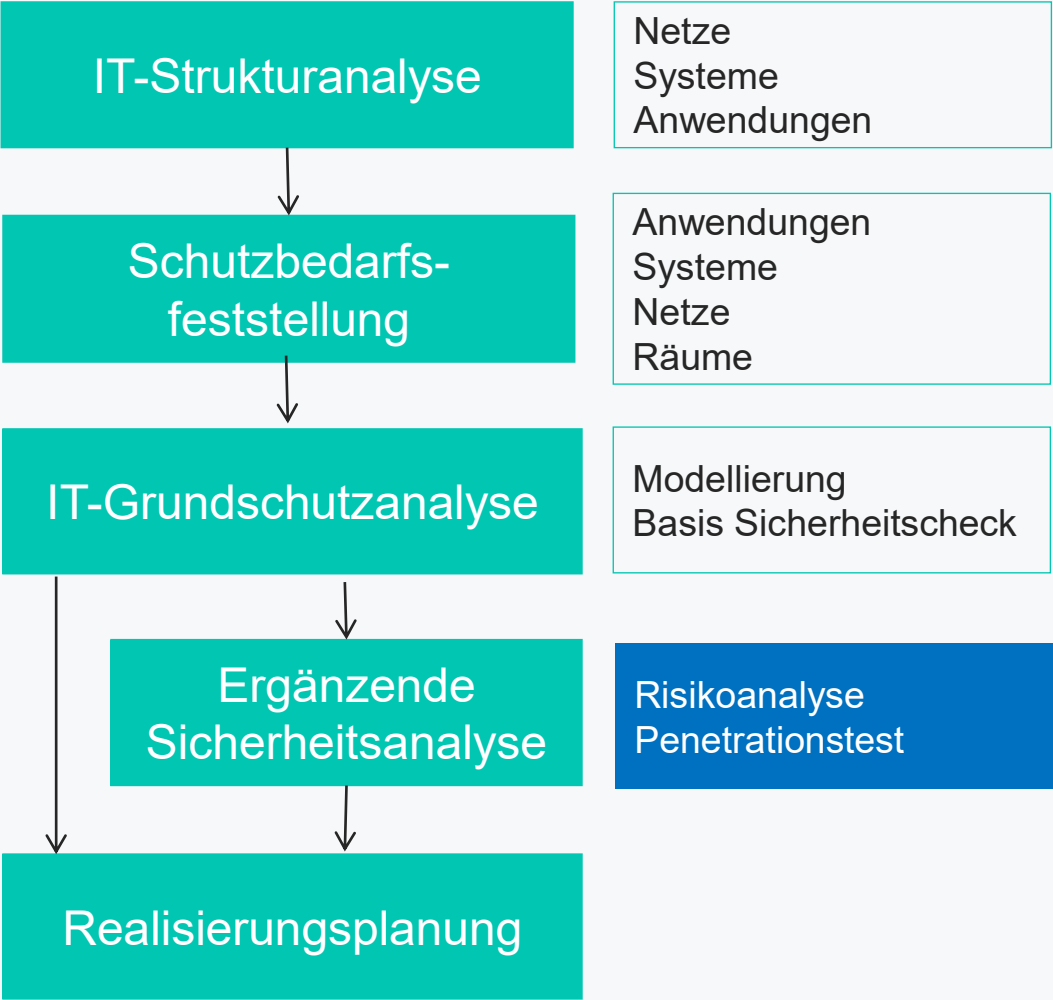


Wichtig!

Ein IT-Grundschutz-Check ist ein Soll-Ist-Vergleich zwischen Sicherheitsanforderungen und tatsächlich umgesetzten Sicherheitsmaßnahmen.



# Zusätzlicher Analysebedarf



Quelle: Hofmann et. al., 2010, S. 310

# Risikoszenarien: Beispiel für Bedrohungen und Schwachstellen

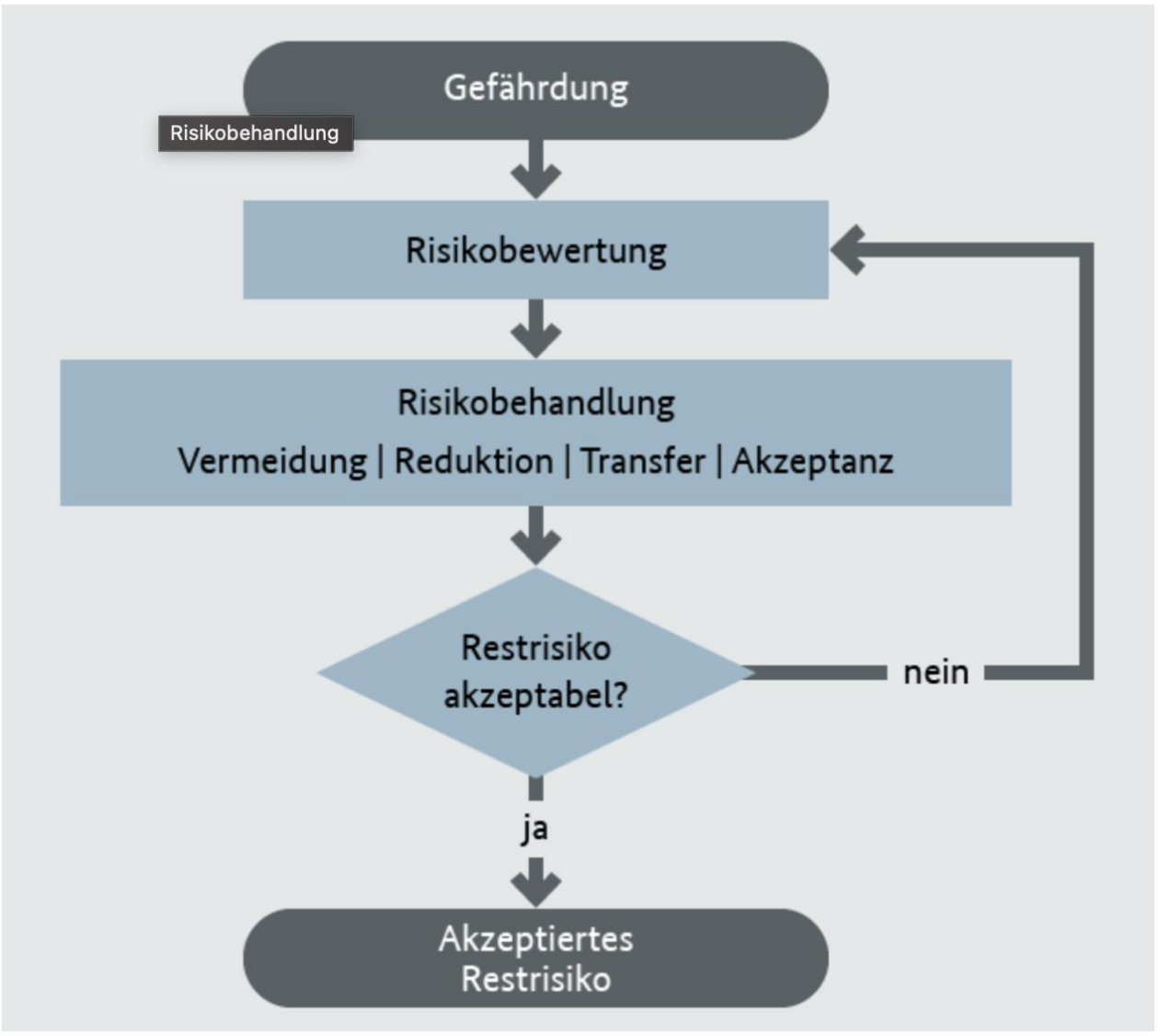
## Bestimmen und Bewerten von Bedrohungen

Threats werden aufgrund der erwarteten Häufigkeit wie folgt klassifiziert:

- (0) Selten
- (1) Jährlich
- (2) Monatlich
- (3) Wöchentlich
- (4) Täglich
- (5) Stündlich

## Bestimmen und Bewerten von Schwachstellen

- (0) Sehr niedrig: Das Ausnutzen der Schwachstelle erfordert einen gerichteten Angriff, hoch spezialisiertes Wissen oder Fertigkeiten und Ressourcen, die einem Angreifer nicht üblicherweise zur Verfügung stehen. Seltene Naturereignisse oder technisches Versagen großen Ausmaßes kann die Schwachstelle auslösen.
- (1) Niedrig: Das Ausnutzen der Schwachstelle erfordert einen gerichteten Angriff durch einen entschlossenen Angreifer. Naturereignisse oder technisches Versagen können die Schwachstelle auslösen.
- (2) Hoch: Das Ausnutzen der Schwachstelle kann durch einen automatisierten Angriff erfolgen (z.B. geskriptete Angriffe) oder auch durch einen Angreifer mit begrenzten Kapazitäten und Fähigkeiten. Naturereignisse oder technisches Versagen können die Schwachstelle auslösen.
- (3) Sehr hoch: Ein Ausnutzen der Schwachstelle könnte zufällig stattfinden und ist sehr wahrscheinlich. Sogar jemand ohne böse Intention könnte die Schwachstelle unbeabsichtigt auslösen. Häufig auftretende Ereignisse würden die Schwachstelle zweifellos auslösen.



# Ergänzende Risikoanalyse

## Optionale Teamarbeit

- ...
- Da Sie fiktiv davon ausgehen, das zumindest ein Zielobjekt in Ihrem Informationsverbund einen hohen oder sehr hohen Schutzbedarf in mindestens einem der drei Grundwerte Vertraulichkeit, Integrität und Verfügbarkeit hat, sollten Sie eine Risikoanalyse durchführen.
- Ggf. gibt für ein Zielobjekt keinen hinreichend passenden Baustein im IT-Grundschutz-Kompendium; dies erfordert auch die Durchführung einer Risikoanalyse.
- Orientieren Sie sich bitte am Beispiel RECPLAST.
- Der erstellte Informationsverbund in verinice soll auch im Rahmen der folgenden Übungen erweitert werden.
- Am Ende der Veranstaltung wird die Export-Datei des jeweiligen Informationsverbunds über den entsprechenden Teams-Kanal für die weitere Verwendung gesichert.

# Vielen Dank für Ihre Aufmerksamkeit!